

MANUAL DE POLÍTICAS Y LINEAMIENTOS DE SEGURIDAD Y PRIVACIDAD DE LA INFORMACIÓN

**Proceso Información, Innovación y Tecnología
Subproceso Seguridad de la Información
VERSIÓN 6
MN-IIT-0072
Año 2025**

TABLA DE CONTENIDO

1. OBJETIVO	5
2. ALCANCE	5
3. DEFINICIONES Y SIGLAS	5
4. RESPONSABILIDAD Y CUMPLIMIENTO.....	5
5. CONTROLES ORGANIZACIONALES	6
5.1 Políticas de seguridad de la información.....	6
5.2 Roles y responsabilidades para la seguridad de la información	7
5.3 Segregación de funciones.....	7
5.4 Responsabilidades de la dirección.....	9
5.5 Contacto con las autoridades.....	11
5.6 Contacto con grupos de interés especial.....	12
5.7 Inteligencia de amenazas.....	13
5.8 Seguridad de la información en la gestión de proyectos.....	14
5.9 Inventario de información y otros activos asociados	15
5.10 Uso aceptable de la información y otros activos asociados	16
5.11 Devolución de activos	18
5.12 Clasificación de la información	19
5.13 Etiquetado de la información	20
5.14 Transferencia de información.....	22
5.15 Control de acceso	26
5.16 Gestión de identidad.....	29
5.17 Información de autenticación.....	30
5.18 Derechos de acceso	31
5.19 Seguridad de la información en las relaciones con los proveedores.....	34
5.20 Abordar la seguridad de la información en los acuerdos con proveedores.....	38
5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC.....	41
5.22 Seguimiento, revisión y gestión de cambios de servicios de proveedores.....	42
5.23 Seguridad de la información para el uso de servicios en la nube	44
5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información.....	45
5.25 Evaluación y decisión sobre eventos de seguridad de la información	47
5.26 Respuesta a incidentes de seguridad de la información.....	47
5.27 Aprendiendo de los incidentes de seguridad de la información	49
5.28 Recopilación de evidencias digitales.....	50
5.29 Seguridad de la información durante la interrupción.....	51

5.30	Preparación de las TIC para la continuidad del negocio	53
5.31	Requisitos legales, estatutarios, reglamentarios y contractuales	55
5.32	Derechos de propiedad intelectual	56
5.33	Protección de registros	58
5.34	Privacidad y protección de los datos personales	59
5.35	Revisión independiente de la seguridad de la información	61
5.36	Cumplimiento de políticas, normas y estándares de seguridad de la información	62
5.37	Procedimientos operativos documentados	63
6.	CONTROLES DE PERSONAS	65
6.1	Selección	65
6.2	Términos y condiciones de empleo	67
6.3	Concientización, educación y capacitación en seguridad de la información	68
6.4	Proceso disciplinario	70
6.5	Responsabilidades después de la terminación o cambio de empleo	72
6.6	Acuerdos de confidencialidad y no divulgación de información	74
6.7	Trabajo a distancia (Política de Teletrabajo)	75
6.8	Reporte de eventos de seguridad de la información	78
7.	CONTROLES FISICOS	79
7.1	Perímetros de seguridad física	79
7.2	Entrada física	81
7.3	Asegurar oficinas, salas e instalaciones	82
7.4	Supervisión de la seguridad física	83
7.5	Protección contra amenazas físicas y ambientales	85
7.6	Trabajar en áreas seguras	86
7.7	Escritorio y pantalla despejados	90
7.8	Ubicación y protección del equipo	92
7.9	Seguridad de los activos fuera de las instalaciones	94
7.10	Medios de almacenamiento	96
7.11	Utilidades de apoyo	97
7.12	Seguridad del cableado	98
7.13	Mantenimiento de equipos	100
7.14	Eliminación segura o reutilización de equipos	101
8.	CONTROLES TECNOLOGICOS	102
8.1	Dispositivos de punto final de usuario	102
8.2	Derechos de acceso privilegiado	105
8.3	Restricción de acceso a la información	106

8.4	Acceso al código fuente	107
8.5	Autenticación segura	108
8.6	Gestión de capacidad.....	110
8.7	Protección contra malware	110
8.8	Gestión de vulnerabilidades técnicas.....	112
8.9	Gestión de la configuración	114
8.10	Eliminación de información.....	116
8.11	Enmascaramiento de datos.....	117
8.12	Prevención de fuga de datos.....	118
8.13	Copia de seguridad de la información	119
8.14	Redundancia de las instalaciones de procesamiento de información.....	122
8.15	Registro	123
8.16	Actividades de seguimiento.....	124
8.17	Sincronización de reloj.....	126
8.18	Uso de programas de utilidad privilegiados	127
8.19	Instalación de software en sistemas operativos	128
8.20	Seguridad en redes	131
8.21	Seguridad de los servicios de red	134
8.22	Segregación de redes	135
8.23	Filtros Web.....	136
8.24	Uso de criptografía.....	138
8.25	Ciclo de vida de desarrollo seguro	140
8.26	Requisitos de seguridad de la aplicación.....	142
8.27	Principios de arquitectura e ingeniería de sistemas seguros.....	144
8.28	Codificación segura.....	146
8.29	Pruebas de seguridad en desarrollo y aceptación.....	147
8.30	Desarrollo subcontratado	148
8.31	Separación de los entornos de desarrollo, prueba y producción	149
8.32	Gestión del cambio	151
8.33	Información de prueba	153
8.34	Protección de los sistemas de información durante las pruebas de auditoría	154
9.	CONTROLES ADICIONALES	155
9.1	Analítica De Datos	155
9.2	Inteligencia Artificial.....	158
10.	MARCO LEGAL Y NORMATIVO	161
11.	ACCIONES DE IMPLEMENTACIÓN	161



12. CONTROL DE CAMBIOS.....	161
-----------------------------	-----

1. OBJETIVO

Proporcionar a los usuarios internos y externos de la **Unidad Administrativa Especial - Dirección de Impuestos y Aduanas Nacionales (DIAN)**, las políticas y lineamientos de obligatorio cumplimiento con el fin de gestionar la Seguridad y Privacidad de la Información en función de los principios de integridad, confidencialidad, disponibilidad, no repudio y autenticidad de la información.

2. ALCANCE

Este manual aplica a todos los usuarios internos y externos de la entidad, establece las políticas y lineamientos para el manejo de cualquier tipo de información (física y digital de la **DIAN**), en los lugares donde la entidad tenga presencia o desarrolle acompañamiento a través de la recolección, procesamiento, almacenamiento, recuperación, intercambio, transferencia y consulta de información, en el desarrollo de su misión institucional y cumplimiento de sus objetivos estratégicos.

Las políticas y lineamientos establecidos se encuentran enmarcados en El Modelo de Seguridad y Privacidad de la Información MSPI y la implementación del Sistema de Gestión de Seguridad y Privacidad de la Información (SGSPI) Resolución 212 de 2025, el cual está basado en la norma ISO/IEC 27001:2022, la Ley 1581 de 2012 de Protección de Datos Personales, la Ley 1712 de 2014 Transparencia y Acceso a la Información Pública y Reservada, entre otras, adoptadas por la entidad y que son necesarias para la protección de los activos de información de la **DIAN**.

3. DEFINICIONES Y SIGLAS

Todas las definiciones y siglas presentados en el contenido de este documento están exhaustivamente detallados y explicados en el Anexo Definiciones y Siglas de Seguridad y Privacidad de la Información, el cual, ha sido cuidadosamente elaborado para proporcionar una comprensión precisa y completa de los conceptos utilizados. Se aclara que las definiciones se ajustan a estándares internacionales como ISO/IEC 27000 y a la normatividad colombiana aplicable, asegurando coherencia terminológica en materia de seguridad de la información y protección de datos personales.

4. RESPONSABILIDAD Y CUMPLIMIENTO

Los siguientes documentos: (1) MSPI - El Modelo de Seguridad y Privacidad de la Información - OD-IIT-0001, (2) Manual para la Protección de Datos Personales - MN-IIT-0062, (3) Manual de Políticas y Lineamientos de Seguridad y Privacidad de la Información - MN-IIT-0072, (4) Procedimiento de Gestión de Activos de Información - PR-IIT-0366, (5) Cartilla para la Gestión de Activos de Información – CT-IIT-0079 y (6) Cartilla Gestión de Riesgos de Seguridad - CT-IIT-0132 deben ser aplicados con estricto cumplimiento por parte de todos los directivos, funcionarios, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores y otros terceros que presten sus servicios o tengan algún tipo de vinculación con la **DIAN**, para el correcto cumplimiento de sus funciones y para conseguir un adecuado nivel de seguridad y protección de los activos de información.

El incumplimiento de lo estipulado en estos documentos acarreará las acciones disciplinarias a las que haya lugar, sin perjuicio de las acciones penales, administrativas o fiscales. Las acciones disciplinarias se registrarán de acuerdo con el Código Disciplinario vigente. Asimismo, se podrá proceder a la suspensión temporal del acceso a sistemas y activos de información mientras se verifica el cumplimiento, conforme a protocolos internos de gestión de incidentes de seguridad.

A continuación, se definen los lineamientos y políticas para los diferentes tipos de control los cuales son de obligatoria aplicación y cumplimiento:

- Controles Organizacionales
- Controles de personas
- Controles físicos
- Controles tecnológicos
- Controles adicionales (este último definido por la Entidad)

Establecidos en el ANEXO A de acuerdo con los controles de seguridad de la información de la norma ISO/IEC 27001:2022.

5. CONTROLES ORGANIZACIONALES

Se describen los lineamientos que hacen referencia a los roles y responsabilidades en seguridad y privacidad de la información que establece la **DIAN**:

5.1 Políticas de seguridad de la información

- A. Objetivo de control:** definir la idoneidad y adecuación de las políticas de seguridad y privacidad de la información de la **DIAN**, teniendo en cuenta requisitos legales y la misión institucional.
- B. Alcance:** el alcance de esta política aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que desempeñen alguna actividad con la **DIAN** o a nombre suyo.
- C. Características del control:**
1. Tipo de control: preventivo.
 2. Propiedades de seguridad: confidencialidad, integridad, disponibilidad y autenticidad
- D. Lineamientos:**

La Oficina de la Seguridad de la Información debe:

- a. Emitir las políticas y lineamientos relacionados con la Seguridad y Privacidad de la Información en el campo de los datos y la información.
- b. Revisar las políticas y lineamientos relacionados con la seguridad y privacidad de la información y determinar si es necesario ajustarlas según las necesidades y cambios de la entidad.
- c. Presentar ante el Comité Institucional Estratégico las políticas y lineamientos relacionados con la Seguridad y Privacidad de la Información para su aprobación.
- d. Solicitar la publicación de las políticas y lineamientos relacionados con la Seguridad y Privacidad de la Información para poder ser consultada por la ciudadanía en general. La publicación debe respetar los niveles de clasificación y confidencialidad definidos para cada documento.

E. Controles relacionados: No aplica.

5.2 Roles y responsabilidades para la seguridad de la información

A. **Objetivo de control:** definir los roles y la asignación de responsables para cada acción establecida dentro de la planeación de seguridad de la información como aspecto fundamental para el correcto funcionamiento del MSPI.

B. **Alcance:** el alcance de este lineamiento aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) con roles y responsabilidades relacionadas con la Seguridad y Privacidad de la Información.

C. **Características del control:**

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. **Lineamientos:**

1. La Oficina de Seguridad de la Información debe:
 - a. Implementar y gestionar el Modelo de Seguridad y Privacidad de la Información en la entidad.
 - b. Generar el modelo de gobierno, roles y responsabilidades de seguridad y privacidad de la información, revisarlo mínimo una vez al año o cada vez que se requiera.
 - c. Dar a conocer a los funcionarios y terceros de la **DIAN**, el Modelo de Seguridad y Privacidad de la Información establecido en la entidad.
 - d. Efectuar el monitoreo al grado de implementación del Modelo de Seguridad y Privacidad de la Información.
2. Los jefes de las dependencias deben:
 - a. Identificar y clasificar los activos de información y conservar su seguridad. Los propietarios de los activos de información son los responsables de aplicar y cumplir los controles que mitiguen la afectación a la disponibilidad, confidencialidad e integridad de los activos de información.
 - b. Designar a los enlaces de seguridad de la información, quienes facilitaran el cumplimiento a los lineamientos, políticas y demás reglamentación establecida con el fin de implementar el Modelo de Seguridad y Privacidad de la Información.
 - c. Identificar los riesgos de seguridad de la información y dar cumplimiento a los planes de tratamiento y mitigación de estos.

E. **Controles relacionados:**

5.1.1 – Políticas de seguridad de la información

5.3 Segregación de funciones

- A. Objetivo de control:** segregar las funciones clave para separar las responsabilidades de las dependencias de la entidad y permitir reducir las posibilidades de modificación no autorizada o no intencional, o el uso indebido de los activos de información. Los lineamientos y las políticas están alineadas con las funciones definidas en el Decreto 1742 de 2020, el cual establece la nueva estructura y organización de la **DIAN**.
- B. Alcance:** el alcance de este lineamiento aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que desarrollen funciones de acuerdo con las políticas de seguridad y privacidad de la información de la **DIAN**.
- C. Características del control:**
1. Tipo de control: preventivo.
 2. Propiedades de seguridad: confidencialidad, integridad, disponibilidad y autenticidad
- D. Lineamientos:**
1. La Oficina de Seguridad de la Información debe:
 - a. Generar el gobierno de identidades (roles y responsabilidades) y monitorear las directrices relacionadas con el control y asignación de permisos para el acceso a las instalaciones, dependencias seguras y sistemas de información de la entidad.
 - b. Actualizar la segregación de funciones de acuerdo con la matriz de roles y responsabilidades en seguridad y privacidad de la información, mínimo una vez al año o cada vez que se requiera.
 2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Definir e implementar la segregación de funciones para los procesos y procedimientos que se definan para el cumplimiento de las políticas establecidas en este documento.
 - b. Definir e implementar la segregación de funciones para el acceso y flujos de trabajo en los sistemas de información en la entidad, también para el personal que requiere ingreso a los *datacenters* o suscripciones de computación en la nube.
 - c. Definir e implementar los controles para la segregación de funciones desde el inicio de desarrollo de los proyectos tecnológicos y acompañar los relacionados con desarrollos tecnológicos o adquisiciones de software de otras dependencias.
 3. Los dueños de los Sistemas de Información deben:
 - a. Definir los controles a implementar para evitar que una misma persona tenga acceso a dos o más responsabilidades dentro de un mismo sistema, para impedir realizar acciones o transacciones que ocasionen el uso indebido de los activos y/o cometer conductas fraudulentas.
 4. Los jefes de las dependencias deben:
 - a. Determinar los procedimientos y lineamientos a implementar para evitar que una persona pueda acceder, modificar o usar los activos de su competencia sin autorización ni detección.

- b. Aplicar controles compensatorios cuando la segregación de funciones sea difícil o imposible de conseguir. Entre estos controles, se encuentran: a) la revisión periódica de las actividades, lo que permite su supervisión mientras están en desarrollo, como una forma de validar que se lleven a cabo de manera correcta, b) los rastros de auditoría y c) la supervisión de la gestión.
5. Los funcionarios y terceros de la entidad deben:
 - a. Conocer sus funciones y responsabilidades dentro de la entidad teniendo en cuenta para ello la matriz de roles y responsabilidades, los procesos y/o procedimientos y el manual de funciones, así como los lineamientos establecidos en este manual.
 - b. Dar cumplimiento a los controles estipulados y socializados a través del presente manual.

E. Controles relacionados: No aplica.

5.4 Responsabilidades de la dirección

A. Objetivo de control: definir responsabilidades de la dirección y comprender su papel en la seguridad y privacidad de la información, así como requerir a todo el personal que aplique las políticas establecidas en este documento.

B. Alcance: el alcance de este lineamiento aplica a los funcionarios de la entidad que ejecutan responsabilidades de la dirección en la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. El Comité Institucional Estratégico debe:
 - a. Adoptar el presente documento como parte integral del Modelo de Seguridad y Privacidad de la Información.
 - b. Requerir a todos los funcionarios y terceros el cumplimiento normativo interno de la entidad (políticas, directrices, lineamientos y procedimientos establecidos), así como la normatividad externa a la entidad relacionada con seguridad y privacidad de la información.
 - c. Promover el compromiso de todos los niveles de responsabilidad y autoridad de la **DIAN** en la implementación del Modelo de Seguridad y Privacidad de la Información.
 - d. Verificar el cumplimiento de las políticas de seguridad y privacidad de la información y los objetivos definidos, alineados con las necesidades de la **DIAN**.
 - e. Gestionar la integración de los lineamientos del Modelo de Seguridad y Privacidad de la Información con los procesos y procedimientos definidos en la **DIAN**.
 - f. Comunicar la necesidad de definir y mantener una gestión de la seguridad y privacidad de la información representada por medio de los objetivos y las políticas de seguridad.
 - g. Apoyar y promover a las personas para que contribuyan al desarrollo del Modelo de Seguridad y Privacidad de la Información y adquieran un rol de liderazgo en cada una de sus dependencias de responsabilidad.

- h. Gestionar los recursos requeridos para el mantenimiento del Modelo de Seguridad y Privacidad de la Información.
2. La Oficina de Seguridad de la Información debe:
 - a. Divulgar y capacitar a los funcionarios de la entidad acerca de las políticas y lineamientos de seguridad y privacidad de la Información establecidos en este documento.
 - b. Definir y gestionar programas de capacitación, entrenamiento y educación que incluyan temas relevantes y pertinentes sobre seguridad y privacidad de la información.
 - c. Generar los lineamientos y políticas para la implementación del Modelo de Seguridad y Privacidad de la Información en la **DIAN** en concordancia con las políticas de seguridad y sus objetivos.
 - d. Apoyar a las dependencias en la identificación y evaluación de los riesgos de seguridad de la información, identificación y valoración de activos y demás temas relacionados con la seguridad y privacidad de la información, para seleccionar y aplicar el plan de tratamiento de riesgos más adecuado.
 - e. Verificar que las dependencias realicen el análisis y evaluación de riesgos de seguridad de la información por lo menos una vez al año.
 - f. Establecer las herramientas y los procedimientos que permitan monitorear, hacer seguimiento y facilitar el reporte de eventos e incidentes de seguridad y/o privacidad de la información, que se consideren como incumplimiento de las responsabilidades establecidas en este numeral.
 - g. Realizar el monitoreo y el seguimiento de manera permanente al cumplimiento de las responsabilidades establecidas en los principios y lineamientos de este numeral.
 - h. Diseñar, implementar, supervisar y optimizar el Centro de Operación de Seguridad de la Información (COSI = SOC), aprovechando la información proporcionada para la toma de decisiones.
 - i. Definir y gestionar en coordinación con la Dirección de Innovación y Tecnología, o la dependencia que haga sus veces, los procedimientos de continuidad operativa y recuperación en caso de desastres, respecto de la infraestructura tecnológica de la **DIAN**.
3. Los jefes de las dependencias deben:
 - a. Promover el cumplimiento, por parte del personal bajo su responsabilidad, de las políticas, lineamientos, directrices y procedimientos de seguridad y privacidad de información.
 - b. Aplicar los controles establecidos por la **DIAN** para activar o desactivar, de manera temporal o permanente, el acceso a la información digital catalogada como pública clasificada, pública reservada y datos personales no públicos, por parte del personal que esté vinculado a la entidad utilizando DLP (prevención de pérdida de datos).
 - c. Clasificar los activos de información de su proceso de acuerdo con los requerimientos de confidencialidad, integridad y disponibilidad.
 - d. Realizar mínimo una vez al año el análisis de riesgos de seguridad de la información para cada proceso con el apoyo de la Oficina de Seguridad de la Información y así determinar el grado de exposición a las amenazas vigentes y confirmar los requerimientos de confidencialidad, integridad y disponibilidad relacionados con sus activos de información de acuerdo con la guía de gestión de riesgos.
 - e. Definir los requerimientos de seguridad y privacidad de la información de cada proceso con el acompañamiento de la Oficina de Seguridad de la Información para los activos de información bajo su responsabilidad, para que se les proporcione un nivel adecuado de

protección de conformidad con los estándares, políticas y lineamientos de seguridad y privacidad de la información.

- f. Solicitar a la Oficina de Seguridad de la Información las capacitaciones sobre seguridad y privacidad de la información que le compete a la dependencia.
- g. Definir, documentar, mantener, actualizar y mejorar permanentemente los procedimientos relacionados con su proceso, incluyendo los controles de seguridad y privacidad de la información.
- h. Hacer seguimiento al cumplimiento de las obligaciones en materia de seguridad y privacidad de la información de su proceso.
- i. Reportar a la Oficina de Seguridad de la Información de los eventos o incidentes relacionados con el incumplimiento de las responsabilidades frente a la seguridad y privacidad de la información, descritos en los principios y lineamientos de este documento.
- j. Incorporar la seguridad y privacidad de la información como parte de las actividades y tareas asignadas a su dependencia.

E. CONTROLES RELACIONADOS:

1. 6.3 - Concientización, educación y capacitación en seguridad de la información

5.5 Contacto con las autoridades

A. Objetivo de control: mantener y gestionar contacto proactivo y reactivo con las diferentes autoridades que puedan apoyar a prevenir y solucionar incidentes de seguridad y privacidad de la información identificados en la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica a la Oficina de Seguridad de la Información, dependencia encargada de establecer y mantener contacto con las autoridades pertinentes, en coordinación con la Dirección de Gestión de Innovación y Tecnología, la Dirección de Gestión Jurídica y la Oficina de Comunicaciones Institucionales, según la naturaleza del incidente.

C. Características del control:

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Reportar a la Superintendencia de Industria y Comercio los incidentes relacionados con protección de datos personales, de acuerdo con el protocolo establecido por dicha entidad, Se deberá realizar la notificación dentro de los términos legales establecidos, detallando el alcance del incidente, los datos comprometidos y las acciones de mitigación implementadas.
 - b. Establecer el canal de comunicación autorizado para contactar a las autoridades nacionales a las que se reportarán, en caso de ser requerido, los incidentes de cualquier índole que pongan en riesgo la confidencialidad, integridad y disponibilidad de la información. Evaluar los eventos de violación de seguridad de la información presentados en la entidad y determinar las acciones que se deben adoptar, siendo una de ellas la de reportar a las autoridades nacionales competentes en la materia.

- c. Mantener la relación con autoridades para contactarlas de manera oportuna en casos de presencia de un incidente de seguridad de la información, tales como Centro Cibernético Policial (CCP C4), Grupo de Respuesta a Emergencias Cibernéticas en Colombia (COLCERT), Centro de Coordinación Seguridad Informática Colombia (CSIRT-CCIT), Policía Nacional, Superintendencia de Industria y Comercio y la Unidad Administrativa Especial Dirección de Bomberos de Colombia, entre otras autoridades.

E. Controles relacionados:

1. 5.24 – Planificación y preparación de la gestión de incidentes de seguridad de la información.
2. 5.28 – Recopilación de pruebas.
3. 5.29 – Seguridad de la información durante la interrupción.
4. 5.30 – Preparación de las TIC para la continuidad del negocio.

5.6 Contacto con grupos de interés especial

A. Objetivo de control: establecer y mantener contactos apropiados con grupos de interés especial u otros, foros y asociaciones profesionales especializadas en seguridad y privacidad de la información.

B. Alcance: el alcance de este lineamiento aplica a la Oficina de Seguridad de la Información, encargada de establecer y mantener contacto con los grupos de interés especial u otros foros especializados en seguridad y asociaciones profesionales.

C. Características del control:

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir mecanismos que permitan hacer mayor uso de las membresías en grupos o foros de interés especial en seguridad y privacidad de la información, impulsando de esta manera el desarrollo de competencias del talento humano en temáticas específicas de seguridad y privacidad de la información.
 - b. Coordinar dentro de la **DIAN** las acciones requeridas para mantener contacto permanente con universidades, grupos de investigación, proveedores de tecnología, entre otros grupos de interés, que puedan ofrecer boletines, noticias, contenidos de formación y actualizaciones sobre temáticas relacionadas con seguridad y privacidad de la información, dirigidas a funcionarios que desempeñan funciones dentro del ámbito de la seguridad y privacidad de la información en la entidad.
 - c. Mantener contacto con grupos especializados en seguridad y privacidad de la información, que ofrezcan recomendaciones ante incidentes que puedan vulnerar la confidencialidad, integridad y disponibilidad de la información en la entidad.

E. Controles relacionados:

1. 5.24 – Planificación y preparación de la gestión de incidentes de seguridad de la información
2. 5.28 – Recopilación de pruebas

5.7 Inteligencia de amenazas

A. Objetivo de control: recopilar y analizar la información relacionada con las amenazas a la seguridad y privacidad de la información de la entidad, para generar información sobre amenazas, proporcionar contexto para la concienciación del entorno de amenazas de la organización con el propósito de tomar medidas de mitigación adecuadas.

B. Alcance: el alcance de este lineamiento aplica a la Oficina de Seguridad de la Información de la **DIAN**, dependencia encargada de recopilar y analizar la información sobre amenazas existentes y emergentes relacionadas con la entidad.

C. Características del control:

1. Tipo de control: preventivo, detectivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir las herramientas, fuentes de información y metodologías para identificar las posibles amenazas cibernéticas que se puedan presentar en la entidad, con el fin de proporcionar una comprensión precisa y detallada del panorama de estas, y que agregue contexto a la información en el momento en que se pueda presentar un evento, para actuar de manera adecuada teniendo en cuenta experiencias previas en entidades similares.
 - b. Realizar informes periódicos a partir de la información obtenida, sobre el análisis de amenazas para seguridad de la información en la entidad, comunicarlo y socializarlo a los diferentes grupos de interés en los niveles estratégicos, tácticos y operativos, prevaleciendo los pilares fundamentales de integridad, disponibilidad y confidencialidad de la información.
 - c. A partir del resultado de los análisis de inteligencia de amenazas, proponer y sugerir medidas adecuadas para mitigar el impacto de las amenazas en la entidad y tenerlas en cuenta en la gestión de riesgos de seguridad de la información en la **DIAN**.
 - d. Utilizar y analizar la información sobre inteligencia de amenazas como entrada adicional para la gestión de controles técnicos preventivos y de detección que debe implementar las diferentes dependencias de la entidad, como ejemplo: firewalls, sistemas de detección de intrusos o soluciones antimalware.
 - e. Analizar y utilizar la información para los procedimientos y técnicas de pruebas de seguridad y privacidad de la información en la entidad.
 - f. Compartir la información sobre inteligencia de amenazas con otras entidades de forma mutua para mejorar los conocimientos en relación con las experiencias obtenidas.

E. Controles relacionados:

1. 5.25 – Evaluación y decisión sobre eventos de seguridad de la información
2. 8.7 – Protección contra malware
3. 8.16 – Actividades de seguimiento
4. 8.23 – Filtrado web

5.8 Seguridad de la información en la gestión de proyectos

A. Objetivo de control: integrar desde las etapas iniciales, la seguridad de la información en la gestión de proyectos de la entidad para tratar los riesgos de seguridad de la información.

B. Alcance: el alcance de este lineamiento aplica para todos los proyectos de tecnología que son ejecutados desde la Subdirección de Innovación y Proyectos; así como los demás proyectos que sean manejados al interior de la entidad, como por ejemplo proyectos misionales, procesos de apoyo o gestión de instalaciones.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Innovación y Proyectos, Dirección de Gestión o quien haga sus veces debe:
 - a. Determinar la criticidad de la información que se utilizará en el proyecto, teniendo como base la clasificación de los activos de información definido en el Procedimiento de Gestión de Activos
 - b. Definir en el proyecto, el tiempo que la información será utilizada, los periodos de conservación de la información y la accesibilidad a la información por parte de los funcionarios y terceros de la entidad.
 - Incluir la privacidad de la información y los datos personales en el análisis de riesgos, previo al proyecto, de acuerdo con lo definido en el Manual de Protección de Datos Personales de la Entidad.
 - c. Gestionar los respectivos acuerdos de confidencialidad y de entrega de información según la normatividad vigente en la entidad.
 - Implementar las mejores prácticas relacionadas con el desarrollo seguro y pruebas de penetración para gestionar desde el inicio las debilidades de seguridad en los proyectos que incluyan desarrollo de sistemas de información. Lo anterior de acuerdo con las Guías de desarrollo seguro emitidas por MINTIC.
 - d. Determinar si en el proyecto van a participar terceros y si aplica gestionar las cláusulas de cumplimiento según las normas aplicables, la autorización de tratamiento de datos, la cláusula de confidencialidad de la información y de aceptación de las políticas de seguridad.
 - Evaluar, tratar y hacer seguimiento a los riesgos de seguridad de la información y datos personales asociados a los proyectos, durante todo el ciclo de vida del proyecto (al inicio, durante la ejecución y al finalizar). y en todo el ciclo de vida del proyecto), de acuerdo con lo definido en el Procedimiento de Gestión de Riesgos de la Entidad.
2. La Oficina de Seguridad de la Información debe:
 - a. Guiar a la Subdirección de Innovación y Proyectos en las actividades de definición de riesgos para cada uno de los proyectos que gestiona esta dependencia.

E. CONTROLES RELACIONADOS:

1. 5.12 - Clasificación de la información
2. 5.32 - Derechos de propiedad intelectual
3. 8.26 - Requisitos de seguridad de la aplicación

5.9 Inventario de información y otros activos asociados

A. Objetivo de control: desarrollar y mantener actualizado el inventario de activos de información. Los activos de información son el insumo principal de la entidad para la ejecución de la gestión de riesgos de seguridad de la información y adicionalmente, para generar el índice de Información Clasificada y Reservada y la matriz de Inventario de activos de Información.

B. Alcance: el alcance de este lineamiento aplica para todos los jefes de las dependencias de la **DIAN** que poseen facultades para identificar, clasificar y administrar activos de información con los que desarrollan sus funciones.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Información y Analítica debe:
 - a. Ejercer gobierno teniendo en cuenta los activos de información definidos por las diferentes dependencias de la entidad, para tener autoridad y control sobre la información, a través de la implementación de procedimientos, circulares y otros instrumentos relacionados con la recolección, calidad, consistencia (limpieza de datos), y uso, en coordinación con otras dependencias de la entidad, en el marco de sus competencias.
 - b. Definir los criterios para la identificación de activos de información junto con la Oficina de Seguridad de la Información.
2. La Oficina de Seguridad de la Información debe:
 - a. Realizar capacitación y acompañamiento a todas las dependencias en lo referente a la Gestión de Activos de Información.
 - b. Realizar seguimiento a la gestión de los activos de información, de acuerdo con los lineamientos referenciados en este documento (5.10, 5.12, 5.13 y 5.14) en la “sección E” de este control.
 - c. Solicitar a las dependencias el registro de los activos de información o la revisión del inventario de activos para identificar cambios o eliminación de un activo, cada vez que se requiera (por disposiciones internas o requerimientos de la Oficina de Seguridad de la Información) o como mínimo una vez al año.
 - d. Definir la metodología para la gestión de activos de Información teniendo en cuenta lo relacionado con Datos Personales, el Manual para la Protección de Datos Personales,

los lineamientos de MinTIC, la norma ISO 27001, los procedimientos de retención documental y demás legislación aplicable.

- e. Proporcionar la herramienta para la gestión de los activos de información y la facilitación de su identificación, registro, clasificación, valoración y tratamiento. Se deben tener en cuenta: el propietario, el custodio, los tipos de activos, la ubicación y la legislación aplicable.

3. Los jefes de las dependencias deben:

- a. Ejercer control sobre sus activos de información, administrar y mantener actualizado su inventario.
- b. Realizar la gestión de los activos de información en la herramienta de gestión facilitada por la **DIAN**, con el apoyo del funcionario designado como “enlace de seguridad” de la Información de la dependencia, siguiendo los lineamientos definidos en la Cartilla para la Gestión de Activos de Información.
- c. Registrar los activos de información en la herramienta de gestión y participar en las campañas de actualización y mejora continua realizados por la Oficina de Seguridad de la Información dentro del marco del Sistema de Gestión de Seguridad y Privacidad de la Información.
- d. Tener en cuenta los parámetros de las Tablas de Retención Documental de la **DIAN** para ser incluidos en los inventarios de activos de información y otros activos asociados.
- e. Realizar una revisión y actualización del inventario de activos de información cada vez que se requiera (por disposiciones internas, solicitud de la Oficina de Seguridad de la Información y/o requerimientos de entes de control). Esto debe hacerse como mínimo una vez al año.
- f. Aprobar en la herramienta de gestión cualquier actualización realizada sobre los activos de información de la dependencia.
- g. Aprobar los activos de información de su dependencia, una vez estén gestionados en su totalidad.
- h. Diligenciar todos los campos que requiere la metodología de activos definida por la Oficina de Seguridad de la Información.
- i. El jefe de cada dependencia es el propietario del activo de información, por lo tanto, es el responsable de la identificación, actualización, aprobación, eliminación, transferencia o inactivación que se le realice a un activo.

E. Controles relacionados:

1. 5.10 – Uso aceptable de la información y otros activos asociados
2. 5.12 – Clasificación de la información
3. 5.13 – Etiquetado de la información
4. 5.14 – Transferencia de información

5.10 Uso aceptable de la información y otros activos asociados

- A. **Objetivo de control:** identificar, documentar e implementar reglas para el uso aceptable de la información y otros activos asociados con información e instalaciones de procesamiento de información.

B. Alcance: el alcance de este lineamiento aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que hagan uso de la información y otros activos asociados propiedad de la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir los lineamientos aplicables a todos los funcionarios y/o terceros que creen, actualicen, tengan acceso, utilicen, almacenen, transfieran o eliminen activos de información de la entidad, orientados a garantizar el uso aceptable de los activos de información dentro de las diferentes dependencias de la entidad.
 - b. Capacitar a los funcionarios y/o terceros de la **DIAN**, en los requisitos establecidos de seguridad de la información y privacidad, para la protección y el manejo adecuado de la información de la entidad.
 - c. Divulgar los lineamientos de uso aceptable de la información en la entidad a los funcionarios y/o terceros para que la conozcan y apliquen; así mismo, comunicar toda actualización de manera oportuna.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Implementar medidas de seguridad de la información cuando se utilicen entornos de trabajo colaborativos.
 - b. Implementar los controles para la restricción de acceso no autorizado a los activos de información de acuerdo con la clasificación realizada por los propietarios de los mismos.
 - c. Establecer los mecanismos para proteger las copias temporales o permanentes de la información de los activos.
 - d. Conservar los activos de información (*Hardware* y *software*) de acuerdo con las recomendaciones de los fabricantes.
3. La Subdirección de Compras y Contratos debe:
 - a. Incluir acuerdos de confidencialidad o compromisos de protección de los activos y su información de propiedad de terceros en los contratos, incluyendo servicios de computación en la nube pública.
 - b. Vincular la responsabilidad para el proveedor o la tercera parte contratada en lo relacionado al uso aceptable de los activos de la entidad.
4. Los jefes de las dependencias deben:
 - a. Hacer uso aceptable de los activos teniendo en cuenta la confidencialidad, integridad y disponibilidad de estos.

- b. Cumplir con los requisitos de seguridad de la información que afectan a la información de la entidad, a otros activos asociados, y a los recursos utilizados para el tratamiento de esta.
- c. Gestionar, procesar y almacenar la información de acuerdo con la clasificación de los activos de información.
- d. Utilizar los mecanismos establecidos por la Dirección de Gestión de Innovación y Tecnología que permitan proteger las copias temporales o permanentes de la información de los activos.
- e. Suscribir los acuerdos de confidencialidad pertinentes en los formatos correspondientes, cuando exista intercambio o entrega de información a externos, contratistas o partes interesadas.

5. Los funcionarios y terceros deben:

- Cumplir con los lineamientos y políticas establecidas sobre el uso aceptable de activos de información de la **DIAN**.

E. Controles relacionados:

1. 5.12 – Clasificación de la información
2. 7.6. – Trabajar en áreas seguras
3. 7.8 – Ubicación y protección del equipo
4. 7.10 – Medios de almacenamiento
5. 8.10 – Eliminación de información

5.11 Devolución de activos

A. Objetivo de control: devolver todos los activos de la entidad que se encuentren a cargo de los funcionarios y terceros de la **DIAN**, al terminar su contrato, empleo o acuerdo.

B. Alcance: el alcance de este lineamiento aplica a todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que posean activos físicos o electrónicos de la entidad y cambien o terminen su vinculación con la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - Establecer procedimientos para la entrega y la recepción de bienes y activos físicos de la entidad por parte de los funcionarios y terceros.
2. La Subdirección de Soluciones y Desarrollo debe:

- Establecer lineamientos para realizar la entrega de bienes y activos de información de la entidad (dentro de estos se incluyen datos, equipos de cómputo, Hardware y Software).
- a. Identificar y documentar la información y otros activos tecnológicos asociados que deben ser devueltos en el momento de notificación de terminación vinculación, entre estos se encuentran:
 - Equipo especializado.
 - Hardware de autenticación (por ejemplo, llaves mecánicas, tokens físicos y tarjetas inteligentes para sistemas de información, sitios y archivos físicos).
 - Copias físicas de la información.
 - Equipos de cómputo.
- 3. Los funcionarios y terceros deben:
 - a. Devolver el activo de información que fue asignado para el desarrollo de sus funciones (documentos, datos, equipos de cómputo, hardware, Software, y todo elemento entregado o generado por la entidad), al finalizar su vínculo laboral o contractual, por cambio de dependencia o finalización de actividades.
 - b. Hacer transferencia de la información que se haya trabajado o reproducido y efectuar su borrado general en el equipo usado.

E. Controles relacionados:

1. 5.18 – Derechos de acceso
2. 6.8. – Informes de eventos de seguridad de la información
3. 7.14 – Eliminación segura o reutilización de equipos
4. 8.24 – Uso de criptografía

5.12 Clasificación de la información

A. Objetivo de control: identificar y clasificar los activos de información de acuerdo con su criticidad teniendo en cuenta la confidencialidad, integridad y disponibilidad de la información y requisitos legales.

B. Alcance: el alcance de esta política aplica a todos los propietarios que gestionan y administran activos de información de la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - Definir los criterios y niveles para clasificar la información de acuerdo con su criticidad, donde se valorarán los activos de información, considerando sus atributos de confidencialidad, integridad y disponibilidad de la información.

- Comunicar los procedimientos definidos para la clasificación de la información y la guía para la identificación, creación, clasificación y/o actualización del inventario de activos de información.
 - a. Disponer de una herramienta para la clasificación de los activos de información por parte de los propietarios de los activos.
 - Definir controles para la protección de datos e información compartida con terceras partes de acuerdo con la clasificación de los activos de información.
2. Los jefes de las dependencias deben:
- a. Realizar la clasificación de la información de acuerdo con los procedimientos y guías definidas por la Oficina de Seguridad de la Información.
 - Aprobar la entrega de información registrada como activo de información a una persona natural o jurídica, teniendo en cuenta su clasificación y los lineamientos asociados a la transferencia de información.
 - Monitorear periódicamente la clasificación de sus activos de información y de ser necesario realizar la actualización de las valoraciones de estos.Aprobar en la herramienta de gestión de activos cualquier actualización realizada sobre los activos de información de la dependencia.
 - Definir controles para la protección de datos e información compartida con terceras partes de acuerdo con la clasificación de los activos de información.
 - Hacer cumplir los períodos de almacenamiento de información de acuerdo con lo establecido por el Programa de Gestión Documental (PGD) de la entidad, para la información física y electrónica manejada por la **DIAN**. Una vez cumplido el periodo, toda la información deberá ser eliminada adecuadamente. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Implementar los controles para asegurar la protección de datos e información compartida con terceras partes, y que sean definidos por la Oficina de Seguridad de la Información. También deben realizar monitoreos periódicos para confirmar su correcto funcionamiento.
3. Los custodios de los activos de información deben:
- a. Aplicar los controles para la protección de la información, según su nivel de clasificación.
 - b. Notificar a los propietarios sobre situaciones de riesgos en los activos de información.

E. Controles relacionados:

1. 5.1 – Políticas de seguridad de la información
2. 5.13 – Inventario de información y otros activos asociados

5.13 Etiquetado de la información

- A. Objetivo de control:** establecer procedimientos y/o lineamientos para el etiquetado de la información, de acuerdo con el esquema de clasificación adoptado por la entidad.
- B. Alcance:** el alcance de este lineamiento aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades

del estado, entes de control) que elaboran documentos para la entidad y también para los propietarios de activos que etiquetan información de acuerdo con su clasificación.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir procedimientos para el etiquetado de la información, de acuerdo con el esquema de clasificación adoptado por la entidad.
 - b. Divulgar los procedimientos para el etiquetado de información a todos los funcionarios y terceros de la entidad.
 - c. Promover el uso del procedimiento de etiquetado de la información.
 - d. Incluir dentro del esquema de etiquetado de la información los documentos de ofimática de la entidad.
 - e. Incluir la clasificación de los activos como criterio para el etiquetado de la información en la entidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Implementar mecanismos para la ejecución del etiquetado de la información en las herramientas tecnológicas de la entidad, de conformidad con los procedimientos establecidos por la Oficina de Seguridad de la Información.
3. Los jefes de las dependencias deben:
 - a. Asegurar que el etiquetado de sus activos se realice según los criterios establecidos y de acuerdo con su clasificación.
 - b. Etiquetar la información de manera reconocible y de fácil utilización para evitar confusiones en el manejo y gestión de la información.
 - c. Confirmar el etiquetado de información de los activos identificados en la matriz de activos de su dependencia.
4. Los funcionarios y terceros deben:
 - a. Ser responsables del etiquetado de su información de acuerdo con los lineamientos del Modelo de Seguridad y Privacidad de la Información, las Tablas de Retención Documental (TRD) y debe estar alineado con lo ordenado por la Ley 1712 del 2014 (Ley de Transparencia y del Derecho de Acceso a la Información Pública Nacional). Este etiquetado debe contemplar la información y los activos relacionados tanto en soporte físico como electrónico.
 - b. Llevar a cabo el etiquetado de información de acuerdo con los procedimientos de etiquetado definido por la Oficina de Seguridad de la Información, teniendo en cuenta su clasificación.
 - c. Realizar el etiquetado de la información en los documentos de ofimática de la entidad, de acuerdo con las guías definidas por la Oficina de Seguridad de la Información.

5. La Oficina de Tributación Internacional debe:

- a. Aplicar la metodología de etiquetado establecida por la Oficina de Seguridad de la Información para clasificar y marcar adecuadamente los documentos y datos obtenidos de los acuerdos internacionales.

E. Controles relacionados:

1. 5.12 – Clasificación de la información

5.14 Transferencia de información

A. Objetivo de control: definir mecanismos físicos o electrónicos para la transferencia de información con terceros y establecer los acuerdos requeridos para mantener la confidencialidad y no divulgación.

B. Alcance: el alcance de esta política abarca a todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que realicen transferencias (incluidas actividades de transferencia internacional) de información física, electrónica y verbal de la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Conservar actualizado el inventario de toda la información electrónica que sea compartida; de igual manera debe contar con el requerimiento y la autorización de la dependencia dueña del activo de información, antes de compartirla o intercambiarla.
 - b. Implementar las medidas de seguridad necesarias para proteger la transmisión, transferencia o intercambio de información y así minimizar el riesgo de fuga, pérdida o modificación no autorizada de la información en las aplicaciones o equipos de comunicaciones.
 - c. Activar y remitir a la herramienta de análisis de eventos de la Oficina de Seguridad de la Información los logs generados por los servicios involucrados en la transferencia de información.
 - d. Contar con el inventario de conexiones, usuarios y la información a la que tienen acceso los terceros que hacen uso de este tipo de conexiones.
 - e. Utilizar medios seguros para la transferencia, transición e intercambio de información electrónica en medios físicos como cintas o discos.
 - f. Utilizar las mejores prácticas del mercado en el control de intercambio de información.
 - g. Limitar la transferencia de información mediante el uso de herramientas colaborativas vía web a información clasificada como “pública”.
 - h. Contar con una herramienta segura que permita la conexión entre las partes para compartir información con otras entidades o terceros, preservando la confidencialidad, integridad y disponibilidad de la información; lo anterior siempre y cuando exista un

acuerdo con el tercero. Implementar y monitorear mecanismos de control sobre el envío de correos fuera de la entidad.

- i. Implementar un sistema de etiquetado para la información sensible o crítica de la entidad, en caso de requerir transferencia de información.

2. La Dirección de Gestión de Fiscalización debe:

- a. Gestionar la evidencia digital solicitada por un organismo de control y/o judicial competente que requiera información contenida en la misma, preservando la confidencialidad, integridad y disponibilidad de la información; dando cumplimiento a los acuerdos, convenios y normatividad vigente para tal fin.
- b. Contar con la autorización de la Oficina de Seguridad de la Información para todas las entregas a los entes de control y/o judiciales de los archivos de evidencia física, digital o electrónica.
- c. Utilizar y almacenar la huella digital o código *hash* que permita la integridad de la información suministrada en dos momentos diferentes, acorde con los estándares técnicos para el cifrado.
- d. Cumplir con los procedimientos, lineamientos y formatos internos relacionados con el proceso de cadena de custodia.
- e. Diligenciar los formatos de cadena de custodia vigentes para el proceso de entrega de evidencia digital a los entes de control y/o judiciales.
- f. Solicitar al organismo de control y/o judicial los medios físicos necesarios para realizar el traslado, cumpliendo las especificaciones técnicas mínimas y procedimentales que se requieren para la entrega de evidencia digital.

3. La Subdirección de Asuntos Disciplinarios debe:

- a. Solicitar a la Oficina de Seguridad de la Información las evidencias digitales recolectadas referente a información de los funcionarios para posterior envío a los Entes de Control.
- b. Contar con la autorización de la Oficina de Seguridad de la Información para todas las entregas a los entes de control y/o judiciales de los archivos de evidencia física, digital o electrónica.
- c. Utilizar y almacenar la huella digital o código *hash* que permita la integridad de la información suministrada en dos momentos diferentes, acorde con los estándares técnicos para el cifrado.
- d. Cumplir con los procedimientos, lineamientos y formatos internos relacionados con el proceso de cadena de custodia.
- e. Diligenciar los formatos de cadena de custodia vigentes para el proceso de entrega de evidencia digital a los entes de control y/o judiciales.
- f. Solicitar al organismo de control y/o judicial los medios físicos necesarios para realizar el traslado, cumpliendo las especificaciones técnicas mínimas y procedimentales que se requieren para la entrega de evidencia digital.

4. La Oficina de Tributación Internacional debe:

- a. Cumplir con la leyes y normas vigentes para la protección de datos personales en tratados internacionales.
- b. Verificar el cumplimiento de los compromisos de la transferencia de información en acuerdo internacionales.
- c. Tener en cuenta las directrices de la Circular Única de la Superintendencia de Industria y Comercio, modificada por la circular 002 del 23 de marzo de 2018, en el caso de

compartir información con otros países, en donde se enuncian los países que cuentan con un nivel adecuado de protección de datos personales.

- d. Verificar todos los documentos que contengan información sujeta a acuerdos internacionales, según los términos establecidos en los convenios firmados por la **DIAN**, etiquetar estos documentos de manera clara y visible con las marcas y categorías pertinentes según los estándares internacionales definidos en dichos acuerdos.

5. La Oficina de Seguridad de la Información debe:

- a. Establecer medidas de seguridad y monitoreo para los canales de comunicaciones contratados con terceros, de tal manera que se minimice el riesgo de ataques o vulnerabilidades que expongan la información que se transmita, transfiera o intercambie.
- b. Definir los compromisos de intercambio de información en los acuerdos internacionales.
- c. Divulgar entre los funcionarios y terceros de la entidad, el uso adecuado de la transferencia de información (física, electrónica y verbal).

6. Los jefes de las dependencias que entregan información a terceros deben:

- a. Cumplir los lineamientos establecidos por la Dirección de Gestión Jurídica (Circular No. 00026 de 2019 o la que la reemplace o sustituya), sobre la estandarización de la entrada y salida de información y la política de cifrado de datos e información, atendiendo los principios constitucionales y legales.
- b. Aplicar los lineamientos del Manual para la Protección de Datos Personales para los casos donde se requiera el intercambio, transmisión y/o transferencia de la información tanto interna, como con terceros que contenga información asociada a datos personales.
- c. Realizar un convenio entre las partes interesadas cuando se deba efectuar el intercambio de información con externos (entes de control, otras entidades nacionales o internacionales, empresas privadas, entre otros), teniendo en cuenta lo establecido en el Manual para la Protección de Datos Personales y las leyes existentes que protejan la información.
- d. Reportar a las partes interesadas todo incidente que ocurra con la información que sea intercambiada, transmitida y/o que se transfiera, a través de los medios que se tengan establecidos para tal fin.
- e. Contar con la autorización del funcionario responsable del proceso institucional, en el caso de realizar extracción de información de las bases de datos corporativas, que es quien produce o administra la información y es el dueño del activo de información.

7. La Oficina de Comunicaciones Institucionales debe:

- a. Dar buen manejo del correo electrónico asignado y de todas las actividades realizadas con el mismo y su contenido. Así mismo, el contenido de los mensajes enviados a través de correo electrónico debe contar con una firma institucional que permita identificar a la persona que lo envía, la dependencia, la Oficina, la Dirección de Gestión o Seccional a la que pertenece y la extensión telefónica. Esta medida debe aplicarse para el envío y el reenvío de mensajes.
- b. Divulgar y recordar permanentemente los lineamientos para el uso correcto de la imagen institucional de la marca **DIAN**, en la referida firma. Los mensajes de correo electrónico están respaldados por la Ley 527 de 1999 (por medio de la cual se define y reglamenta el acceso y uso de los mensajes de datos, del comercio electrónico y de las firmas digitales, se establecen las entidades de certificación y se dictan otras disposiciones), la

cual establece la legalidad de los mensajes de datos y las implicaciones legales que conlleva su mal uso.

- c. Divulgar información a los funcionarios y/o terceros sobre la restricción de reenviar información masivamente, información no institucional, comunicaciones a dominios ajenos de la entidad.

8. La Subdirección Administrativa debe:

- a. Implementar mecanismos de control para las actividades de transferencia de medios de almacenamiento físico (documentos, archivos, carpetas, entre otros).
- b. Monitorear el correcto enrutamiento de la información física y/o electrónica y preservando la trazabilidad y el no repudio, incluido el mantenimiento de una cadena de custodia de la información durante el tránsito.
- c. Prevenir el envío de información física, electrónica y verbal en las comunicaciones a la dirección o número equivocado.
- d. Impedir el reenvío automático de correo electrónico a direcciones de correo externas.
- e. Usar embalaje para envío de información física incluido el papel, que proteja el contenido de cualquier daño físico que pueda surgir durante el tránsito y de acuerdo con las especificaciones de los fabricantes, por ejemplo, protegiendo contra cualquier factor ambiental que pueda reducir la eficacia de la restauración de los medios de almacenamiento, como la exposición al calor, la humedad o la radiación electromagnética. Utilizar normas técnicas mínimas para el embalaje y la transmisión (por ejemplo, el uso de sobres opacos).
- f. Usar controles para envío de información física a prueba de manipulaciones o inviolables (por ejemplo, bolsas, contenedores), dependiendo del nivel de clasificación de la información en los medios de almacenamiento a ser transportados.
- g. Mantener registros de información de envío de información física para identificar el contenido de los medios de almacenamiento, la protección aplicada, así como registrar la lista de destinatarios autorizados, los tiempos de transferencia a los custodios de tránsito y la recepción en destino.
- h. Asegurar la implementación de controles adecuados en sala de reuniones (por ejemplo: insonorización, puertas cerradas).

9. Los funcionarios y terceros deben:

- a. No revelar la información institucional importante o reservada de manera física, electrónica o verbal.
- b. Firmar el compromiso de confidencialidad y de no divulgación de la información reservada o clasificada, según lo especificado en el Manual para el tratamiento de datos personales.
- c. Comunicar a su jefe inmediato y a la autoridad competente cuando un usuario interno de la entidad reciba algún tipo de mensaje que contenga información inapropiada, amenazante, en contra de la imagen de la **DIAN** y/o cualquier contenido fuera de contexto, de acuerdo con lo previsto en el numeral 24 del artículo 34 de la Ley 734 de 2002, "Código Disciplinario Único". Así mismo, se debe remitir a la Oficina de Seguridad de la Información el incidente reportado (Procedimiento PR-IIT-0458 Gestión de incidentes).
- d. No realizar reenvío de correos electrónicos y agendas del correo electrónico institucional a cuentas personales.
- e. No tener conversaciones verbales confidenciales en lugares públicos o por canales de comunicación inseguros, ya que pueden ser escuchadas por personas no autorizadas.

- f. No dejar mensajes que contengan información confidencial en contestadores automáticos o mensajes de voz, ya que estos pueden ser reproducidos por personas no autorizadas, almacenados en sistemas comunales o almacenados incorrectamente como resultado de una marcación incorrecta.
- g. Comenzar cualquier conversación delicada con un descargo de responsabilidad para que los presentes sepan el nivel de clasificación y los requisitos de manejo de lo que están a punto de escuchar.

E. Controles relacionados:

1. 5.10 – Uso aceptable de la información y otros activos asociados
2. 5.13 – Etiquetado de la información
3. 5.31 – Requisitos legales, estatutarios, reglamentarios y contractuales
4. 5.32 – Derechos de propiedad intelectual
5. 5.33 – Protección de registros
6. 5.34 – Protección de datos personales. (PII)
7. 8.7 – Protección contra malware
8. 8.24 – Uso de criptografía

5.15 Control de acceso

A. Objetivo de control: establecer los lineamientos generales para el acceso controlado a la información de la **DIAN**. Lo anterior, con el fin de minimizar afectación a la confidencialidad, integridad y disponibilidad de la información generada y procesada.

B. Alcance: el alcance de esta política aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) de la **DIAN** que requieren acceder a la información, instalaciones de procesamiento de información y/o a la información de servicios informáticos y/o aplicaciones informáticas disponibles en la red.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Controlar el acceso a áreas seguras e instalaciones físicas de la **DIAN**, limitando el acceso del personal debidamente autorizado de acuerdo con sus necesidades.
 - b. Definir controles para los accesos físicos de áreas restringidas.
2. La Oficina de Seguridad de la Información debe:
 - a. Definir lineamientos para el control de acceso a las aplicaciones y servicios informáticos de la entidad.

- b. Adoptar legislación aplicable a la seguridad de la información y cualquier obligación contractual concerniente a la limitación de acceso para la definición de los lineamientos con respecto al control de acceso.
 - c. Realizar la revisión de la segregación de funciones por las dependencias de la entidad.
3. La Dirección de Gestión de Innovación y Tecnología debe:
- a. Implementar los controles de acceso para las aplicaciones y servicios informáticos definidos por la Oficina de Seguridad de la Información.
 - b. Proveer un controlador de dominio que pueda establecer un sistema de Controladores de Dominio compuesto por uno o varios servidores de configuración idéntica que permita atender los requerimientos técnicos, geográficos o de servicio, siempre y cuando mantenga la sincronización en tiempo real.
 - c. Mantener copias de respaldo de las credenciales de los usuarios con la periodicidad correspondiente a su criticidad e importancia.
 - d. Monitorear y auditar las operaciones realizadas por los usuarios en los equipos, dispositivos o aplicaciones y/o servicios, sin requerir autorización expresa de las personas, cumpliendo las disposiciones vigentes sobre la materia.
 - e. Mantener los registros donde cada uno de los líderes funcionales haya autorizado a usuarios (internos o externos) el acceso a los diferentes sistemas de información de la entidad.
 - f. Realizar la revisión periódica de las actividades de los usuarios en los sistemas de información.
 - g. Remover a los usuarios deshabilitados o redundantes en las aplicaciones y/o servicios prestados.
 - h. Realizar monitoreo sobre las redes y los sistemas informáticos de la **DIAN**.
 - i. Definir la segregación de roles de control de acceso, enmarcada en crear, modificar, eliminar, consultar e imprimir.
 - j. Definir matriz de roles para el control de accesos a los sistemas de información de la entidad.
 - k. Definir los accesos especiales sobre los activos de información para su adecuado acceso.
 - l. Divulgar y autorizarla información de acuerdo con el uso aceptable, la clasificación y el etiquetado de la información.
 - m. Realizar restricciones al acceso privilegiado.
 - n. Incluir segregación de funciones para los accesos a los sistemas de información.
 - o. Incluir manejo de registros en los sistemas de información.
 - p. Identificar la matriz de accesos de acuerdo con los roles establecidos para la entidad por los sistemas de información.
 - q. Activar la autenticación en dos pasos para todos los sistemas de información misionales expuestos al público.
4. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
- a. Integrar los servicios y/o aplicaciones de la **DIAN** al controlador de dominio como fuente única de autenticación, si la aplicación o servicio técnicamente lo permite; el controlador de dominio debe poder gestionar la segregación de funciones de las aplicaciones y/o servicios.
 - b. Controlar el acceso a las áreas seguras e instalaciones de procesamiento de información y recursos tecnológicos, limitando éste al personal debidamente autorizado de acuerdo con sus necesidades para la operación.

- c. Implementar controles para el acceso de usuarios remotos a los equipos en la red de la **DIAN**, el cual se debe realizar a través del servicio de escritorios remotos, escritorios virtuales o con la tecnología adoptada y apropiada para la entidad.
 - d. Retirar, de manera temporal o definitiva de la red de datos, los equipos que presenten tráfico, eventos o actividades que comprometan o puedan afectar el correcto funcionamiento de los sistemas de información de la **DIAN**.
 - e. Controlar todo acceso a la red de la entidad. En caso de que se requiera acceder a la red mediante elementos o recursos tecnológicos no institucionales, esto debe ser informado y autorizado.
5. La Subdirección de Gestión del Empleo Público debe:
- a. Solicitar y autorizar a través de la herramienta asignada por la Dirección de Gestión de Innovación y Tecnología, por parte del responsable, el acceso a la información y a los recursos tecnológicos de la **DIAN** para funcionarios y terceros que laboren en la entidad o personal externo (empresa o entidad externa), basado en la premisa: "Todo está restringido, a menos de que esté expresamente permitido".
 - b. Realizar el enrolamiento a los funcionarios y personal externo con los permisos y accesos a zonas no autorizadas (ejemplo: control de accesos que maneja el concesionario en el Aeropuerto el Dorado).
6. Los funcionarios y terceros deben:
- a. Cumplir con la política establecida y seguir los procedimientos, instructivos, cartillas y demás documentos, definidos, relacionados con accesos a redes, gestión de usuarios, permisos de administrador, políticas de copias de respaldo (*backup*), gestión de roles, desarrollo de sistemas de información y demás.
 - b. Solicitar por parte del jefe de la dependencia la aprobación a la Dirección de Gestión de Innovación y Tecnología, en caso de requerir una modificación a la configuración de las redes y equipos de infraestructura tecnológica según la necesidad de acceso.
 - c. Utilizar los usuarios asignados con los privilegios correspondientes para cada caso. Ningún usuario de la **DIAN** puede registrarse directamente en un equipo o servidor de la entidad como administrador con todos los privilegios de acceso.
 - d. Informar inmediatamente a la mesa de ayuda sobre cualquier novedad que afecte la operación normal de la infraestructura tecnológica de la entidad o acceso no requerido para la operación.

E. Controles relacionados:

- 1. 5.2 – Roles y responsabilidades para la seguridad de la información
- 2. 5.3 – Segregación de funciones
- 3. 5.10 – Uso aceptable de la información y otros activos asociados
- 4. 5.12 – Clasificación de la información
- 5. 5.13 – Etiquetado de la información
- 6. 5.16 – Gestión de identidad
- 7. 5.17 – Información de autenticación
- 8. 5.18 – Derechos de acceso
- 9. 5.31 – Requisitos legales, estatutarios, reglamentarios y contractuales
- 10. 5.32 – Derechos de propiedad intelectual
- 11. 5.33 – Protección de registros
- 12. 5.34 – Protección de datos personales (PII)

- 13. 6.8. – Reporte de eventos de seguridad de la información
- 14. 7.2 – Entrada física
- 15. 7.3 – Aseguramiento de oficinas, salas e instalaciones
- 16. 7.4 – Supervisión de la seguridad física
- 17. 8.2 – Derechos de acceso privilegiado
- 18. 8.3 – Restricción de acceso a la información
- 19. 8.4 – Acceso al código fuente
- 20. 8.5 – Autenticación segura
- 21. 8.15 – Inicio de sesión
- 22. 8.18 – Uso de programas privilegiados de utilidad
- 23. 8.26 – Requisitos de seguridad de la aplicación

5.16 Gestión de identidad

A. Objetivo de control: definir y establecer lineamientos adecuados sobre la gestión del ciclo de vida de las identidades.

B. Alcance: el alcance de este lineamiento aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que utilizan identificación para acceder a la información de la entidad y otros activos asociados.

C. Características del control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Oficina de Seguridad de la Información debe:
 - a. Definir lineamientos y controles para la gestión de identidades en la **DIAN**, que se encuentran definidos en este numeral. Monitorear de manera periódica las identidades asignadas a las personas y el cumplimiento de los lineamientos definidos en la gestión de identidad.
- 2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Implementar los lineamientos y controles definidos por la Oficina de Seguridad de la Información respecto a la gestión de identidad.
 - b. Asignar un nombre único de cuenta a todos los funcionarios y terceros de la **DIAN** para hacer uso de los sistemas de información de la entidad.
 - c. Restringir las cuentas de administrador local de los equipos de los usuarios internos únicamente para labores de soporte técnico.
 - d. Verificar que todas las aplicaciones y sistemas de información tengan autenticación solo de cuentas administradas por el controlador de dominio y contar con la documentación de la gestión de identidades adoptada por la **DIAN**.
 - e. Asignar los roles a los usuarios internos únicamente si son aprobados por su jefe inmediato.

- f. Establecer la gestión de identidades a través del controlador de dominio de la entidad o mediante la solución tecnológica adoptada por la **DIAN**.
 - g. Desactivar de los sistemas de información misionales, aquellos usuarios que presentan inactividad superior a 45 días calendario.
3. Los funcionarios y terceros deben:
- a. Cambiar la clave de acceso a los sistemas de información de la **DIAN** en forma periódica.
 - b. Cumplir los lineamientos y directrices sobre la gestión de identidad establecidas por la entidad.
 - c. Utilizar la identidad y la contraseña asignada para el acceso a los sistemas de información, estos son de uso personal e intransferible y es responsabilidad del usuario interno preservar su confidencialidad.
 - d. Notificar en caso de contar con roles o permisos que no son necesarios para el cumplimiento de sus funciones y obligaciones asignadas.

E. Controles relacionados:

1. 5.17 – Información de autenticación
2. 5.18 – Derechos de acceso
3. 5.19 – Seguridad de la información en las relaciones con los proveedores

5.17 Información de autenticación

A. Objetivo de control: definir un proceso de gestión formal para la asignación de información de autenticación en la **DIAN** para el acceso a los recursos tecnológicos de la entidad.

B. Alcance: el alcance de este lineamiento aplica para que todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que hacen uso de información de autenticación. Adicionalmente, la Oficina de Seguridad de la Información, en apoyo con la Dirección de gestión de Innovación y tecnología, debe definir e implementar un sistema de gestión de contraseñas que permita mantener su calidad y controlar la asignación de información de autenticación.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
- b. Definir un proceso de gestión para la asignación de la información de autenticación en la **DIAN**, donde se incluyan criterios como:
 - El cambio de contraseñas solo puede ser solicitado por el titular de la cuenta o jefe/supervisor inmediato, este último solo cuando los colaboradores no tengan medios para realizarlo.
 - Cantidad de caracteres permitidos.
 - Tipos de caracteres permitidos.

- Características diferenciales para administradores de servicios tecnológicos.
 - Impedir el reuso de contraseñas.
 - No enviar la contraseña por correo electrónico.
- c. Definir lineamientos y controles para gestionar los requerimientos en la asignación de información de autenticación enmarcados en este numeral.
- Promover buenas prácticas en el uso de la información de autenticación entre los funcionarios y terceros de la **DIAN**.
2. La Dirección de Gestión de Innovación y Tecnología debe:
- a. Implementar los lineamientos y controles definidos por la Oficina de Seguridad de la Información para la asignación de la información de autenticación.
 - b. Verificar la identidad del usuario antes de asignarle la información de autenticación ya sea nueva, de sustitución o provisional.
 - c. Suministrar la información asociada a la autenticación a los usuarios de manera segura únicamente a través del correo institucional, evitando el uso correos electrónicos no autorizados.
 - d. Implementar una herramienta para la gestión de contraseñas definiendo características de acuerdo con el sistema adoptado por la entidad.
 - e. Renovar la autorización y solicitar el cambio de contraseña periódicamente para los usuarios externos que tengan autorización de acceso a la **DIAN**. Si la lista de usuarios con permisos no es renovada por los externos, serán bloqueados y luego de tres meses de estar bloqueados serán eliminados.
 - f. Forzar el cambio de contraseñas periódicamente. Cuando un usuario sea nuevo en los sistemas se debe obligar a realizar su cambio.
3. La Subdirección de Soluciones y Desarrollo debe:
- a. Implementar los lineamientos de autenticación segura en los sistemas de información que desarrolle o desarrollos subcontratados en la entidad.
4. Los funcionarios y terceros de la entidad deben:
- a. Suscribir el compromiso de confidencialidad de la información, con el fin de mitigar el uso indebido de la información de autenticación entregada.
 - b. Cumplir con lo establecido en los instructivos asociados a la creación de cuentas de usuario definido por la entidad.

E. Controles relacionados:

1. 6.2. – Términos y condiciones de empleo
2. 6.8. – Reporte de eventos de seguridad de la información
3. 8.24 – Uso de criptografía

5.18 Derechos de acceso

- A. Objetivo de control:** proporcionar, revisar, modificar y eliminar los derechos de acceso a la información y otros activos asociados, de acuerdo con reglas de control de acceso definidas por la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología, que asigna o revoca los derechos de acceso para todo tipo de usuarios en los sistemas de información y servicios de la entidad.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Realizar la configuración y/o instalación de los agentes correspondientes para la integración de ingreso, cambios y/o reinstalaciones de los sistemas de la **DIAN** a las plataformas de SIEM (*Security Information and Event Management* – Gestión de Eventos e Información de Seguridad), protección de bases de datos.
 - b. Definir y establecer lineamientos y controles para la desactivación o bloqueo de los privilegios de acceso sobre los recursos tecnológicos, los servicios de red y los sistemas de información de manera oportuna, teniendo en cuenta las siguientes situaciones administrativas:
 - Desvinculación.
 - Licencias.
 - Vacaciones.
 - Traslados o ubicaciones entre dependencias o seccionales.
 - Cambio de cargo o proceso.
 - Sanción disciplinaria.
 - Terminación de contrato de prestación de servicio o contrato con terceras partes o proveedores.
 - En las situaciones anteriormente, los usuarios deben ser notificados a través de los canales dispuestos para tal fin.
2. La Subdirección de Gestión del Empleo Público debe:
 - a. Notificar a los funcionarios de la entidad sobre la desactivación o bloqueo de los privilegios de acceso sobre los recursos tecnológicos, los servicios de red y los sistemas de información, de manera oportuna y a través de los canales dispuestos para tal fin.
 - b. Reportar a la Dirección de Gestión de Innovación y Tecnología las novedades de desvinculación o cambio de rol del personal para proceder con los cambios de acceso en los recursos tecnológicos.
3. La Dirección de Gestión de Innovación y Tecnología debe:
 - Contar con un sistema centralizado de identidades, por medio del cual se asignan los roles de acceso a los sistemas de información, de acuerdo con las funciones de cada usuario interno.
 - a. Llevar el registro de las cuentas de super usuario interno de cada uno de los sistemas de la DIAN, con el fin de ser monitoreadas de manera permanente.

- b. Integrar al controlador de dominio o a la herramienta de gestión de identidades definida los sistemas de la DIAN, para el manejo de los usuarios internos a través del sistema centralizado de identidades.
 - c. Definir los tipos de usuario que tendrán acceso para cada tipo de información establecido de acuerdo con las funciones. Esta clasificación debe tener en cuenta los siguientes aspectos: funciones de la dependencia a la que pertenezca el funcionario, tipo de información a la que accede y las acciones permitidas sobre la información a la que se tiene acceso.
 - d. Establecer un procedimiento que permita gestionar la creación, modificación, o borrado de las cuentas de acceso de los usuarios (por ejemplo: cuenta de correo, acceso a las Apps, entre otros) indicando quién debe autorizarlo.
 - e. Generar reportes de acceso y uso de los sistemas de información a los responsables de cada dependencia.
 - f. Mantener actualizado y depurado el listado y los permisos de administración de los diferentes recursos tecnológicos de la entidad. Para tal efecto, se deben hacer por lo menos dos revisiones al año. Adicionalmente, se debe contar con un registro de cuentas con accesos privilegiados.
 - g. Inactivar los derechos de acceso en la herramienta de gestión de identidades definida por la entidad. Los derechos de acceso se deben inactivar para ausencias temporales (vacaciones, incapacidades, licencias remuneradas, licencias no remuneradas, permisos, etc.) o en caso de sanción disciplinaria. Cuando se requiera la reactivación de los derechos de acceso para realizar actividades especiales inherentes al rol desempeñado por el funcionario o usuario, el jefe inmediato debe solicitar esta autorización. En caso de retiro, los derechos de acceso se inactivarán definitivamente.
 - h. Gestionar las conexiones de los usuarios con roles sensibles (super usuarios internos, administradores y usuarios internos que manejan transacciones críticas, entre otros), utilizando la herramienta de gestión de Identidades privilegiadas que permita la conexión a los sistemas de la DIAN según las funciones del rol que desempeñe.
 - i. Verificar que todas las aplicaciones y sistemas de información tengan autenticación solo de cuentas administradas por el controlador de dominio y contar con la documentación de la gestión de identidades que se realiza.
 - j. Realizar monitoreo de todas las cuentas, incluidas las cuentas de super usuarios, administradores y también las cuentas genéricas o de servicio con privilegios especiales.
 - k. Eliminar las cuentas genéricas y duplicadas adicionales con permisos de administrador en los casos de pruebas suplementarias.
3. Los funcionarios y terceros de la entidad deben:
 - a. Reportar oportunamente las novedades que originan el retiro o la inactivación de los derechos de acceso (cuentas de usuario) de manera temporal o definitiva, según sea el caso.
4. Los jefes de las dependencias deben:
 - Verificar que sus funcionarios cuenten con los debidos roles para desempeñar sus funciones. Lo anterior se establece con base en el procedimiento PR-IIT-0455, Gestión de Accesos.
 - Realizar validación de los roles en los sistemas de información y solicitar la inactivación en caso de identificar accesos no autorizados.

- Depurar los roles asignados y realizar acciones pertinentes para inactivar oportunamente el acceso a aquellos funcionarios que no requieren el acceso a sistemas de información externos.
- Reportar de manera oportuna las novedades de desvinculación o cambio de rol de sus funcionarios y terceros.

E. Controles relacionados:

1. 5.3. – Segregación de funciones
2. 5.9. – Inventario de información y otros activos asociados
3. 5.15. – Control de acceso
4. 5.20. – Abordar la seguridad de la información en los acuerdos con proveedores
5. 6.1. – Selección
6. 6.2. – Términos y condiciones de empleo
7. 6.3. – Concientización, educación y capacitación en seguridad de la información
8. 6.4. – Proceso disciplinario
9. 6.5. – Responsabilidades después de la terminación o cambio de empleo
10. 6.6. – Acuerdos de confidencialidad o no divulgación
11. 6.8. – Reporte de eventos de seguridad de la información

5.19 Seguridad de la información en las relaciones con los proveedores

A. Objetivo de control: establecer las políticas, principios y lineamientos para proteger y gestionar adecuadamente los activos de información accesibles por los proveedores de productos y servicios y, asegurar el cumplimiento de las políticas y procedimientos de la seguridad y privacidad de la información emitidos por la entidad.

B. Alcance: el alcance de esta política aplica para todos los proveedores de productos y servicios, su personal a su cargo y demás terceros o subcontratistas que tengan acceso a la información de la entidad, e incluye los proveedores en calidad de encargados del tratamiento de información a nombre de la entidad. Debe ser atendido por los funcionarios y terceros que intervienen en la contratación y/o ejecución de contratos con proveedores.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Establecer políticas y lineamientos de seguridad y privacidad de la información con el fin de: i) proteger la información de accesos no autorizados; ii) evitar su manipulación; iii) evitar usos indebidos o fuera de las finalidades; iv) evitar la interrupción de servicios críticos y de v) evitar la introducción de vulnerabilidades a través de productos o servicios.
 - b. Establecer el marco para evaluar los tipos de proveedores que pueden afectar la confidencialidad, integridad, disponibilidad y privacidad de la información.
 - c. Establecer requisitos de seguridad y privacidad de la información para la selección y contratación de los proveedores conforme a los criterios de riesgos y en función de la sensibilidad y criticidad de la información.

- d. Establecer lineamientos de control de acceso a los activos de información (físicos, electrónicos o sistemas de información) que requieran los proveedores, en todo el ciclo de vida del dato, desde la recolección hasta la disposición final.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Categorizar los proveedores en función de la criticidad del servicio y de la información
 - b. Evaluar los riesgos de la relación con los proveedores y definir los planes de mitigación.
 - c. Establecer cláusulas para el uso apropiado de la información en ambientes en nube.
 - d. Verificar las especificaciones técnicas de los contratos y convenios con los proveedores se incluyan las cláusulas de seguridad y privacidad de la información.
 - e. Evaluar los proveedores que pueden afectar la confidencialidad, integridad, disponibilidad y privacidad de la información.
 - f. Definir y monitorear las necesidades y condiciones de conexión de los equipos de cómputo y dispositivos de procesamiento de información de los proveedores a través de acuerdos y niveles de servicio.
 - g. Establecer requisitos, las especificaciones y requerimientos para canales de comunicación segura en la transmisión e intercambio de información desde y hacia los proveedores.
 - h. Establecer las configuraciones y requisitos de seguridad de la información pertinentes para los dispositivos de propiedad del proveedor en los que se almacene o procese información de la entidad, así como las herramientas de cifrado y controles técnicos requeridos para la comunicación segura, transmisión de información, medidas de respaldo y recuperación de la información a la cual tengan acceso los proveedores.
 - i. Establecer cláusulas para el uso apropiado de la información en ambientes en nube. En caso de realizar la contratación a través de acuerdo marco de precios del SECOP, se deben verificar las cláusulas de seguridad allí definidas.
 - j. Realizar seguimiento a la gestión de la seguridad de información relacionada con los proveedores.
 - k. Establecer el procedimiento para la terminación de la relación con los proveedores para asegurar la devolución y/o destrucción segura de la información y revocación de accesos.
 3. La Subdirección de compras y contratos debe:
 - a. Categorizar a los proveedores según la criticidad del servicio que prestan y el tipo de información que manejan, con el fin de establecer niveles de control adecuados.
 - b. Evaluar los riesgos asociados a la relación con los proveedores y definir planes de mitigación que garanticen la seguridad de la información.
 - c. Establecer cláusulas condiciones que regulen el uso apropiado de la información en ambientes en nube, asegurando su protección.
 - d. Evaluar a los proveedores que puedan impactar la confidencialidad, integridad, disponibilidad y privacidad de la información institucional.
 - e. Definir y monitorear las condiciones de conexión de los equipos de cómputo y dispositivos de procesamiento de información de los proveedores, mediante acuerdos y niveles de servicio.
 - f. Establecer requisitos técnicos y de seguridad para los canales de comunicación utilizados en la transmisión e intercambio de información con los proveedores.

- g. Definir configuraciones y controles de seguridad para los dispositivos de propiedad del proveedor que almacenen o procesen información de la entidad, incluyendo herramientas de cifrado, medidas de respaldo y recuperación.
 - h. Incluir cláusulas específicas sobre el uso y protección de la información, incluidos los ambientes en nube y los contratos realizados mediante acuerdos marco de precios del SECOP, verificando que se cumplan los requisitos de seguridad establecidos.
 - i. Establecer el procedimiento de finalización de la relación contractual con los proveedores, asegurando la devolución o destrucción segura de la información y la revocación de accesos.
- 4. La Subdirección de Compras y Contratación debe:
 - a. Definir el proceso de contratación y las cláusulas de los contratos para el cumplimiento de la Ley de Protección de Datos Personales por parte de los terceros involucrados en el proyecto o servicio, lo cual debe ser verificado por el supervisor de contrato.
 - b. Asegurar la inclusión de los acuerdos de confidencialidad y/o compromisos de uso de los servicios informáticos para proteger la información que será gestionada o a la cual tendrá acceso el proveedor para preservar la seguridad y privacidad de la información. Estos acuerdos y compromisos serán vinculantes y deben contener una responsabilidad tanto civil como penal para el proveedor o la tercera parte contratada.
 - c. Asegurar la obligación de suscripción de acuerdos de confidencialidad con el personal a cargo y los subcontratistas del proveedor que intervienen en la gestión de la información objeto y finalidad del contrato suscrito.
 - d. Mantener actualizado el registro de todos los proveedores que hacen parte de la entidad y que tienen acceso a la información por la naturaleza de sus contratos.
 - e. Verificar la aplicación de gestión de riesgos y obligaciones de seguridad y privacidad de la información para la suscripción de los contratos con terceros en la entidad.
 - f. Incluir en el manual de supervisión criterios de seguridad y privacidad de la información asociados a los contratos que gestionen información institucional.
 - g. Incluir cláusulas dependiendo del tipo de información que maneje el proveedor, incluyendo obligaciones para la recuperación, la contingencia, la disposición final de la información, la eliminación y el borrado seguro de la información gestionada al finalizar la relación contractual, según la sensibilidad del contrato.
- 5. La Subdirección de Soluciones y Desarrollo debe:
 - a. Definir las cláusulas relacionadas con la seguridad y privacidad de la información, las buenas prácticas de desarrollo seguro, análisis de vulnerabilidades, derechos de autor y propiedad intelectual y revisión de cumplimiento de los lineamientos relacionados con desarrollo de software de este manual.
 - b. Implementar medidas para evitar la introducción de vulnerabilidades en los sistemas de la organización a través de productos o servicios de proveedores
- 6. Los proveedores y terceros de la entidad deben:
 - a. Implementar las políticas, procesos y procedimientos para cumplir con los lineamientos, políticas, procedimientos y controles emitidos por la entidad para proteger la seguridad y privacidad de la información.
 - b. Gestionar los riesgos de seguridad y privacidad de la información para asegurar, impedir, acceder, copiar, reproducir, distribuir, transmitir o divulgar por ningún medio

- conocido o por conocer la información confidencial, en todo o en parte, sin previo y escrito consentimiento de la DIAN.
- c. Adoptar las medidas de seguridad necesarias y adecuadas para la conservación, la protección, la custodia y la reserva de la información que reciba, produzca, procese o a la que tenga acceso para prevenir riesgos asociados con fuga, pérdida, manipulación o difusión no autorizada y el acceso no autorizado o fraudulento.
 - d. Suscribir los acuerdos de confidencialidad o compromisos de uso de los servicios informáticos para proteger la información que será gestionada o a la cual tendrá acceso el proveedor, haciendo énfasis en los datos personales, preservando la seguridad y privacidad de la información, de acuerdo con lo establecido por la entidad (responsabilidad demostrada de terceros sobre la protección de los datos personales).
 - e. Utilizar la información suministrada por la DIAN exclusivamente para las finalidades establecidas en el objeto contractual.
 - f. Mantener la confidencialidad, integridad y disponibilidad de la información de la que haga uso o tenga conocimiento en el cumplimiento del objeto contractual, comprometiéndose a no utilizarla para provecho propio, ni divulgarla, comercializarla, publicarla, cederla, revelarla o reproducirla de manera directa e indirecta, o ponerla a disposición de terceros que no estén autorizados por la DIAN para conocerla.
 - g. Evitar actos que comprometan o afecten a la DIAN, por lo que es su obligación como proveedor o contratista no utilizar la información institucional incluso después de terminada la relación contractual para su beneficio o el de terceros.
 - h. Cumplir y certificar la disposición final de información en los términos establecidos en el contrato toda la información entregada u obtenida de la DIAN en desarrollo de su objeto contractual, tales como documentos, soportes magnéticos y físicos, entre otros.
 - i. No acceder, copiar, reproducir, distribuir o transmitir por ningún medio conocido o por conocer la información confidencial, en todo o en parte, sin previo y escrito consentimiento de la DIAN.
 - j. Cumplir con el adecuado tratamiento de los datos personales de los titulares, recolectados por la entidad en virtud de la legislación vigente.
 - k. No transferir, ceder o divulgar el “usuario” y “contraseña” que le sean asignados (si aplica), teniendo en cuenta que se encuentran bajo su responsabilidad todas las acciones o tareas que se realicen con ellos.
 - l. Suministrar a la DIAN la información relacionada con sus políticas, procedimientos y demás documentación asociada con la seguridad de la información y la protección de datos personales, la responsabilidad demostrada y la debida diligencia.
 - m. Responder las solicitudes de información relacionadas con la seguridad y privacidad de la información y atender las visitas de verificación que podrá ejecutar la DIAN sin previo aviso.
 - n. Realizar actividades de concientización sobre seguridad y privacidad de la información al personal que tenga acceso a la información sensible de la entidad.
 - o. Informar a la entidad los eventos o incidentes de seguridad que afecten los activos.
 - p. Suscribir los acuerdos internos de confidencialidad de la información con sus colaboradores y su personal a cargo, terceros y subcontratistas y remitir copia a la entidad.

7. Los supervisores de contratos deben:

- a. Custodiar y cuidar la documentación e información que en cumplimiento del objeto contractual sea entregada por la entidad, así como a la que tenga acceso, e impedir o evitar su sustracción, destrucción, manipulación, ocultamiento o utilización indebida.

- b. Solicitar al proveedor la firma de los acuerdos de confidencialidad o compromisos de uso de los servicios informáticos para proteger la información que será gestionada o a la cual tendrá acceso el proveedor, haciendo énfasis en la que contenga datos personales, preservando la seguridad y privacidad de la información de la entidad.
- c. Interactuar coordinadamente con los enlaces de seguridad de la información designados por las diferentes dependencias de la entidad.
- d. Cumplir con la legislación vigente, así como con las medidas y protocolos de seguridad que la entidad ha implementado para mitigar la afectación a la confidencialidad de los datos de carácter personal, privados o sensibles.
- e. Reportar a la Oficina de Seguridad de la Información y a la Dirección de Gestión Innovación y Tecnología los incidentes de seguridad o privacidad de la información a través de los canales y medios destinados para tal fin.
- f. Gestionar la asignación y revocación de permisos de el control de acceso a los activos de información que requieran los proveedores ya sean físicos, electrónicos o sistemas de información.
- g. Identificar los riesgos de seguridad y privacidad de la información según el alcance del contrato o contratos bajo su supervisión.
- h. Tramitar las evaluaciones de seguridad y privacidad de la información solicitadas por la Oficina de Seguridad de la Información.
- i. En los reportes de supervisión de los contratos dejar constancia del seguimiento a los acuerdos de seguridad y privacidad de la información.

8. La Subdirección Administrativa debe:

Incluir la obligación de adelantar actividades de concientización en seguridad y privacidad de información al personal de vigilancia para los contratos de seguridad física.

E. Controles relacionados: No aplica.

5.20 Abordar la seguridad de la información en los acuerdos con proveedores

A. Objetivo de control: asegurar la aplicación las políticas, requisitos, procesos y procedimientos de seguridad y privacidad de la información pertinentes con cada proveedor.

F. Alcance: el alcance de este lineamiento aplica para todos los proveedores de productos o servicios que tengan acceso a información clasificada o reservada y datos personales. Igualmente debe ser atendido por los funcionarios y terceros que intervienen en la contratación, ejecución, supervisión o interventoría de contratos con proveedores y terceros.

B. Características del control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

C. Lineamientos:

1. La Oficina de Seguridad de la información debe:
 - a. Definir criterios para calificar la información, los servicios e infraestructura a la que los proveedores pueden acceder, supervisar, controlar o usar.
 - b. Definir metodologías y lineamientos para gestionar los riesgos de seguridad y privacidad relacionados con los proveedores.
 - c. Validar que sean adoptados los requisitos de seguridad y privacidad de la información en los procesos de contratación y durante la ejecución y liquidación de los contratos.
 - d. Verificar la adopción de las políticas, procedimientos y lineamientos para el procesamiento de información por parte de los proveedores que garanticen la seguridad y privacidad de la información incluidas la continuidad de los servicios, el cifrado, los controles técnicos para la transmisión segura de la información y la disposición final.
 - e. Verificar el cumplimiento de los requisitos de seguridad y privacidad de la información por parte de los proveedores que acceden a los activos de información con el fin de proteger de acceso y usos indebidos a los activos de información de la entidad, en todo el ciclo de vida del dato, desde la recolección hasta la disposición final.
 - f. Verificar que los contratos y convenios con los proveedores incluyan las cláusulas necesarias de seguridad y privacidad de la información, conforme a los requisitos institucionales.
2. Las áreas propietarias de los activos
 - a. Identificar los activos y clasificarlos para establecer el grado de confidencialidad y las finalidades que se autorizan para ejecución del contrato.
 - b. Establecer las condiciones de acceso y las finalidades de los datos para ser incluidas en el proceso de contratación para garantizar la seguridad y privacidad de la información.
3. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Establecer los requisitos de seguridad de productos y servicios prestados por proveedores.
 - b. Monitorear las necesidades y condiciones de conexión de los equipos de cómputo y dispositivos de procesamiento de información de los proveedores a través de acuerdos y niveles de servicio.
 - c. Definir las especificaciones y requerimientos para canales de comunicación segura en la transmisión e intercambio de información desde y hacia los proveedores.
 - d. Verificar las condiciones, configuraciones y requisitos de seguridad de la información pertinentes para los dispositivos de propiedad del proveedor en los que se almacene o procese información de la entidad, así como las herramientas de cifrado y controles técnicos requeridos para la comunicación segura, transmisión de información, medidas de respaldo y recuperación de la información a la cual tengan acceso los proveedores.
 - e. Verificar el cumplimiento de las cláusulas para el uso apropiado de la información en ambientes en nube.
 - f. Monitorear el cumplimiento de las condiciones de operación de los proveedores.
 - g. Gestionar incidentes de seguridad y tomar medidas para garantizar la seguridad y privacidad de la información.
 - h. Monitorear el mal funcionamiento o vulnerabilidades de productos, componentes y subcomponentes de software o servicios prestados por los proveedores.

4. La Subdirección de compras y contratos debe:

- a. Verificar la suscripción de acuerdos en los que se especifiquen los requisitos de seguridad y privacidad de la información requeridas, de tal manera que se minimicen los riesgos por indisponibilidad, exposición indebida, difusión, adulteración o pérdida de información conforme al producto o servicio.
- b. Verificar la inclusión las condiciones de para cumplir las especificaciones de seguridad y privacidad en el manual de contratación y en los acuerdos con los proveedores.

5. Los supervisores de contratos deben:

- a. Verificar la suscripción de acuerdos de confidencialidad de los proveedores, su personal a cargo y sus subcontratistas que intervengan en la gestión de la información objeto (finalidad) del contrato suscrito.
- b. Validar el cumplimiento de los requisitos legales, regulatorios y de las normas de la entidad relacionados con seguridad y privacidad de la información y la protección de datos personales, los derechos de propiedad intelectual y derechos de autor.
- c. Verificar que se incluyan en los acuerdos las medidas de respaldo y recuperación de la información a la cual tengan acceso los proveedores.
- d. Validar la inclusión de los mecanismos de control de acceso a los activos de información (físicos, electrónicos o sistemas de información) que requieran los proveedores.
- e. Validar la inclusión de las configuraciones y requisitos de seguridad de la información pertinentes para los dispositivos de propiedad de los proveedores, en los que se almacene o procese información de la entidad.
- f. Validar que se firmen, por parte de los proveedores, los acuerdos de confidencialidad y no divulgación de la información, así como verificar la suscripción de acuerdos de confidencialidad con los colaboradores/empleados de los proveedores que tengan acceso a la información de la entidad.
- g. Validar los requisitos para la terminación del contrato, especialmente la aplicación de los procedimientos de terminación del contrato y disposición final de la información.

6. Los proveedores deben:

- a. Proteger la información calificada como pública clasificada y pública reservada que sea suministrada por la **DIAN**, para propender por la confidencialidad, integridad y disponibilidad de la información que se requiera para la ejecución de las actividades establecidas en los procesos contractuales.
- b. Tratar de manera adecuada los datos personales de los titulares en caso de tener accesos a ellos en el cumplimiento del contrato y cumpliendo con la finalidad autorizada.
- c. Dar cumplimiento a las cláusulas asociadas con la seguridad de la información, a este manual y a los procedimientos asociados a seguridad y privacidad de la información.
- d. Reportar los incidentes de seguridad y privacidad de la información por los canales y medios destinados para tal fin.
- e. Atender las visitas de verificación que realice la DIAN o sus encargados.

D. Controles relacionados:

1. 5.10. – Uso aceptable de la información y otros activos asociados
2. 5.11. – Devolución de Activos

3. 5.12. – Clasificación de la información
4. 5.13. – Etiquetado de la información

5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC

A. Objetivo de control: definir e implementar procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con la cadena de suministro de productos y servicios de TIC en la entidad.

B. Alcance: estos lineamientos aplican para todos los proveedores de productos o servicios, así como su personal a cargo, terceros y subcontratistas, incluidos aquellos que tengan acceso a datos personales, información clasificada o reservada, encargados del tratamiento de la información y debe ser considerado por los funcionarios y terceros que intervienen en la contratación, ejecución, supervisión o interventoría de contratos con proveedores y terceros.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Compras y Contratos debe:
 - a. Definir los requisitos de seguridad y privacidad de la información para los contratos suscritos para la adquisición de suministro de productos y servicios de tecnología de información y comunicaciones.
 - b. Incluir dentro de los componentes de los contratos de TI garantías asociadas a la cadena de suministro de las TIC.
2. La Oficina de Seguridad de la Información debe:
 - a. Definir la metodología para la Gestión de Riesgos de seguridad de la información asociados a los requisitos y acuerdos establecidos para la cadena de suministro de productos y los servicios de tecnología de información y comunicaciones.
 - b. Verificar que se incluyan obligaciones para la cadena de suministro de tecnologías.
3. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Establecer en los contratos con sus proveedores de productos de tecnología de información y comunicaciones que estos apliquen las prácticas de seguridad adecuadas en la cadena de suministro.
 - b. Establecer en los contratos con proveedores los requisitos de seguridad de la información y la gestión de riesgos, aplicables a la adquisición de productos o servicios de tecnología de la información y de comunicaciones.

- c. Tener la seguridad de que los servicios o los productos sean entregados de acuerdo con las especificaciones contractuales establecidas.
 - d. Solicitar a los proveedores de servicios de TIC que transmitan, divulguen y comuniquen los requisitos de seguridad y privacidad a lo largo de su cadena de suministro.
 - e. Identificar y documentar los componentes del producto o servicio que son críticos para la entidad.
 - f. Verificar el aprovisionamiento de servicios en la nube, proveedores de servicios de telecomunicaciones y proveedores de hardware.
4. Los supervisores de los contratos deben:
- a. Notificar situaciones de riesgos a la Subdirección de Compras y Contratos novedades relacionadas con el suministro de productos y servicios de tecnología de información y comunicaciones.
 - b. Monitorear las novedades relacionadas con el suministro de productos y servicios de tecnología de información y comunicaciones.

E. Controles relacionados: No aplica.

5.22 Seguimiento, revisión y gestión de cambios de servicios de proveedores

A. Objetivo de control: monitorear, revisar, evaluar y gestionar periódicamente los cambios en las prácticas de seguridad y privacidad de la información de los proveedores y prestación de servicios.

B. Alcance: El alcance de este lineamiento aplica para todos los funcionarios que deban mantener el nivel acordado de seguridad y privacidad de la información y de prestación del servicio en línea con los acuerdos con los proveedores; adicionalmente se deben gestionar los cambios, incluyendo los asociados a la infraestructura, los aplicativos y los servicios tecnológicos, que son soportados por terceros, para permitir estándares de eficiencia, seguridad y calidad.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Compras y Contratos debe:
 - a. Definir procedimientos donde se establezcan las condiciones para el seguimiento, la revisión y la gestión de cambios en los servicios suministrados por los proveedores.
 - b. Establecer las acciones que deben tomar los supervisores cuando se observen deficiencias en la prestación del servicio por parte de los proveedores.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Establecer lineamientos, procedimientos y/o mecanismos que permitan cumplir la gestión de cambios a nivel de infraestructura, sistemas de información y servicios tecnológicos que son soportados por proveedores, para confirmar eficiencia, seguridad y calidad en la gestión de cambios.

- b. Monitorear la asignación de permisos de acceso de los proveedores a los sistemas de información de la entidad; lo anterior, teniendo en cuenta las condiciones que estos deben cumplir en cuanto a la gestión de usuarios y contraseñas definidos en este manual.
 - c. Incluir dentro de las cláusulas, cuando se considere necesaria, la identificación de vulnerabilidades en los contratos de tecnología.
 - d. Incluir dentro de las cláusulas contractuales la posibilidad de realizar auditorías a los proveedores cuando haya cambios en los servicios que suministra.
 - e. Involucrar al responsable del plan de recuperación de desastre con voto para los temas que puedan afectar la continuidad de la operación. Gestionar los cambios que se presenten en la ejecución de los contratos suscritos con los proveedores, los cuales pueden estar asociados con:
 - Sistemas de información
 - Políticas de seguridad de la información
 - Mejoramiento de procedimientos
 - Eficiencia de los controles de seguridad de la información
 - Mantenimiento
3. Los supervisores de los contratos deben:
 - a. Realizar una revisión y actualización de sus proveedores, cada vez que se requiera, como mínimo una vez al año en cada inicio de período. Que se realiza con el apoyo por los enlaces de seguridad de la información designados.
 - b. Monitorear periódicamente el cumplimiento de los Acuerdos de Niveles de Servicio (ANS), acuerdos de confidencialidad y acuerdos de intercambio de información por parte de los proveedores.
 - c. Realizar seguimiento con regularidad a la prestación del servicio de los proveedores en los términos y condiciones de seguridad y privacidad de la información de los acuerdos se cumplan y que el manejo de incidentes de seguridad de la información se gestione adecuadamente.
 - d. Verificar que se cumplan los términos y condiciones de seguridad y privacidad de la información.
4. Los proveedores de la entidad deben:
 - a. Reportar a la Oficina de Seguridad de la Información y/o Dirección de Gestión de Innovación y Tecnología cualquier incidente de seguridad o privacidad de la información que se presente en la relación con los proveedores, con el fin de tomar las medidas respectivas de acuerdo con los lineamientos, parámetros y procedimientos establecidos.
 - b. Respalidar y proteger los activos de información que sean utilizados por los proveedores, teniendo en cuenta la clasificación de la información. Cuando se requiera, se debe contar con el apoyo de la Dirección de Gestión de Innovación y Tecnología para preservar su conservación y resguardo.

E. CONTROLES RELACIONADOS:

1. 5.24. – Planificación y preparación de la gestión de incidentes de seguridad de la información
2. 5.29. – Seguridad de la información durante la interrupción
3. 5.30. – Preparación de las TIC para la continuidad del negocio

4. 5.35. – Revisión independiente de la seguridad de la información
5. 5.36. – Cumplimiento de políticas, normas y estándares de seguridad de la información
6. 6.8. – Reporte de eventos de seguridad de la información
7. 8.14. – Redundancia de las instalaciones de procesamiento de información

5.23 Seguridad de la información para el uso de servicios en la nube

A. Objetivo de control: establecer procesos de adquisición, uso, gestión y salida de los servicios en la nube, de acuerdo con los requisitos de seguridad y privacidad de la información definidos por la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y la Dirección de Gestión de Innovación de Tecnología, encargadas de definir y comunicar una política sobre el uso de los servicios en la nube a todas las partes interesadas.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir los requisitos de seguridad y privacidad de la información asociados con el uso de los servicios en la nube, tales como IaaS, PaaS, Anexo Lineamientos Técnicos de Servicios en Nube.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Definir los riesgos de seguridad o privacidad de la información asociados con el uso de servicios en la nube, relacionados con la gestión de los servicios suministrados por terceros.
 - b. Solicitar y verificar la implementación y efectividad de los controles de seguridad y privacidad de la información al proveedor de servicios en la nube.
 - c. Establecer los criterios técnicos para evaluar o adquirir los servicios de cómputo en la nube.
 - d. Diseñar, definir y probar los procesos de continuidad operativa y recuperación en caso de desastres, respecto de la base tecnológica en nube de la **DIAN**, tomando como base los lineamientos dados en este manual por los controles 5.1.29 y 5.1.30 o los que hagan sus veces.
 - e. Definir con el (los) proveedor(es) de nube los ANS correspondientes a los requisitos no funcionales de seguridad de la información en todo el ciclo de gestión de la nube.
 - f. Alinear los contratos de nube con los lineamientos de derechos de propiedad intelectual dados por el control 5.1.32 o el que haga sus veces.
 - g. Los contratos de servicios en la nube deben alinearse con los lineamientos de seguridad de la información dados por este manual, asegurando que contemplen la eliminación segura de datos, la protección de información personal, la posibilidad de auditoría, la seguridad en redes, la gestión de identidades y de la configuración, la transferencia segura de información, el uso de cifrado, la gestión de cambios, gestión de

vulnerabilidades y todos aquellos lineamientos que puedan impactar la confidencialidad, disponibilidad e integridad de los activos de información alojados en la nube.

- h. Incluir los elementos de la nube, en los procesos de monitoreo de seguridad, generando alertas sobre eventos de seguridad.
- i. Realizar un análisis de riesgos de seguridad y privacidad de la información con la metodología adoptada por la Oficina de la Seguridad de la Información.
- j.
- k.

3.

E. Controles relacionados:

- 1. 5.21. – Gestión de la seguridad de la información en la cadena de suministro de las TIC.
- 2. 5.22. – Seguimiento, revisión y gestión de cambios de servicios de proveedores.

5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información

A. Objetivo de control: definir los roles, las responsabilidades y los procedimientos de gestión para la atención oportuna y eficaz de los incidentes de seguridad y privacidad de la información en la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y las dependencias que definen e implementan los lineamientos para la gestión de incidentes de seguridad de la información, para el manejo de eventos o de los posibles incidentes de seguridad y privacidad de la información sobre los activos de información, a través de una oportuna identificación, atención, tratamiento y respuestas con el fin de mitigar el impacto asociado a la pérdida de la confidencialidad, integridad y disponibilidad de la información de la **DIAN**.

C. Características del control:

- 1. Tipo de control: correctivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Oficina de Seguridad de la Información debe:
 - a. Definir los procedimientos, lineamientos o normatividad para evaluar los incidentes de seguridad de la información.
 - b. Coordinar los esfuerzos necesarios para dar atención a un incidente de seguridad y privacidad de la información dentro de la entidad, de igual manera, informar a los respectivos niveles administrativos de los incidentes y su grado de severidad dentro de la entidad, así como coordinar los esfuerzos con entidades externas (proveedores, ColCERT, Comando Conjunto Cibernético, Policía Nacional de Colombia, y la Superintendencia de Industria y Comercio) en caso de ser necesario.

- c. Evaluar, clasificar y responder, de manera eficiente y adecuada, los incidentes de seguridad y privacidad de la información.
 - d. Consolidar las lecciones aprendidas, las cuales se realizan en conjunto con las dependencias involucradas en el incidente de seguridad y privacidad de la información y que serán documentadas en la herramienta definida por la entidad para este fin.
 - e. Generar una base de datos de conocimiento de incidentes de seguridad y privacidad de la información.
 - f. Realizar el escalamiento de los incidentes de seguridad y privacidad de la información a las partes que corresponden, tanto internas como externas.
 - g. Mantener los contactos apropiados con los grupos de interés especial de seguridad y privacidad de la información. En el caso de que se presente un incidente de seguridad y privacidad de la información y, ser requerido solicitar asesoría externa a los grupos como el ColCERT, las mesas de infraestructuras críticas cibernética el CSIRT Gobierno, el Centro Cibernético Policial o a los foros de seguridad especializados y asociaciones profesionales.
 - h. Incluir en la clasificación de incidentes de seguridad y privacidad de la información, como mínimo: clasificación, prioridad, manera de contención, manera de recuperación, forma de erradicación, tiempos de respuesta (de acuerdo con el nivel de criticidad o impacto). Estas actividades se realizan para dar cumplimiento al ciclo de vida de la gestión y respuesta a un incidente de seguridad, de acuerdo con la Guía para la gestión y clasificación de incidentes de seguridad de la información (MINTIC).
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Coordinar los esfuerzos necesarios para dar atención a un incidente de seguridad o privacidad de información dentro de la entidad.
 - b. Gestionar los eventos de seguridad para detectar y tratarlos con eficiencia. Una vez identificados, clasificar o no como incidentes de seguridad y privacidad de la información.
 - c. Informar a los niveles administrativos los incidentes y su grado de severidad dentro de la entidad.
 - d. Recolectar la evidencia digital asociada con el incidente de seguridad o privacidad de la información.
3. Los funcionarios y terceros de la entidad deben:
 - a. Reportar los incidentes por los medios autorizados, teniendo en cuenta los procedimientos vigentes, y cualquier situación anormal que pueda llegar a convertirse en un incidente de seguridad y privacidad de la información, en donde se identifica su categoría y se direcciona a la Dirección de Gestión de Innovación y Tecnología y/o a la Oficina de Seguridad de la Información para su tratamiento y respuesta.

E. Controles relacionados:

1. 5.5. – Contacto con las autoridades
2. 5.6. – Contacto con grupos de interés especial
3. 5.25. – Evaluación y decisión sobre eventos de seguridad de la información
4. 5.26. – Respuesta a incidentes de seguridad de la información
5. 5.28. – Recopilación de pruebas
6. 6.8. – Reporte de eventos de seguridad de la información
7. 8.15. – Registro
8. 8.16. – Actividades de seguimiento

5.25 Evaluación y decisión sobre eventos de seguridad de la información

A. Objetivo de control: evaluar los eventos de seguridad presentados en la entidad, valorarlos y decidir si se clasifica como incidente de seguridad y privacidad de la información.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y la Dirección de Gestión de Innovación y Tecnología, encargadas de establecer un esquema de categorización y priorización de incidentes de seguridad y privacidad de la información para la gestión y respuesta.

C. Características del control:

1. Tipo de control: detectivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Evaluar, en conjunto con la Dirección de Gestión de Innovación y Tecnología, los eventos de seguridad para identificar si es necesario o no clasificarlos como incidentes de seguridad y privacidad de la información.
 - b. Evaluar y clasificar los incidentes de seguridad de la información y privacidad de la información que se presenten sobre los activos de información de la **DIAN**.
 - c. Crear un grupo de monitoreo especializado en incidentes encargado de monitorear, clasificar, informar y gestionar a las dependencias o grupos correspondientes los incidentes de seguridad y privacidad de la información.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Adoptar los procedimientos, lineamientos o normatividad para la gestión de incidentes de seguridad y privacidad de la información.
 - b. Clasificar el tipo de evento/incidente de acuerdo con los documentos, lineamientos o procedimientos establecidos por la entidad.
 - c. Gestionar y responder a los eventos clasificados como incidente de seguridad y privacidad de la información, teniendo en cuenta los lineamientos o procedimientos definidos.
 - d. Analizar, validar y documentar cada incidente de seguridad y privacidad de la información desde su identificación hasta la finalización de su tratamiento.
 - e. Incorporar las lecciones aprendidas de la base de datos de conocimiento de incidentes de seguridad y privacidad de la información.

E. Controles relacionados: No aplica.

1. 6.8 - Reporte de eventos de seguridad de la información.

5.26 Respuesta a incidentes de seguridad de la información

A. Objetivo de control: verificar que se den respuesta de manera eficiente y eficaz a los incidentes de seguridad y privacidad de la información que se presenten en la entidad.

B. Alcance: el alcance de este lineamiento aplica para todos los funcionarios y terceros que deban dar respuesta a los incidentes de seguridad de la información que se presenten en la entidad, mediante el uso las herramientas y formatos definidos en los procedimientos vigentes.

C. Características del control:

1. Tipo de control: correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Generar respuesta a los incidentes de seguridad y privacidad de la información e incluir como mínimo la siguiente información:
 - Tipo de incidente.
 - Activo de información afectado.
 - Criticidad del incidente.
 - Descripción de las debilidades de seguridad de la información que se encontraron, causaron o contribuyeron al incidente.
 - Personas responsables en el tratamiento y respuesta del incidente.
 - Las actividades de tratamiento y respuesta involucradas en la gestión del incidente.
 - Duración de la solución del incidente.
 - Estado del incidente (Abierto: Sin dar una respuesta definitiva al incidente - Cerrado: Incidente tratado y manejado adecuadamente).
 - b. Documentar un registro de las respuestas en la base de datos de conocimiento de incidentes de seguridad y privacidad de la información.
 - c. Informar sobre el incidente de seguridad de la información a entes de control o autoridades competentes, teniendo en cuenta los procedimientos vigentes.
 - d. Definir lineamientos respecto a respuesta de los incidentes para:
 - La contención del incidente.
 - Recopilación de evidencia.
 - Comunicación a las partes interesadas internas y externas.
 - Coordinar con partes internas y externas para mejorar la eficacia de la respuesta.
 - Analizar la causa raíz del incidente.
 - Identificar y gestionar las vulnerabilidades y debilidades en los controles relacionados con la causa del incidente de seguridad y privacidad de la información.
 - Establecer responsabilidades como el primer respondiente, vocero oficial dentro de la gestión de incidentes de seguridad o privacidad de la información.
 - e. Informar o notificar a los propietarios de los activos de información afectados sobre el incidente de seguridad y privacidad de la información, así como de las medidas adoptadas para la remediación y/o solución del incidente.

E. Controles relacionados:

1. 5.24. – Planificación y preparación de la gestión de incidentes de seguridad de la información
2. 5.27. – Aprendiendo de los incidentes de seguridad de la información

3. 5.28. – Recopilación de pruebas
4. 5.29. – Seguridad de la información durante la interrupción
5. 5.30. – Preparación de las TIC para la continuidad del negocio

5.27 Aprendiendo de los incidentes de seguridad de la información

A. Objetivo de control:

- B.** Garantizar la gestión sistemática del conocimiento derivado de los incidentes de seguridad y privacidad de la información, mediante la implementación de un repositorio centralizado de lecciones aprendidas, con mecanismos de clasificación, análisis de causas raíz y correlación de incidentes. Este repositorio debe integrarse con los planes de respuesta, continuidad de negocio y resiliencia organizacional, con el fin de prevenir recurrencias, reducir el impacto de futuras amenazas y mejorar los tiempos de detección y respuesta (MTTD/MTTR)

- C. Alcance:** El lineamiento aplica a la Oficina de Seguridad de la Información (OSI) y a todas las áreas que administren activos críticos de información.:

D. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

E. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Documentar, clasificar y actualizar la base de conocimiento sobre incidentes de seguridad y privacidad.
 - b. Validar que la información recopilada sea utilizada para el fortalecimiento de controles técnicos, administrativos y físicos en línea con la Política Nacional de Seguridad Digital.
 - c. Asegurar la interoperabilidad de la base de lecciones aprendidas con sistemas de gestión de continuidad del negocio (ISO 22301) y con el SGSPI (ISO/IEC 27001).
 - d. Coordinar la difusión de las lecciones aprendidas a través de boletines internos de ciberseguridad y entrenamientos obligatorios, fomentando la cultura de seguridad digital en toda la entidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Implementar mecanismos que permitan cuantificar y hacer el seguimiento de todos los tipos, los volúmenes y los costos de los incidentes de seguridad y privacidad de la información que afecten la infraestructura tecnológica de la **DIAN**.
 - b. Documentar la base de datos de conocimiento para identificar las amenazas, las vulnerabilidades y las oportunidades de mejora de los incidentes de seguridad y privacidad de la información que se presenten en la infraestructura tecnológica de la entidad.

F. Controles relacionados:

1. 5.24. – Planificación y preparación de la gestión de incidentes de seguridad de la información.
2. 6.3. – Concientización, educación y capacitación en seguridad de la información.

5.28 Recopilación de evidencias digitales

A. Objetivo de control: asegurar que la recopilación de evidencias digitales ante incidentes de seguridad de la información se realice de forma controlada, legalmente válida y forensemente aceptable, con el fin de preservar su integridad, autenticidad, trazabilidad y utilidad en investigaciones internas o legales

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información encargada de definir y aplicar procedimientos para la identificación, la recopilación, la adquisición y la preservación de la evidencia digital relacionada con eventos o incidentes de seguridad y privacidad de la información.

C. Características del control:

1. Tipo de control: correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

La Oficina de seguridad de la Información debe adelantar las siguientes actividades por cada frente:

- a. Diseñar, implementar y mantener políticas y procedimientos normalizados para la recolección, análisis, procesamiento, preservación y custodia de evidencias digitales.
- b. Asegurar la alineación con:
 - i. **ISO/IEC 27037** (identificación, recolección, adquisición y preservación de evidencia digital).
 - ii. **ISO/IEC 27041 y 27042** (revisión y análisis de evidencia digital).
 - iii. **ISO/IEC 27043** (principios de investigación de incidentes).
 - iv. **NIST SP 800-86** (guide to integrating forensic techniques).
 - v. **Ley 906 de 2004** (cadena de custodia en Colombia).
- c. Asegurar que los procedimientos de recolección de evidencias digitales estén integrados con el **Sistema de Gestión de Seguridad de la Información (SGSPI)** y con el **Sistema de Gestión de Incidentes (ISO/IEC 27035)**.
- d. Incorporar el registro de evidencias dentro de la gestión de riesgos y de la trazabilidad de incidentes.
- e. Garantizar que el personal asignado cuente con formación en **informática forense, cadena de custodia y análisis de evidencias digitales**, preferiblemente con certificaciones internacionales (ej. **CHFI, GCFA, CCE, EnCE**).

- f. Realizar entrenamientos periódicos y simulacros de levantamiento de evidencia digital.
- g. Velar porque toda recolección de evidencia digital se realice de manera que no se altere la fuente original.
- h. Exigir la generación de **hash criptográficos (SHA-256 o superiores)** antes y después de la adquisición, para garantizar la integridad de los datos.
- i. Documentar exhaustivamente la **cadena de custodia** desde la identificación hasta la disposición final.
- j. Autorizar y mantener actualizado un catálogo de **herramientas forenses aprobadas** (ej. EnCase, FTK, Autopsy, X-Ways, Cellebrite).
- k. Disponer de los elementos necesarios para la recolección segura de evidencias:
 - i. Dispositivos de adquisición forense (write-blockers, duplicadores forenses).
 - ii. Dispositivos de respaldo seguros (backs cifrados).
 - iii. Elementos de protección física y electromagnética (jaulas de Faraday, bolsas antiestáticas).
 - iv. Medios estériles y certificados (HDD, SSD, USB forenses).
 - v. Insumos de embalaje (bolsas de evidencia, etiquetas con códigos únicos, precintos de seguridad inviolables).

Hacer seguimiento al cumplimiento de las políticas de seguridad de la información establecidas en la entidad al **laboratorio forense digital** teniendo especial rigurosidad en lo relacionado con condiciones controladas de seguridad física y ambiental.

- l. Documentar en la base de conocimiento:
 - i. Los incidentes que requirieron recolección de evidencia digital.
 - ii. Los métodos y herramientas utilizadas.
 - iii. Los responsables en cada fase de la cadena de custodia.
 - iv. Las lecciones aprendidas y mejoras requeridas.

E. Controles relacionados: No aplica.

5.29 Seguridad de la información durante la interrupción

A. Objetivo de control: incluir en el plan de continuidad del negocio y el plan de recuperación ante desastres criterios de seguridad de la información.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información, la Dirección de Gestión de Innovación y Tecnología, la Subdirección de Procesos y la Subdirección de Infraestructura Tecnológica y de Operaciones. Estas son las áreas encargadas de establecer, documentar, implementar y mantener los procesos, procedimientos y controles para cumplir el nivel de seguridad de la información durante una situación adversa.

C. Características del control:

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Validar los requisitos de seguridad y privacidad en los minutogramas de pruebas.
 - b. Validar que los escenarios de riesgo definidos en el DRP estén enmarcados en las buenas prácticas recomendadas por MinTic
 - c. Identificar, junto con la Subdirección de Procesos, los riesgos de seguridad y privacidad sobre la disponibilidad de los activos críticos de información relacionados con la continuidad del negocio. Para esto deben tener en cuenta los activos de información considerados como críticos para la entidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - d. Minimizar el impacto que se pueda derivar de cualquier situación de emergencia sobre los servicios de TI o el nivel de prestación de estos.
 - e. Definir los escenarios de riesgos, basados en las buenas prácticas recomendadas por MinTic.
 - f. Implementar el plan de recuperación ante desastres de acuerdo con los escenarios definidos, teniendo en cuenta lo establecido en el BIA
 - g. Elaborar un plan de mitigación o tratamiento para atender los hallazgos identificados en las pruebas, revisiones y/o monitoreos, asignando responsables y rango de fechas de ejecución.
 - h. Establecer la capacidad de respuesta de DGIT frente a los RTO y RPO definidos por las áreas de negocio en el Análisis de Impacto de Negocio BIA,
 - i. Desarrollar las estrategias de continuidad en las aplicaciones y sistemas de información (según el nivel de criticidad) que apoyan los procesos/procedimientos de la operación.
 - j. Mantener actualizada la documentación del plan de recuperación ante desastres.
 - k. Elaborar y ejecutar un plan de capacitación y sensibilización relacionado con la implementación plan de recuperación ante desastres y hacer seguimiento a dicho plan.
 - l. Incluir en los planes de recuperación ante desastres controles de seguridad existentes durante la interrupción. En caso de no poderlos tener, establecer controles de compensación.
 - m. Establecer las acciones para la activación del plan de recuperación ante desastres, alineado al protocolo de manejo de crisis - OD-PEC-0004
3. La Subdirección de Procesos debe:

- a. Mantener actualizado el plan de continuidad del negocio. Para ello se realizan revisiones periódicas y cuando se produzca un cambio significativo que pueda afectar al mismo.
- b. Alinear las estrategias de continuidad del negocio con el plan de recuperación ante desastres, definido por la Dirección de Gestión de Innovación y Tecnología.
- c. Revisar por lo menos una vez al año, la alineación del plan de continuidad del negocio con el BIA actualizado.
- d. Definir en conjunto con las direcciones de gestión de la **DIAN** por cada dependencia o sistema de información el tiempo RTO (*Tiempo Objetivo de Recuperación*), valor que establece el límite superior para la recuperación de los servicios de cada una de las aplicaciones que fueron identificadas en el punto anterior y el RPO (*Punto Objetivo de Recuperación*) *Tiempo máximo transcurrido entre la última copia de seguridad de datos y el momento en que se produce el fallo, preferiblemente a través del Business Impact Analysis*)
- e. .
- f. Elaborar y ejecutar un plan de capacitación y sensibilización relacionado con la implementación plan de continuidad del negocio y hacer seguimiento.
- g. Identificar junto con la Dirección de Gestión de Innovación y Tecnología los riesgos sobre la disponibilidad de los activos críticos de información de TI que apoyan las operaciones.
- h. Validar y actualizar, en conjunto con las direcciones de gestión de la **DIAN**, el nivel de criticidad del proceso, procedimiento o sistema de información y el tiempo de RTO, por lo menos una vez al año, esto preferiblemente a través Análisis de Impacto del Negocio (BIA por sus siglas en inglés).
- i. Definir metodología para el plan de continuidad del negocio teniendo en cuenta: los tipos de interrupción, la metodología para Análisis de Impacto del Negocio e incluir como mínimo: las personas, los procesos, la infraestructura física y la tecnológica.
- j. Realizar al menos una vez al año pruebas del plan continuidad del negocio y su alineación con el plan de recuperación ante desastres.
- k. Supervisar el cumplimiento de los protocolos para la activación del plan de continuidad del negocio, incluidos en los documentos “Protocolo de Manejo de Incidentes e Identificación de Crisis” y “Protocolo de manejo de crisis” de la entidad.
- l. Definir controles compensatorios en caso de que, en una situación de crisis, algún control no se pueda implementar.
- m. Asegurar que las áreas operativas tengan actualizados los planes de operación alternos, en el evento de la pérdida de los servicios de TI por encima de los RTO (*Tiempo Objetivo de Recuperación*) y RPO (*Punto Objetivo de Recuperación*).

E. Controles relacionados:

1. 5.30. – Preparación de las TIC para la continuidad del negocio

5.30 Preparación de las TIC para la continuidad del negocio

- A. Objetivo de control:** planificar, implementar, mantener y probar la preparación de las TIC en función de los objetivos de continuidad del negocio y los requisitos de continuidad de las TIC.
- B. Alcance:** el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología, encargada de mantener la disponibilidad de la información en la **DIAN** y otros activos asociados durante la interrupción.

C. Características del control:

1. Tipo de control: correctivo
2. Propiedades de seguridad: disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Apoyar a las áreas responsables en la elaboración del plan de pruebas anual.
 - b. Verificar que el plan de recuperación ante desastres se desarrolle y se implemente de forma adecuada, teniendo en cuenta la criticidad de los servicios, procesos y procedimientos.
 - c. Asegurar la autonomía de realizar revisiones y/o monitoreos a la metodología, estrategias, planes, procedimientos implementados y/o relacionados con continuidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Identificar y establecer estrategias de continuidad de las TIC en las cuales se deben considerar opciones antes, durante y después de una posible interrupción o falla.
 - b. Definir y documentar el plan de recuperación ante desastres.
 - c. Incluir en los planes de continuidad TIC especificaciones de rendimiento y capacidad para cumplir con los requisitos y objetivos de continuidad de la entidad.
 - d. Contar con el BIA (análisis de impacto del negocio) que incluya el RTO (Recovery Time Objective – Tiempo objetivo de recuperación) de cada servicio TIC priorizado y los procedimientos para restaurar esos componentes; así mismo el RPO (Recovery Point Objective – Punto objetivo de recuperación) de los recursos TIC priorizados definidos como información y los procedimientos para restaurar la información.
 - e. Establecer un plan de pruebas anual de las estrategias de recuperación de desastres definidos por la entidad.
 - f. Capacitar a los involucrados en las estrategias de recuperación de desastres definidos por la entidad.
 - g. Tomar las lecciones aprendidas de las pruebas de las estrategias de recuperación ante desastres definidos por la entidad e incluirlas en las futuras actualizaciones de los planes.
 - h. Actualizar las estrategias de recuperación de desastres definidas por la entidad teniendo en cuenta los resultados de las pruebas realizadas y cambios que hayan surgido desde la última actualización del plan.
 - i. Definir los objetivos, alcance y límites del plan de recuperación ante desastres.
 - j. Desarrollar, entregar y actualizar los entregables del plan de recuperación ante desastres según la definición de la Guía para la preparación de las TIC en la continuidad del negocio del Modelo de Seguridad y Privacidad de la Información formulado por el MINTIC, con respecto a:
 - Planificación para la preparación de las TIC para la continuidad de negocio.
 - Implementación para la preparación de las TIC para la continuidad de negocio.
 - Evaluación de desempeño para la preparación de las TIC para la continuidad de negocio.
 - Mejora continua para la preparación de las TIC para la continuidad de negocio.
 - k. Cumplir con los objetivos de las siguientes prácticas profesionales de resiliencia definidas por el *Instituto Internacional de Recuperación de Desastres* (DRII, por sus siglas en inglés):

- Evaluación de riesgos
 - Análisis de impacto al negocio
 - Estrategias de continuidad de negocio
 - Respuesta a incidentes
 - Desarrollo e Implementación del plan
 - Programas de concientización y entrenamiento
 - Ejercicio, evaluación y mantenimiento del plan de continuidad del negocio
 - Comunicación de crisis
 - Coordinación con dependencias externas
 - l. Mantener actualizada la documentación del plan de recuperación ante desastres.
 - m. Elaborar y ejecutar un plan de capacitación y sensibilización relacionado con la implementación plan de recuperación ante desastres y hacerle seguimiento.
 - n. Definir las necesidades del plan de recuperación de desastres en los proyectos con soluciones de nuevas tecnológicas.
 - o. Incluir al comité en gestión de cambios en los procesos relacionados con el plan de recuperación de desastres.
3. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
- a. Probar de forma periódica el plan de recuperación ante desastres, para validar su adecuación a las necesidades de la entidad.
 - b. Buscar que los centros de datos cumplan con los lineamientos definidos por la guía TIA-942 estándar - Diseño y Cableado de un Centro de Datos.
 - c. Contar con la infraestructura requerida para el plan de recuperación ante desastres, teniendo en cuenta un centro de datos alternativo, sin importar las estrategias de continuidad definidas.
 - d. Asignar, mantener y actualizar la infraestructura técnica (equipos, licencias, software, comunicaciones, centros de datos, entre otros) para la puesta en marcha de las estrategias definidas.
4. La Subdirección de Procesos debe:
- a. Coordinar con DGIT la integración y alineación del plan de continuidad del negocio y el plan de recuperación de desastres.

E. Controles relacionados:

1. 5.29. – Seguridad de la información durante la interrupción.

5.31 Requisitos legales, estatutarios, reglamentarios y contractuales

- A. Objetivo de control:** identificar la legislación y los registros contractuales en materia de seguridad y privacidad de la información, vigilar su cumplimiento y actualización de manera permanente.
- B. Alcance:** el alcance de este lineamiento aplica para Dirección de Gestión Jurídica y para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que deben proteger

la información de la **DIAN** evitando cualquier alteración, fuga o pérdida, preservando la confidencialidad, integridad y disponibilidad de esta.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión Jurídica debe:
 - a. Mantener actualizado un catálogo normativo o normograma donde se identifiquen, documenten y actualicen todos los requerimientos de la legislación y la regulación nacional e internacional, con el fin de salvaguardar la información que se genere, obtenga, adquiera, transforme, controle, transfiera o se intercambie en la entidad.
 - b. Dar cumplimiento de las leyes y normas reglamentarias y regulatorias establecidas, así como la normatividad interna en relación con seguridad y privacidad de la información.
 - c. Definir la frecuencia de revisión, validación y pertinencia de los requisitos legales.
 - d. Revisar periódicamente la legislación y los reglamentos identificados para mantener al día los cambios e identificar nueva legislación.
 - e. Realizar la actualización del catálogo normativo de la entidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Documentar y actualizar todos los requerimientos estatutarios, regulatorios y contractuales para cada sistema de información, una vez al año y/o cada vez que estos sean requeridos.
3. Los funcionarios y terceros de la entidad deben:
 - a. Cumplir con las obligaciones legales, estatutarias, reglamentarias o contractuales relacionadas con seguridad y privacidad de la información.

E. Controles relacionados:

1. 5.20. – Abordar la seguridad de la información en los acuerdos con proveedores.

5.32 Derechos de propiedad intelectual

- A. Objetivo de control:** implementar procedimientos apropiados para el cumplimiento de los requisitos legislativos, reglamentarios y contractuales relacionados con los derechos de propiedad intelectual y el uso de software patentado.
- B. Alcance:** el alcance de esta política aplica para la Dirección de Gestión de Innovación y Tecnología, quien hace la adquisición de software en la **DIAN** y todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) de la entidad que deben implementar y cumplir

con los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con los derechos de propiedad intelectual.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Fortalecer la cultura en los usuarios internos de la **DIAN** sobre los derechos de propiedad intelectual.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Definir controles con el objetivo de proteger adecuadamente la propiedad intelectual de la **DIAN**, tanto propia como la de terceros según aplique para los derechos de autor de software, licencias y código fuente.
 - b. Validar que se use software autorizado por la entidad independiente si este es propietario, de licencia comercial o de software libre.
 - c. Verificar que todo el software utilizado por la entidad, para trabajar o desarrollar esté licenciado y sea usado únicamente bajo los términos y condiciones definidos en las licencias.
 - d. Verificar que no se exceda el número máximo de usuarios permitidos por las licencias o las capacidades, para tal efecto se deben realizar monitoreos periódicos de la utilización de software que se encuentren en el inventario.
 - e. Reportar a la Oficina de Seguridad de la Información los eventos o incidentes relacionados con la violación de los derechos de propiedad intelectual.
 - f. Mantener las evidencias de la propiedad de las licencias de software adquirido.
 - g. Contar con un listado de licenciamiento de la entidad.
 - h. Cumplir con los términos y condiciones del software libre.
 - i. Registrar ante la entidad competente el software desarrollado por la entidad.
3. Los funcionarios y terceros deben:
 - a. Utilizar software legalmente adquirido y/o autorizado por la entidad.
 - b. Cumplir con las políticas y lineamientos definidos para la utilización de software licenciado en los equipos de la entidad.
 - c. Referenciar la fuente de donde se extrajo la información para presentaciones, documentos, informes y demás documentos que utilicen los usuarios internos para funciones de su cargo.
 - d. Cumplir con la legislación de derechos de propiedad intelectual.
 - e. Evitar realizar descargas o almacenar o ejecutar en los equipos de la **DIAN** archivos de música, fotos, videos, software o material sujeto a propiedad intelectual.
 - f. Cumplir con la legislación vigente y/o requisitos legales aplicables a los derechos de propiedad intelectual, la protección de registros, la privacidad y la protección de datos personales y la reglamentación de controles criptográficos.

- g. Cumplir con las leyes de derechos de autor y los acuerdos de licenciamiento, no duplicar y/o distribuir ningún software o su documentación sin permiso del propietario de los derechos de autor.
- h. No copiar, total o parcialmente, estándares (por ejemplo: estándares internacionales ISO/IEC), libros, artículos, informes u otros documentos, salvo lo permitido por la ley de derechos de autor o las licencias aplicables.

E. Controles relacionados: No aplica.

5.33 Protección de registros

A. Objetivo de control: proteger los registros contra pérdida, destrucción, falsificación, acceso no autorizado y liberación no autorizada, de acuerdo con los requisitos legislativos, reglamentarios y contractuales.

B. Alcance: el alcance de esta política aplica para todos los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) de la entidad, con el fin cumplir los requisitos legales, estatutarios, reglamentarios y contractuales en la protección de registros.

C. Características del control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Establecer los lineamientos, procedimientos y/o instructivos para la protección de los registros en bases de datos, registros de transacciones (Logs) y registros de auditoría (Audit Logs).
 - b. Contar con sistemas de almacenamiento y manejo de datos, teniendo en cuenta como mínimo lo siguiente:
 - Permitir el acceso a los datos (legibilidad de los medios y de formatos) durante todo el período de retención, para proteger la información contra pérdida debido a cambios futuros de la tecnología.
 - Permitir recuperar los datos requeridos en un tiempo y formato aceptables, dependiendo de los requisitos que se deban cumplir.
 - Identificar los registros y su período de retención.
 - Permitir la destrucción apropiada de registros, luego del período de retención, si la entidad ya no los requiere.
 - c. Elaborar un programa de retención que identifique los registros electrónicos y el período de tiempo durante el cual se deberían retener los registros.
 - d. Definir un inventario de fuentes de información de acuerdo con la identificación y clasificación de activos de información.
 - e. Documentar lineamientos, procedimientos o instructivos, en conformidad con el Programa de Gestión Documental de la **DIAN**, sobre la retención, el almacenamiento y el manejo de registros e información electrónicos para cumplir con requisitos

estatutarios, reglamentarios y contractuales o para el soporte de las actividades misionales de la entidad.

- f. Establecer procedimientos y/o instructivos para conservar en un lugar seguro con acceso restringido al personal autorizado y con protección de acceso, los registros de eventos provenientes del hardware y el *software* de la infraestructura de seguridad de la **DIAN**.
- g. Reportar a la Oficina de Seguridad de la Información los eventos o incidentes relacionados con la pérdida, destrucción, falsificación, acceso no autorizado y liberación no autorizada de registros de la **DIAN**.
- h. Aplicar medidas de amonificación o enmascaramiento antes de transferir registros con terceros para depuración o solución de errores, cuando estos contengan datos personales.
- i. Realizar copia de los logs de los sistemas operativos y aplicaciones en un medio diferente si el almacenamiento se llena, antes de ser eliminados de los servidores.
- j. Definir, aprobar y socializar los procedimientos para proteger la información de registro (logs) de accesos o cambios no autorizados, de acuerdo con los siguientes parámetros:
 - a) Gestionar solo por los responsables (administradores y operadores) los logs a través de los roles y responsabilidades definidos.
 - b) Configurar accesos limitados (de solo lectura) a los logs para los procesos de auditoría.
 - c) Definir cuánto tiempo se conservan los logs de cada una de las aplicaciones, conforme a las TRD. En caso de no tener una clasificación se debe conservar como mínimo un año de los logs.
 - d) Detallar pruebas de aseguramiento para la recuperación de logs, del medio en el cual este almacenada.

2. Los funcionarios y terceros deben:

- a. Cumplir con los lineamientos establecidos en el Programa de Gestión Documental de la **DIAN** y desarrollados en el instructivo IN-ADF-0132 - Manejo de los archivos en la UAE-DIAN.

E. Controles relacionados:

- 1. 8.24. – Uso de criptografía

5.34 Privacidad y protección de los datos personales

- A. Objetivo de control:** Mantener la protección y privacidad de los datos personales tal como lo estipula la legislación colombiana, las regulaciones y, si fuese aplicable, las cláusulas contractuales.
- B. Alcance:** el alcance de esta política aplica para para todas las dependencias, funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que deban cumplir los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con los aspectos de seguridad de la información y de la protección de los datos personales a cargo.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad, disponibilidad y privacidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Dar cumplimiento a los lineamientos y funciones establecidas en la Resolución vigente “por la cual se asignan las funciones de Oficial de protección de datos personales a la Oficina de Seguridad de la Información”, o la que la modifique con posterioridad.
 - b. Estructurar, diseñar y administrar el Programa Integral de Gestión de Datos Personales (PIGDP).
 - c. Actualizar y verificar el cumplimiento de lo establecido en el Manual de protección de datos personales MN-IIT062 y la demás documentación relacionada.
 - d. Definir los lineamientos para la incorporación de instrumentos como compromisos de confidencialidad, que impidan que los datos personales circulen sin la autorización del titular o se hagan públicos por inadecuado tratamiento.
 - e. Gestionar el Registro Nacional de Bases de Datos (RNBD) dispuesto por la SIC.
 - f. Gestionar los incidentes de seguridad de la información que afecten los datos personales.
2. Los jefes de dependencias deben:
 - a. Dar cumplimiento a la Resolución 101 del 2020 “Por la cual se asignan las funciones de Oficial de protección de datos personales a la Oficina de Seguridad de la Información y se fijan obligaciones de las dependencias frente a la protección de los datos personales en la Unidad Administrativa Especial – Dirección de Impuestos y Aduanas Nacionales – **DIAN**”, o la que la modifique con posterioridad.
 - b. Identificar y gestionar los riesgos de seguridad de la información de los activos de información que contengan datos personales. Estos deben ser controlados para evitar la adulteración, pérdida, consulta, uso o acceso no autorizado o fraudulento de la información que contiene datos personales.
 - c. Adoptar, de carácter obligatorio, todos los lineamientos de protección de datos personales para el diseño, la implementación y/o la generación de nuevos servicios de la entidad como canales de atención, nuevos procesos, adecuación, renovación o disposición de espacios físicos, nuevas formas físicas o digitales de interoperabilidad o circulación de la información tanto interna o externamente.
 - d. Identificar en sus activos de información lo siguiente:
 - Cuáles contienen datos personales.
 - En qué medios se encuentran (físicos o electrónicos).
 - Qué medidas de seguridad de la información aplican.
 - Si la recolección, tratamiento, circulación y disposición que se hace de esos activos se realiza conforme con la normatividad colombiana y las normas y políticas establecidas en la entidad.
 - Si se trata de bases de datos con datos personales, analizar y evaluar si debe ser registrada en el Registro Nacional de Bases de Datos (RNBD) dispuesto por la SIC y generar los reportes periódicos correspondientes.

- e. Responsabilizarse directamente del tratamiento de datos personales manejados por su dependencia, y/o dicho tratamiento delegado a un tercero; en cualquiera de los casos se debe cumplir con los lineamientos y procedimientos idóneos para la protección de los datos personales y la estricta confidencialidad de estos, de acuerdo con la normatividad vigente y lo establecido en este manual.
 - f. Realizar la recolección, el tratamiento, el almacenamiento y la disposición final de los datos, observando los principios de: legalidad, finalidad, libertad, veracidad, transparencia, acceso y circulación restringida, seguridad y confidencialidad.
 - g. Recibir las bases de datos personales que, con ocasión de un mandato legal o el cumplimiento de un tratado, acuerdo, convenio, contrato o un mecanismo jurídico de igual naturaleza, la **DIAN** reciba de otra entidad u organismo en cumplimiento de sus funciones.
3. Todas las dependencias, funcionarios y terceros deben:
- a. Cumplir la normatividad nacional vigente en materia de protección de datos personales. Proceder a la supresión de los datos personales en su posesión (cuando aplique), una vez cumplida las finalidades del tratamiento y sin perjuicio de normas legales que dispongan lo contrario. Esta supresión o disposición final de los datos personales se realiza de acuerdo con las políticas de gestión documental de la entidad.
 - b. Cumplir con la reglamentación y normatividad vigente de la **DIAN** en materia de protección de datos personales:
 - La circular externa No. 001 de 2019 “Política de Tratamiento de Datos Personales”.
 - El Manual para la Protección de Datos Personales MN-IIT-0062 y sus respectivos anexos.
 - La Circular 026 de 2020 “La cual se define los criterios para atender las solicitudes de acceso a la información pública en la entidad”.
 - c. Cumplir con el adecuado tratamiento y protección de los datos personales según la Resolución 101 de 2020. Organizar y depurar los sistemas de información, las bases de datos que contienen datos personales que ya no están en uso.
 - d. Controlar y aplicar medidas de seguridad, técnicas y administrativas, para mantener actualizados los datos personales.
 - e. Recolectar únicamente los datos personales necesarios para llevar a cabo las funciones de la entidad, con el objetivo de reducir o evitar el tratamiento de datos innecesarios.
 - f. Tramitar las consultas y reclamos de habeas data por parte de los titulares, en los tiempos establecidos por la Ley.
 - g. Informar los incidentes de seguridad de la información que afecten los datos personales, a la Oficina de Seguridad de la Información.

E. Controles relacionados: No aplica.

5.35 Revisión independiente de la seguridad de la información

- A. Objetivo de control:** revisar de forma independiente la gestión de la seguridad y privacidad de la información a intervalos planificados o cuando se produzcan cambios significativos.
- B. Alcance:** el alcance de este lineamiento aplica para la Oficina de Control Interno y/o terceros contratados para ejecutar la revisión a la entidad, en la gestión de la seguridad y privacidad de la información.
- C. Características del control:**

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Control Interno y/o quien haga sus veces debe:
 - Revisar el cumplimiento de la implementación del Modelo de Seguridad y Privacidad de la Información de manera independiente y a intervalos planificados (objetivos de control, políticas, procesos, procedimientos de la seguridad de la información), o cuando ocurran cambios significativos. Las revisiones se realizan a manera de auditoría por personal especializado y serán acordadas con cada dependencia.
 - Informar al jefe de cada dependencia sobre los resultados de las revisiones o auditorías y deben ser guardadas en un lugar específico de acceso propio para la dependencia y para la Oficina de Seguridad de la Información o quien haga sus veces.
 - Verificar las acciones correctivas propuestas por las dependencias para confirmar la eficiencia de estas.
 - Informar a la alta dirección del avance en la implementación del Modelo de Seguridad y Privacidad de la Información en la entidad.
 - Evaluar las oportunidades de mejora presentadas durante la revisión de la seguridad de la información.
 - Tener en cuenta la necesidad de cambios en el enfoque de la seguridad de la información.
2. Los jefes de las dependencias deben:
 - a. Formular un plan de acción para corregir las deficiencias o falencias encontradas en las revisiones o auditorías. Así mismo, dicho plan y sus avances deben ser reportados en la herramienta o carpeta definida por la Oficina de Seguridad de la Información.

E. Controles relacionados:

1. 5.1. – Políticas de seguridad de la información.

5.36 Cumplimiento de políticas, normas y estándares de seguridad de la información

- A. Objetivo de control:** revisar el cumplimiento de todos los lineamientos, las políticas, lo procedimientos y las normas establecidas en materia de seguridad y privacidad de la información, con el fin de preservar los principios de privacidad, disponibilidad y confidencialidad.
- B. Alcance:** el alcance de este lineamiento aplica para los funcionarios y terceros de la **DIAN** (servidores públicos, funcionarios vinculados a la planta permanente y provisional, contratistas, consultores, aprendices, pasantes, practicantes, judicantes, proveedores de bienes, entidades del estado, entes de control) que deben aportar porque la seguridad de la información se implemente y opere de acuerdo con la política de seguridad de la información de la **DIAN**, las políticas, las reglas y los estándares específicos del tema.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - Evaluar el cumplimiento de la política de seguridad de la información y las acciones de mejora correspondientes, y llevar un registro de estas.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - Realizar análisis periódicos de seguridad en los sistemas de información con ayuda de herramientas automatizadas y generar informes técnicos de la verificación del cumplimiento con los estándares de implementación de la seguridad de la información.
 - Realizar revisiones técnicas de los procedimientos de análisis, diseño, desarrollo y mantenimiento de las aplicaciones; se deben realizar revisiones técnicas y, en caso de incumplimiento de algún control o lineamiento, se deben determinar las causas de este e implementar acciones de mejora.
3. Los jefes de las dependencias deben:
 - a. Establecer los mecanismos de cumplimiento de todos los requisitos de seguridad de la información definidos en las políticas, las normas y los lineamientos aplicables en sus sistemas de información y en la información manejada.
 - b. Cumplir con las normas de seguridad y privacidad de la información establecidas en este manual.
 - c. Identificar las causas de incumplimiento de las políticas y normas de seguridad e implementar las acciones de mejora apropiadas para dar cumplimiento a estas.

E. Controles relacionados:

1. 5.35. – Revisión independiente de la seguridad de la información
2. 8.15. – Inicio de sesión
3. 8.16. – Actividades de seguimiento
4. 8.17. – Sincronización de reloj

5.37 Procedimientos operativos documentados

- A. Objetivo de control:** documentar y disponer para el personal que lo necesite los procedimientos de operación para las instalaciones de procesamiento de información de la entidad.
- B. Alcance:** el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología, encargada del funcionamiento correcto y seguro de las instalaciones de procesamiento de información.

C. Características del control:

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Procesos debe:
 - Establecer las condiciones para la creación, la actualización y la eliminación de la documentación institucional relacionada con las operaciones en instalaciones de procesamiento de información de la DIAN, para garantizar su funcionamiento correcto y seguro.
 - Promover en las dependencias la verificación, preparación y actualización de procedimientos documentados para actividades operativas de la DIAN asociadas con seguridad de la información.
2. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Documentar y actualizar los procedimientos, instructivos y guías relacionados con la operación y administración de la plataforma tecnológica de la **DIAN**.
Proporcionar a los funcionarios y terceros, de acuerdo con su rol o funciones: los manuales de proveedor, guía(s) de uso, ficha(s) técnica(s), e instructivos operativos de los servicios tecnológicos y sistemas de información que conforman la plataforma tecnológica de la **DIAN**.
Documentar los procedimientos de, instalación y configuración segura de sistemas, administración y operación de los sistemas de información, el procesamiento y manejo de la información.
Documentar los procedimientos de gestión de respaldo de la información, incluidas las pruebas de resiliencia y la verificación de copias de seguridad.
 - b. Documentar, en conjunto con la Oficina de Seguridad de la Información, el manejo de errores y condiciones excepcionales que pueden definirse como incidentes de ciberseguridad, incidentes de seguridad informática y los incidentes de seguridad y privacidad de la información.
Documentar en conjunto con la Oficina de Seguridad de la Información las instrucciones especiales de manejo de medios para información confidencial, incluida la eliminación segura, el apagado, reinicio o la recuperación del sistema, para su uso en caso de falla.
 - c. Documentar los procedimientos con los requisitos de programación e interacción con otros sistemas y tener un registro de los cambios realizados en cada uno.
 - d. Contar con la documentación de monitoreo de red y monitoreo de los activos de información.
3. Los jefes de las dependencias deben:
 - a. Documentar y actualizar los procedimientos donde se relacionen aquellas actividades que puedan afectar el procesamiento de la información de la entidad, así como los procedimientos donde se relacionen las actividades para la protección de la confidencialidad, la integridad y la disponibilidad de la información de la **DIAN**.
 - b. Especificar en la documentación y actualización de los procedimientos operativos: las personas responsables, las instrucciones para manejo de errores u otras condiciones excepcionales que puedan surgir durante la ejecución del trabajo, los contactos de

soporte y escalamiento, incluidos los externos en caso de dificultades operativas o técnicas inesperadas e instrucciones de mantenimiento.

E. Controles relacionados:

1. 7.4. – Supervisión de la seguridad física
2. 7.10 – Medios de almacenamiento
3. 7.14. – Eliminación segura o reutilización de equipos
4. 8.6. – Gestión de capacidad
5. 8.15. – Inicio de sesión
6. 8.16. – Actividades de seguimiento
7. 8.17. – Sincronización de reloj
8. 8.18. – Uso de programas de utilidad privilegiados

6. CONTROLES DE PERSONAS

A continuación, se describen los lineamientos y políticas que hacen referencia a las responsabilidades que establece la **DIAN** para los funcionarios y terceros en términos de seguridad y privacidad de la información:

6.1 Selección

A. Objetivo de control: verificar los antecedentes del talento humano de acuerdo con las leyes, los reglamentos, la ética y comprobar que cumpla con los requisitos de idoneidad, compromiso y responsabilidad inherentes al manejo de los activos de información a los que va a tener acceso y a los riesgos de seguridad y privacidad de la información.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión Corporativa y sus subdirecciones Gestión del Empleo Público y Compras y Contratos, que realizan vinculación de funcionarios y/o terceros en la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión Corporativa debe:
 - a. Establecer los mecanismos o controles en sus procesos de selección del personal tanto funcionarios, contratistas, aprendices, pasantes, practicantes y judicantes para verificar los antecedentes.
 - b. Incluir en las verificaciones de selección de personal tanto a funcionarios, contratistas, aprendices, pasantes, practicantes y judicantes, en lo relacionado con confirmación de los soportes académicos y experiencias profesionales.
 - c. Incluir en la selección de funcionarios, contratistas, aprendices, pasantes, practicantes y judicantes, la verificación de la identidad a través del documento de identidad y/o el pasaporte emitido por las autoridades competentes.

- d. Incluir, en caso de que un funcionario cambie de cargo dentro de la entidad, la verificación de antecedentes.
- b. La subdirección de Compras y Contratos debe:
- a. Disponer de una lista de verificación que contenga los aspectos necesarios para la revisión de los antecedentes del personal a contratar por prestación de servicios, de acuerdo con lo que dicta la ley y la reglamentación vigente.
 - b. Establecer los mecanismos o controles necesarios para proteger la confidencialidad y reserva de la información que le sea entregada por la DIAN. Ejecutar los procedimientos internos para la vinculación y retiro de contratistas, de conformidad con la normatividad vigente.
 - c. Incluir en los procedimientos y procesos contractuales la autorización para el tratamiento de los datos personales de acuerdo con la política de tratamiento de datos personales de la **DIAN** y conforme con lo establecido en la Ley 1581 de 2012 y sus decretos reglamentarios.
 - d. Almacenar en el expediente del contrato, los documentos de verificación y los soportes correspondientes.
 - e. Dar cumplimiento a los mecanismos o controles establecidos por la Dirección de Gestión Corporativa para proteger la confidencialidad y reserva de la información contenida en los expedientes contractuales.
2. La subdirección Gestión del Empleo Público debe:
- a. Incluir en los procedimientos de selección de personal, aprendices, pasantes, practicantes y judicantes, la autorización para el tratamiento de los datos personales de acuerdo con la política de tratamiento de datos personales de la DIAN y conforme con lo establecido en la Ley 1581 de 2012 y sus decretos reglamentarios.
 - b. Almacenar en la historia laboral de los funcionarios y/o expedientes de aprendices, pasantes, practicantes y judicantes, los documentos de verificación y los soportes correspondientes.
 - c. Dar cumplimiento a los mecanismos o controles establecidos por la Dirección de Gestión Corporativa para proteger la confidencialidad y reserva de la información contenida en las historias laborales y expedientes. Establecer los mecanismos o controles necesarios para proteger la confidencialidad y reserva de la información contenida en las historias laborales.
 - d. Ejecutar los procedimientos internos para la vinculación, ascenso, reubicación y retiro del talento humano de la entidad, de conformidad con la normatividad vigente.
 - e. Reportar a través de la mesa de servicio las novedades del personal para que, desde la Subdirección de Soluciones y Desarrollo, asigne o retire los usuarios en los sistemas de información y aplicativos, según sea necesario.
3. Los funcionarios de la entidad deben:
- a. Actualizar en el Registro Único de Personal –RUP (hoy Kactus), SIGEP y remitir el soporte cuando haya lugar a la Coordinación de Historias Laborales de acuerdo con los procedimientos internos, cuando exista novedades en su hoja de vida (datos personales, estudios, producción académica, familiares, entre otros).

E. Controles relacionados:

1. 5.1 – Políticas de seguridad de la información

6.2 Términos y condiciones de empleo

A. Objetivo de control: establecer acuerdos en la vinculación tanto de funcionarios como de contratistas que manejen activos de información dentro de la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión Corporativa y sus subdirecciones Gestión del Empleo Público y Compras y Contratos que realizan los términos y condiciones de la vinculación de funcionarios y/o terceros en la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión Corporativa debe:
 - a. Establecer los lineamientos para los términos y las condiciones de contrato de los terceros y vinculación de funcionarios.
 - b. Establecer las obligaciones contractuales sobre seguridad y privacidad de la información, las leyes de propiedad intelectual, protección de datos personales, transparencia y acceso a la información pública, y las acciones a tomar si no se cumplen estos términos.
 - c. Promover la divulgación términos y condiciones en materia de la seguridad y privacidad de la información tanto en funcionarios como en contratistas.
Definir para la firma, compromisos de confidencialidad de la información tanto en funcionarios, contratistas, aprendices, pasantes, practicantes y judicantes.
2. La subdirección de Compras y Contratos debe:

Definir los términos y condiciones para vinculación de terceros y personal a contratar por prestación de servicios, en los cuales se establezcan las obligaciones contractuales en materia de seguridad y privacidad de la información, las leyes de propiedad intelectual, de protección de datos personales, de transparencia y acceso a la información pública, así como las acciones a tomar si no se cumple con estos términos y condiciones.

- a. Dar a conocer a los candidatos los términos y condiciones del contrato y especificar las obligaciones en materia de la seguridad y privacidad de la información; aclarar que estas se extienden más allá de los límites de la **DIAN** y de ejecución del objeto contractual e informar las acciones a tomar si no se cumple con estos términos y condiciones.
Hacer firmar un documento de compromiso de confidencialidad de la información a los terceros y personal a contratar por prestación de servicios dicho documento debe reposar en el expediente del contrato.
- b. Incluir dentro de las obligaciones contractuales condiciones ante el incumplimiento de las políticas de seguridad de la información o ante acciones irregulares relacionadas con los activos de información de la **DIAN**.

3. La subdirección Gestión del Empleo Público debe:

- a. Incluir en las condiciones del empleo de los funcionarios, aprendices, pasantes, practicantes y judicantes a través de un acuerdo de confidencialidad donde se encuentren las obligaciones referentes a las políticas, lineamientos y directrices en materia de seguridad y privacidad de la información que dicte la **DIAN**.
- b. Definir los términos y condiciones del empleo de los funcionarios; y el alcance de las actividades a desarrollar por aprendices, pasantes, practicantes y judicantes. en los cuales se establezcan las obligaciones en materia de seguridad y privacidad de la información, las leyes de propiedad intelectual, de protección de datos personales, de transparencia y acceso a la información pública, así como las acciones a tomar si no se cumple con estos términos y condiciones.
- c. Dar a conocer a los aspirantes, los términos y condiciones del empleo, así como a los aprendices, pasantes, practicantes y judicantes el alcance de sus actividades y especificar las responsabilidades en materia de la seguridad y privacidad de la información. Se debe aclarar que estas responsabilidades se extienden más allá de los límites de la **DIAN** y del horario normal de trabajo y es necesario informar las acciones a tomar si no se cumple con estos términos y condiciones.
- d. Hacer firmar un documento de compromiso de confidencialidad de la información a los funcionarios, aprendices, pasantes, practicantes y judicantes; dicho documento debe reposar en el Registro Único de Personal –RUP, la historia laboral para el caso de los funcionarios y en el expediente para los demás.

4. La Subdirección de Asuntos Disciplinarios debe:

- a. Ejercer el control disciplinario y adelantar e instruir los procesos respecto a los funcionarios y ex funcionarios de la entidad que incumplan las políticas de seguridad de la información o cometan irregulares relacionadas con los activos de información de la **DIAN**.

E. Controles relacionados:

1. 5.9 - Inventario de información y otros activos asociados
2. 5.13 - Etiquetado de la información
3. 5.32 - Derechos de propiedad intelectual
 - 5.34 - Protección de datos personales (PII)
4. 6.5 - Responsabilidades después de la terminación o cambio de empleo
5. 6.6 - Acuerdos de confidencialidad o no divulgación

6.3 Concientización, educación y capacitación en seguridad de la información

- A. Objetivo de control:** promover conciencia, educación y capacitación en temas de seguridad y privacidad de la información, junto con las actualizaciones regulares de la política, procedimientos, instructivos y las buenas prácticas internacionales relacionadas con seguridad de la información.
- B. Alcance:** el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información, la Subdirección de la Escuela de Impuestos y Aduanas y Subdirección de Desarrollo del Talento Humano, que realizan actividades de conciencia, educación y capacitación en todos los funcionarios y terceros que tienen acceso a los activos de información de la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Establecer un programa de concientización, educación y capacitación en seguridad y privacidad de la información para el cumplimiento las responsabilidades de seguridad de la información en todos los funcionarios y terceros.
 - b. Diseñar e implementar actividades de cultura, cambio y apropiación referentes a la seguridad y privacidad de la información dirigidas a los usuarios internos de la **DIAN** que tengan acceso a activos de información de la entidad.
 - c. Incluir actividades de entrenamiento y actualización periódicas en materia de seguridad y privacidad de la información que permitan la comprensión del alcance y contenido de las políticas, lineamientos y directrices de seguridad y privacidad de la información y la necesidad de respaldarlas y aplicarlas de manera permanente e integral desde su función.
 - d. Evaluar la ejecución del programa de concientización, educación y capacitación de las actividades de cultura, cambio y apropiación referentes a la seguridad y privacidad de la información.
 - e. Definir los contenidos a sensibilizar en toda la entidad, teniendo en cuenta riesgos comunes de seguridad y privacidad de la información, requerimientos, políticas, lineamientos, buenas prácticas, deberes y derechos en la materia y responsabilidades frente al incumplimiento, incluyendo el uso seguro de los activos de información.
Definir contenido especializado para los funcionarios que realicen actividades específicas de seguridad y privacidad de la información como: tecnología, desarrollo de software, dependencias que manipulen datos personales.
Medir el grado de conciencia frente ataques de ingeniería social en una muestra representativa de funcionarios e informar a la Subdirección de la Escuela de Impuestos y Aduanas, junto con el material a utilizar en aquellos funcionarios que requieren reforzar sus conocimiento y actitudes frentes a estos ataques.
2. La Subdirección de la Escuela de Impuestos y Aduanas debe:
 - a. Establecer los mecanismos necesarios en sus procedimientos para que los programas de inducción, reinducción, capacitación y sensibilización incluyan y evalúen temas de seguridad y privacidad de la información.
 - b. Verificar que los procedimientos y programas de capacitación y sensibilización pertinentes de la entidad, incluyan y evalúen temas de seguridad y privacidad de la información.
 - c. Ofrecer los medios necesarios para que la Oficina de Seguridad de la Información pueda promover el programa de concientización, educación y capacitación en seguridad y privacidad de la información.
3. La Subdirección de Desarrollo del Talento Humano debe:

- a. Incluir en los programas y acciones requeridas por la entidad para lograr una transformación del talento temas relacionados con seguridad y privacidad de la información.
4. Los jefes de las dependencias deben:
 - a. Propender porque los funcionarios internos de su dependencia y que tengan acceso a activos de información de la entidad se entrenen, capaciten y aprueben las capacitaciones para las funciones, actividades y cargos que van a desempeñar, esto con el fin de sensibilizar los usuarios sobre la correcta operación de los procedimientos y la adecuada protección de los activos de información de la entidad.
 - b. Controlar que los funcionarios de su dependencia reciban la inducción o reinducción en el puesto de trabajo y/o bajo un esquema virtual.
5. Los supervisores de los contratos deben:
 - a. Propender porque los contratistas bajo su supervisión y que tengan acceso a activos de información de la entidad se entrenen y reciban transferencia de conocimiento para las actividades que van a desempeñar, esto con el fin de sensibilizar los usuarios sobre la correcta operación de los procedimientos y la adecuada protección de los activos de información de la entidad.
6. Los funcionarios y terceros deben:
 - a. Recibir las capacitaciones que suministra la Oficina de Seguridad de la Información y verificar que sus procesos y procedimientos incluyan los controles de seguridad y privacidad adecuados.
 - b. Aprobar los cursos sobre seguridad y privacidad de la información que la Subdirección de la Escuela de Impuestos y Aduanas le asigne.

E. Controles relacionados:

1. 5.17 - Información de autenticación
2. 6.8 - Reporte de eventos de seguridad de la información

6.4 Proceso disciplinario

A. Objetivo de control: cumplir con lo establecido en el Código General Disciplinario (CGD), Ley 1952 de 2019, que es la norma base para adelantar los procesos contra funcionarios y exfuncionarios de la DIAN que hayan incurrido en conductas disciplinarias.

Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información que define lineamientos en materia de seguridad y privacidad y la Subdirección de Asuntos Disciplinarios y las demás dependencias de la DIAN que ejercen actividades de verificación del cumplimiento del Código General Disciplinario en la **DIAN**.

B. Características del control:

1. Tipo de control: preventivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

C. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Asesorar a la Subdirección de Asuntos Disciplinarios en las acciones de traslado ante las instancias disciplinarias, administrativas o penales correspondientes, del resultado de los procesos derivados de los reportes y del análisis de los incidentes de seguridad y privacidad, teniendo en cuenta el impacto y las responsabilidades identificadas.
2. La Subdirección de Asuntos Disciplinarios debe:
 - a. Investigar las conductas o violaciones a la seguridad de la información con relevancia disciplinaria, en las que se pueden ver inmersos funcionarios y exfuncionarios de la entidad, en el desarrollo de las funciones que les han sido encomendadas, o por su cargo, o por su sola condición de funcionario.
 - b. Poner en conocimiento de los organismos competentes, la comisión de hechos presuntamente irregulares sobre seguridad y privacidad de la información de los que se tenga conocimiento dentro del proceso disciplinario.
3. Los funcionarios y terceros deben:
 - a. Reportar cualquier comportamiento que esté relacionado con la violación de las normas, políticas, procedimientos o lineamientos de seguridad y privacidad de la información de la **DIAN** o, acerca de la ocurrencia de alguno de los delitos informáticos considerados en la Ley 1273 de 2009 si la conducta es cometida por algún funcionario o contratista.
4. Los supervisores de los contratos deben:
 - a. Reportar cualquier comportamiento que esté relacionado con la violación de las normas, políticas, procedimientos o lineamientos de seguridad y privacidad de la información de la **DIAN** o, acerca de la ocurrencia de alguno de los delitos informáticos considerados en la Ley 1273 de 2009 si la conducta es cometida por un contratista bajo su supervisión.
5. Los funcionarios deben:
 - a. Conocer y aplicar las responsabilidades implícitas en los deberes definidos en el Código General Disciplinario (CGD), Ley 1952 de 2019, en particular el Artículo 38 numeral 6: "Custodiar y cuidar la documentación e información que por razón de su empleo, cargo o función conserve bajo su cuidado o a la cual tenga acceso, e impedir o evitar la sustracción, destrucción, ocultamiento o utilización indebidos".
 - b. Conocer y aplicar lo pertinente a la violación de las políticas y lineamientos de seguridad y privacidad de la información de la entidad, con aplicación de lo establecido en la ley, particularmente en el Código General Disciplinario (CGD), Ley 1952 de 2019, el Estatuto Anticorrupción (Ley 1474 de 2011), junto con lo concerniente a delitos informáticos en la Ley 1273 de 2009, de ser el caso, y demás normas que las adicionen, modifiquen, reglamenten o complementen.
6. Los contratistas deben:

Conocer y aplicar lo pertinente a la violación de las políticas y lineamientos de seguridad y privacidad de la información de la entidad, con aplicación de lo establecido en la ley,

particularmente en el Código General Disciplinario (CGD), Ley 1952 de 2019, el Estatuto Anticorrupción (Ley 1474 de 2011), junto con lo concerniente a delitos informáticos en la Ley 1273 de 2009, de ser el caso, y demás normas que las adicionen, modifiquen, reglamenten o complementen.

D. Controles relacionados:

1. 5.28 - Recopilación de pruebas

6.5 Responsabilidades después de la terminación o cambio de empleo

A. Objetivo de control: definir responsabilidades y deberes de seguridad y privacidad que permanecen después de la terminación o cambio de empleo en la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información, la Oficina de Tributación Internacional, la Dirección de Gestión de Innovación y Tecnología y la Dirección de Gestión Corporativa y sus subdirecciones Gestión del Empleo Público y Compras y Contratos, que realizan las actividades de en la terminación o cambio de empleo en la **DIAN**.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Establecer mecanismos que permitan al jefe inmediato o supervisor de un contratista reportar eventos o incidentes que impliquen la pérdida, daño, robo o compromiso de activos de información de la **DIAN**, debido a la terminación o cambio de empleo del personal.
2. La Dirección de Gestión Corporativa debe:

Establecer lineamientos a seguir en el caso de retiro, investigación, inhabilidades, o cambio de funciones de un funcionario, así como con el personal contratado en caso de terminación anticipada, definitiva, temporal o cesión del contrato.

 - a. Establecer controles necesarios en sus procesos de terminación o cambio de empleo del personal de la **DIAN**.
 - b. Verificar que los lineamientos establecidos en este numeral, ante la terminación o cambio de empleo del personal de la **DIAN**, se encuentren en procedimientos formales.
3. La subdirección Gestión del Empleo Público debe:
 - a. Informar a los funcionarios que después de la terminación o cambio de empleo de la **DIAN**, las responsabilidades y deberes de seguridad y privacidad de la información permanecen válidos.

Solicitar la desactivación del acceso a los servicios tecnológicos como: accesos VPN, cuentas de usuario, credenciales y demás accesos vinculantes y no necesarios para la OPEAC.

- b. Informar a la supervisión del contrato de vigilancia y seguridad privada para desactivar los accesos biométricos o de tarjetas de proximidad los sistemas de control de acceso. Definir un mecanismo para obtener el correcto diligenciamiento del Acta de Entrega por parte del funcionario, exceptuando que la desvinculación sea por fallecimiento. El Acta de Entrega debe ser cargada en el Registro Único de Personal -RUP. Recoger y custodiar la información de la **DIAN**, que este consignada en el Acta de Entrega de Puesto de Trabajo
- c. Transferir la información, de ser el caso. Verificar que se devuelvan todos los activos de información, se desactiven y/o eliminen los accesos físicos y lógicos y se transfiera la información pertinente a la **DIAN**.

4. La Subdirección de Compras y Contratos debe:

- a. Informar a los contratistas que después de terminación anticipada, definitiva, temporal o cesión del contrato de la **DIAN**, las responsabilidades y deberes de seguridad y privacidad de la información permanecen válidos. Definir un mecanismo para obtener el correcto diligenciamiento del Acta de Entrega o Informe Final por parte del contratista, exceptuando que la desvinculación sea por fallecimiento:
- b. Recoger y custodiar la información de la **DIAN**.
- c. Transferir la información, de ser el caso.
- d. Verificar que se devuelvan todos los activos de información, se desactiven y/o eliminen los accesos físicos y lógicos y se transfiera la información pertinente a la **DIAN**.
- e. Emitir un comunicado a los proveedores y demás personal con el que el usuario interno tenga contacto, indicándoles que esa persona ya no labora en la **DIAN** e informándoles quién asumirá sus funciones o responsabilidades.

5. La Dirección de Gestión de Innovación y Tecnología debe:

- a. Establecer canales de comunicación y divulgarlos para que las dependencias que realizan vinculación de personal (tanto funcionarios como contratistas) notifiquen cuando el personal se desvincule de la entidad.
- b. Desactivar o deshabilitar el acceso a los servicios tecnológicos como: la cuenta de dominio, cuentas de administrador, cuentas privilegiadas, accesos a la VPN, perfiles y permisos de escritorio virtual, roles de sistemas de información y cuentas de usuario en aplicativos legados, entre otros, cuando se solicite formalmente a través de la herramienta de casos que utilice la dependencia.
- c. Crear una copia de respaldo del buzón de correo electrónico una vez se dé por terminada la vinculación con la **DIAN**. Bajo ningún parámetro se podrán restablecer los accesos a estas cuentas; solo se podrán restablecer buzones en ambientes offline y no se podrán emitir correos ni notificaciones desde estos buzones.
- d. Cambiar la contraseña inmediatamente y asignar un nuevo responsable cuando un funcionario o contratista se desvincule y esté a cargo de un buzón genérico (ejemplo: comunicaciones@dian.gov.co).
- e. Realizar el monitoreo sobre la gestión de roles y perfiles de acceso a la plataforma tecnológica de la **DIAN** en la terminación contractual o desvinculación de la entidad.

6. Las Subdirección Administrativa deben:

- a. Recoger los activos de información físicos, cuando la subdirección Gestión del Empleo Público notifique sobre la desvinculación definida de un funcionario.
- b. Recoger los activos de información físicos, cuando la Subdirección de Compras y Contratos notifique sobre la desvinculación definida de un contratista.

E. Controles relacionados:

1. 6.2 Términos y condiciones de empleo
2. 6.6 Acuerdos de confidencialidad o no divulgación

6.6 Acuerdos de confidencialidad y no divulgación de información

A. Objetivo de control: proteger la información de la entidad y notificar a todos los usuarios internos, externos y proveedores de la **DIAN** sobre la responsabilidad de proteger, usar y divulgar la información de manera responsable y autorizada según lo especificado en el Manual de protección de datos personales y este manual.

B. Alcance: el alcance de este lineamiento aplica para todas las dependencias, que deben solicitar la firma del compromiso de confidencialidad y de no divulgación de los funcionarios, contratistas y terceros que se vinculan a la **DIAN** o firmen convenios o acuerdos con la entidad.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Incluir en el compromiso de confidencialidad y de no divulgación criterios como: duración del acuerdo, criterios después de la terminación, derecho a auditar y monitorear, notificación de incidentes, acciones ante un incumplimiento y similares.
 - b. Definir un compromiso de confidencialidad y de no divulgación que incluya el tratamiento de los datos personales y los requisitos establecidos en este documento.
 - c. Revisar los requisitos de los acuerdos de confidencialidad y no divulgación de información, periódicamente y actualizarlos cuando ocurran cambios que influyan en los mismos.
2. La Dirección de Gestión Corporativa debe:
 - a. Establecer lineamientos para que tanto funcionarios como contratistas firmen el compromiso de confidencialidad y no divulgación de información.
 - b. Revisar los requisitos de los acuerdos de confidencialidad y no divulgación de información, periódicamente o cuando ocurran cambios que influyan en los mismos.
3. La subdirección de Gestión del Empleo Público debe:

Supervisar que los funcionarios firmen el compromiso de confidencialidad y no divulgación de información cuando se vinculan a la entidad.

Verificar que los funcionarios firmen el compromiso de confidencialidad y no divulgación de información cuando se vinculan a la entidad.

Revisar los requisitos de los acuerdos de confidencialidad y no divulgación de información, periódicamente o cuando ocurran cambios que influyan en los mismos.

Custodiar los compromisos de confidencialidad y no divulgación de información, suscritos en la dependencia.

4. La Subdirección de Compras y Contratos debe:

- a. Hacer que todos los contratistas firmen el compromiso de confidencialidad y no divulgación cuando se vinculan a la entidad.
- b. Verificar que los contratistas firmen el compromiso de confidencialidad y no divulgación cuando se vinculan a la entidad.
Incluir dentro del manual de contratación, obligaciones para que los supervisores de los contratos soliciten la firma del compromiso de confidencialidad y no divulgación cuando el tercero tenga acceso a la información de la **DIAN**.
- c. Revisar los requisitos de los acuerdos de confidencialidad y no divulgación, periódicamente o cuando ocurran cambios que influyan en los mismos.

5. Los supervisores de los contratos deben:

- a. Solicitar y verificar la firma del compromiso de confidencialidad y no divulgación cuando el tercero bajo su supervisión tenga acceso a la información de la **DIAN**.

6. Los funcionarios y terceros deben:

Firmar el compromiso de confidencialidad y no divulgación cuando se vincule a la entidad o cuando realice un contrato, acuerdo o convenio.

Verificar, entender y cumplir el compromiso de confidencialidad y no divulgación.

Las demás dependencias deben:

8. La Coordinación de Enlace para la transformación digital debe:

E. Controles relacionados:

1. 5.31 - Requisitos legales, estatutarios, reglamentarios y contractuales
2. 5.32 - Derechos de propiedad intelectual
3. 5.33 - Protección de registros
4. 5.34 - Protección de datos personales (PII)

6.7 Trabajo a distancia (Política de Teletrabajo)

A. Objetivo de control: Definir las medidas de seguridad de la información que deben ser incorporadas por los funcionarios de la entidad que trabajen en cualquier modalidad de teletrabajo, definida por la entidad, para que la información a la que se acceda, procese o almacene esté protegida de accesos no autorizados, divulgación, pérdida o daño.

B. Alcance: El alcance de este lineamiento aplica para preservar la seguridad y privacidad de la información cuando los funcionarios y terceros trabajan fuera de las instalaciones de la Entidad.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Socializar a los servidores públicos Teletrabajadores que se encuentren en cualquier modalidad de teletrabajo, los lineamientos de seguridad y privacidad, para proteger la información.
 - b. Analizar la resolución de teletrabajo vigente en la entidad para que los lineamientos de seguridad y privacidad de la información estén en concordancia con la normatividad vigente, el contexto de la organización y la gestión de riesgos
 - c. La Oficina de Seguridad de la Información (OSI) podrá solicitar a la Dirección de Gestión de Innovación y Tecnología (DGIT), en el marco de sus competencias y en cumplimiento de las políticas institucionales de seguridad de la información, la revocación o bloqueo de permisos, la suspensión de credenciales, la limitación de funcionalidades o el retiro de la modalidad de teletrabajo, cuando se detecte cualquier evento, situación o conducta que pueda comprometer la confidencialidad, integridad o disponibilidad de los activos de información de la entidad. Estas medidas podrán adoptarse ante la presencia de anomalías, incidentes de seguridad, accesos no autorizados, incumplimiento de controles establecidos o cualquier indicio de vulneración de las directrices emitidas por la OSI.
2. La subdirección de Desarrollo del Talento Humano debe:
 - a. Validar que los profesionales designados por la ARL para realizar las visitas de inspección del puesto de trabajo en casa de los Teletrabajadores de la Entidad suscriban el Compromiso de Confidencialidad y no Divulgación de la Información Reservada o Clasificada para Terceras Personas en el formato aprobado y publicado en el Listado Maestro de documentos de la UAE DIAN.
 - b. Verificar que los Servidores Públicos Teletrabajadores suscriban el Compromiso de Confidencialidad y no Divulgación de la Información Reservada o Clasificada para Servidores Públicos en el Formato aprobado y publicado en el Listado Maestro de documentos de la UAE DIAN.
 - c. Verificar que en el acuerdo de voluntariedad que suscriba el servidor público teletrabajador se incluyan las políticas institucionales de seguridad de la información, uso adecuado de los activos tecnológicos, tratamiento de datos personales, y demás lineamientos vigentes, que garanticen la integridad, confidencialidad y disponibilidad de la información, manejada en entornos remotos
 - d. Revisar y proponer actualizaciones a la Política Institucional de Teletrabajo con una periodicidad definida o cuando surjan cambios en el contexto de la entidad o en la normatividad vigente, en temas relacionados con Seguridad y Privacidad de la información.

- e. Restringir el acceso a los documentos firmados por los servidores públicos teletrabajadores y los profesionales de la ARL, en el repositorio dispuesto para tal fin.
3. La Dirección de Gestión de Innovación y Tecnología debe:
- a. Llevar el registro e identificación de los equipos de cómputo que fueron asignados a los funcionarios que se encuentren en la modalidad de teletrabajo.
 - b. Implementar controles de seguridad tecnológicos para proteger la confidencialidad, integridad y disponibilidad de la información en la modalidad de teletrabajo.
 - c. Verificar los controles tecnológicos establecidos y los parámetros de seguridad de la información para la realización de las funciones bajo la modalidad de teletrabajo.
 - d. Implementar sistemas y protocolos de seguridad para la transmisión de la información en la modalidad de teletrabajo.
 - e. Verificar periódicamente la efectividad de los controles aplicados sobre las conexiones remotas a los recursos de la plataforma tecnológica de la **DIAN**.
 - f. Instalar la misma línea base de software en los equipos de cómputo utilizados tanto para la modalidad de teletrabajo como en las instalaciones físicas de la **DIAN**.
 - g. Poner a disposición de los teletrabajadores las herramientas tecnológicas, instrumentos, equipos, conexiones, programas y demás elementos necesarios para la prestación y desarrollo de las labores asignadas.
 - h. Monitorear y revisar los registros de auditoria de las actividades realizadas por los Teletrabajadores en los diferentes sistemas y aplicaciones de la entidad.
 - i. Asignar un espacio de respaldo de la información en medios compartidos para los teletrabajadores con los debidos controles de acceso.
 - j. Implementar controles de seguridad tecnológicos para proteger la confidencialidad, integridad y disponibilidad de la información en modalidad de teletrabajo.
 - k. Verificar los controles tecnológicos establecidos y los parámetros de seguridad de la información para la realización de las funciones bajo teletrabajo.
 - l. Implementar sistemas y protocolos de seguridad para la transmisión de la información en teletrabajo.
 - m. Verificar periódicamente la efectividad de los controles aplicados sobre las conexiones remotas a los recursos de la plataforma tecnológica de la **DIAN**.
4. Los funcionarios en modalidad de teletrabajo deben:
- a. Custodiar y preservar los equipos designados,
 - b. Velar por la protección de las cuentas de usuario y contraseñas asociadas a los equipos entregados, aplicaciones y sistemas de la entidad.
 - c. Responder por la información que genere, obtenga, adquiera o controle en el desempeño de sus funciones, especialmente si esta información es pública clasificada o pública reservada, independientemente del medio en el que esté disponible (físico o electrónico).
 - d. Preservar la seguridad de la información de los equipos designados, en los que no se podrá instalar ningún software, programa o aplicativo que no se encuentre autorizado por la entidad.
 - e. Utilizar los equipos suministrados por la **DIAN** exclusivamente para el desarrollo y cumplimiento de las funciones propias del cargo o de las actividades adelantadas para la prestación de las labores encomendadas.
 - f. Utilizar la conexión a internet contratada para el sitio en el cual va a desempeñar sus labores y en ningún caso esta conexión puede ser pública o compartida.

- g. Presentar y poner a disposición de la Dirección de Gestión de Innovación y Tecnología, los equipos asignados para teletrabajo, cuando sea requerido y en los tiempos establecidos por esta dirección o quien haga sus veces.
- h. Evitar el uso compartido de los elementos de la **DIAN** suministrados por parte de la entidad.
- i. Firmar el acuerdo de Confidencialidad y Voluntariedad, igualmente el Acta de visita de la ARL, con las condiciones de seguridad en el teletrabajo.
- j. Utilizar los datos de carácter personal privados o sensibles a los que tenga acceso exclusivamente para el cumplimiento de sus funciones dentro de la entidad conforme a la Política de Tratamiento de datos personales de la UAE DIAN
- k. No ceder, divulgar o compartir con terceras personas los datos de carácter personal, privados o sensibles a los que tenga acceso, incluso con fines de conservación

E. Controles relacionados:

1. 6.8 - Reporte de eventos de seguridad de la información

6.8 Reporte de eventos de seguridad de la información

A. Objetivo de control: asegurar que los eventos de seguridad de la información y las debilidades asociadas se reporten de manera oportuna a los canales adecuados para que se tomen acciones correctivas, se minimicen impactos y se mejoren los controles existentes.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y todos los funcionarios y terceros que tengan acceso a la información de la **DIAN** e identifiquen posibles incidentes de seguridad y privacidad de la información. Se extiende a todos los sistemas de información, incluidas redes, servidores, estaciones de trabajo, dispositivos móviles y servicios en la nube.

C. Características del control:

1. Tipo de control: detectivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir procedimientos para el reporte de posibles eventos de seguridad y privacidad de la información incluyendo: responsables, canales de comunicación, tiempos de respuesta, clasificación de los posibles eventos.
 - b. Socializar el procedimiento de incidentes de posibles eventos de seguridad y privacidad de la información.
Hacer ejercicios de ingeniería social para verificar que el personal de la entidad haga uso de los canales dispuestos para el reporte de posibles eventos de seguridad y privacidad de la información.
Brindar formación periódica sobre qué constituye un evento de seguridad y cómo reportarlo.
2. Los funcionarios y terceros deben:

Utilizar los canales de comunicación definidos por la Oficina de Seguridad de la Información para reportar los posibles eventos de seguridad y privacidad de la información, entre los cuales está el buzón de la oficina: seguridaddigital@dian.gov.co, y el aplicativo GRC

Considerar que cualquier violación de la integridad, confidencialidad o expectativas de disponibilidad de la información de datos personales, según la Ley 1581 de 2012 debe ser reportada.

Los eventos deben ser reportados inmediatamente o en el menor tiempo posible desde su detección.

- a. Reportar cualquier posible evento de seguridad y privacidad de la información teniendo en cuenta al menos las siguientes situaciones:
 - Un control de seguridad ineficaz
 - Errores humanos
 - Daño o pérdida de información física o digital
 - Fuga o robo de información física o digital
 - Cambios no controlados en el sistema
 - Mal funcionamiento en el software o hardware
 - Suplantación de identidad
 - Uso indebido de imagen institucional
 - Accesos no autorizados o intentos de accesos desconocidos
 - Malware, ransomware o actividad sospechosa.
 - Pérdida de dispositivos con información sensible.
 - Vulnerabilidades explotadas o identificadas.
 - Incidentes físicos que afecten la seguridad de la información (como robos o accesos físicos indebidos)

E. Controles relacionados:

1. 8.8 - Gestión de vulnerabilidades técnicas

7. CONTROLES FISICOS

A continuación, se describen los lineamientos y políticas que hacen referencia a las responsabilidades que establece la **DIAN** para los funcionarios y terceros en términos de seguridad física:

7.1 Perímetros de seguridad física

- A. Objetivo de control:** establecer los mecanismos o controles necesarios en los procedimientos de la entidad de forma que existan, funcionen y se apliquen adecuada y efectivamente los controles para los perímetros de seguridad física de la **DIAN**, teniendo en cuenta los principios y lineamientos de este numeral, con el fin de proteger las dependencias que contienen información de la entidad y otros activos asociados.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección Administrativa, dependencia encargada de definir los lineamientos para los controles de perímetro de seguridad física de la entidad tanto en su sede principal como en todas las seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de Seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Definir junto con la Subdirección de Infraestructura Tecnológica y de Operaciones, el perímetro de las áreas seguras de tecnología que contienen la información y sus instalaciones de procesamiento sensible o crítico, las cuales deben estar cerradas y protegidas de accesos no autorizados (cerraduras, alarmas, construcciones sólidas, mecanismos de control).
 - b. Validar que el perímetro de seguridad cuente con vigilancia mediante Circuito Cerrado de Televisión (CCTV) y ser monitoreado por el personal de vigilancia contratado por la DIAN.
 - c. Validar que las puertas y ventanas de las oficinas, salas e instalaciones, que tienen bajo su custodia activos de información de alta criticidad, permanezcan cerradas con llave cuando estén desocupadas o no estén siendo supervisadas. Aquellas oficinas que no tengan puerta deben permanecer vigiladas o supervisadas, mientras se encuentre en ellas personal externo a la **DIAN**.
 - d. Implementar alarmas, monitorear y efectuar pruebas periódicamente a todas las puertas contra incendios en los perímetros de seguridad que hayan definido la entidad.
 - e. Efectuar un análisis de riesgos y planes de tratamiento específicos para cada una de las seccionales que permitan aplicar los lineamientos relacionados con la seguridad perimetral para estas instalaciones.
 - f. Establecer los mecanismos o controles necesarios en sus procedimientos que permitan que existan, funcionen y se apliquen adecuada y efectivamente los controles físicos de entrada a las instalaciones y áreas seguras de la **DIAN**, teniendo en cuenta los principios y lineamientos de este literal y los que indique el Sistema de Gestión de Calidad.
Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN**, debido a inconvenientes en los perímetros de seguridad física, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@bian.gov.co el aplicativo G
2. Los funcionarios y terceros de la entidad deben:

Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN**, debido a inconvenientes en los perímetros de seguridad física, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@bian.gov.co el aplicativo GRC

E. Controles relacionados:

1. 5.1.34 –Privacidad y protección de la información de datos personales (identificación personal PII)
2. 6.8 – Informes de eventos de seguridad de la información

3. 7.2 – Entrada física
4. 7.3 – Asegurar oficina, salas e instalaciones
5. 7.4 – Supervisión de la seguridad física

7.2 Entrada física

A. Objetivo de control: evitar accesos físicos no autorizados que atenten contra la confidencialidad, integridad o disponibilidad de la información de la entidad. Así mismo, controlar los puntos de acceso tales como áreas de despacho y de carga, y otros puntos a donde pueda entrar personal no autorizado a la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección Administrativa, dependencia encargada de definir los lineamientos para los controles de entrada física de la entidad y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Implementar un sistema de control de acceso a las instalaciones de la **DIAN**, así como a las áreas seguras y a las demarcadas con acceso restringido dentro y fuera de las instalaciones principales de la entidad.
 - b. Instalar mecanismos físicos (cerraduras, alarmas, sistemas lectores de tarjeta, muros y similares) con el objetivo de prevenir el acceso no autorizado a zonas que contengan activos de información de alta criticidad de la **DIAN**.
 - c. Implementar en todos los puntos de acceso a áreas seguras, un área de recepción con vigilancia u otro medio para controlar el acceso físico al sitio o edificación.
 - d. Contar con un libro de registro y/o software para el ingreso de funcionarios, contratistas y visitantes a las instalaciones de la **DIAN**, por parte del servicio de vigilancia ubicado en la recepción en este se debe registrar: nombre, número de identificación, fecha y hora de entrada, y nombre del funcionario que autoriza el ingreso.
 - e. Implementar avisos de privacidad como aviso de videovigilancia y autorización de tratamiento de datos personales conforme a las obligaciones establecidas en la Ley 1581 de 2012 y sus decretos reglamentarios.
 - f. Implementar un mecanismo de identificación para los contratistas y visitantes de la **DIAN** que se debe portar en un lugar visible durante la estadía en la entidad, al igual que deben portar el carné o escarapela de la entidad de la cual provienen, si es el caso.
 - g. Mantener cerradas todas las puertas de acceso a cada una de las dependencias, oficinas, centros de cómputo, cableado y comunicaciones, salas de capacitación y similares en casos de ausencias temporales.
 - h. Establecer los mecanismos o controles necesarios en sus procedimientos que permitan que existan, funcionen y se apliquen adecuada y efectivamente los controles físicos de entrada a las instalaciones y áreas seguras de la **DIAN**, teniendo en cuenta los principios y lineamientos de este literal y los que indique el Sistema de Gestión de Calidad.

- i. Establecer áreas de cargue, descargue y despacho de mercancías en zonas que no permitan el acceso a otras áreas de las edificaciones e implementar señalizaciones en estas.
 - j. Mantener las puertas externas de áreas de cargue, descargue y despacho vigiladas cuando las puertas internas estén abiertas, a su vez llevar un registro de los materiales que ingresan a instalaciones de la DIAN.
 - k. Inspeccionar y examinar los materiales que ingresan para determinar la presencia de componentes peligrosos o evidencias de alteración durante el transporte tanto para los funcionarios y personal externo. Si hay componentes peligrosos o presentan alteraciones, se debe reportar de inmediato al personal de seguridad de la DIAN.
 - l. Portar el respectivo carné de identificación; en caso de ser personal que acceda a áreas de cargue, descargue y despacho debe estar identificado con información de la empresa para la que trabaja, así, confirmar que se cuenta con los permisos para transitar en estas áreas.
 - m. Establecer los mecanismos o controles necesarios en sus procedimientos para asegurar la existencia, funcionalidad y aplicación efectiva de los controles físicos de acceso a las instalaciones y áreas seguras de la DIAN.
2. Los funcionarios y terceros de la entidad deben:
- a. Enviar un comunicado por parte del funcionario responsable a la empresa de vigilancia que autoriza el ingreso temporal de visitantes, indicando el motivo y duración de la autorización.
 - b. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la DIAN debido a inconvenientes en los controles físicos de entrada o salida, y también los que se presenten en las áreas de despacho, cargue y descargue, que involucren la pérdida, daño, robo o compromiso de activos de información de la DIAN.
 - c. Establecer y asignar permisos de acceso a las dependencias, oficinas, centros de cómputo, cableado y comunicaciones, salas de capacitación y similares únicamente a los Usuarios internos autorizados para su acceso.

E. Controles relacionados:

1. 5.9 – Inventario de información y otros activos asociados
2. 5.17 – Información de autenticación
3. 5.18 – Derechos de acceso
4. 5.33 – Protección de registros
5. 5.34 - Protección de datos personales (PII)
6. 6.8 – Informes de eventos de seguridad de la información
7. 7.10 – Medios de almacenamiento

7.3 Asegurar oficinas, salas e instalaciones

- A. Objetivo de control:** prevenir el acceso físico no autorizado a la información de la organización y otros activos asociados en las oficinas, salas e instalaciones de la **DIAN**.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección Administrativa, dependencia encargada de administrar los recursos físicos de la **DIAN**, sus instalaciones y seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Implementar un sistema de detección de intrusos (sistema de alarmas físico) que debe permanecer activo en horario laboral.
 - b. Realizar pruebas periódicas a los sistemas de detección de intrusos (sistema de alarmas físico) implementados, de forma que se pueda confirmar su correcto funcionamiento.
 - c. Registrar todos los ingresos o salidas de las dependencias cada vez que entren o salgan los usuarios internos y visitantes, sin excepción. Este registro se debe realizar con la tarjeta de aproximación, mediante el sistema biométrico u otro sistema disponible para abrir las puertas. Por lo tanto, está prohibido “mantener abierta la puerta” para que ingresen o salgan otras personas diferentes a quien abrió la puerta con su mecanismo de ingreso. El personal de vigilancia de la **DIAN** debe estar atento al cumplimiento de este lineamiento.
 - d. Acompañar a todos los visitantes por un funcionario de la **DIAN** cuando se encuentren en las dependencias donde se maneje información. Así mismo, los visitantes que requieran permanecer en las oficinas de la **DIAN**, por periodos superiores a dos días, deben ser presentados al personal de la dependencia donde permanecerán.
 - e. Definir el horario autorizado para recibir visitantes en las instalaciones de la **DIAN**. En horarios distintos se requerirá de la autorización del jefe inmediato o superior jerárquico de la dependencia correspondiente.
 - f. Efectuar un análisis de riesgos y planes de tratamiento específicos para cada una de las seccionales, que permita aplicar los lineamientos relacionados con la seguridad de oficinas, salas e instalaciones.

Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN** debido a fallas en la seguridad de oficinas, recintos e instalaciones utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@dian.gov.co y el aplicativo GRC

E. Controles relacionados:

1. 5.34 – Protección de datos personales (PII)

7.4 Supervisión de la seguridad física

- A. Objetivo de control:** verificar periódicamente el acceso físico de funcionarios y terceros con acceso a la información de la organización y otros activos asociados en las oficinas, salas e instalaciones de la **DIAN**, para prevenir y detectar accesos no autorizados de forma oportuna a las instalaciones de la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección Administrativa, dependencia encargada de verificar de forma periódica el ingreso físico a las dependencias e instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Instalar circuito cerrado de televisión (CCTV) para la vigilancia de los equipos y usuarios internos o visitantes que realicen funciones con activos de información de alta criticidad, incluyendo las dependencias de cargue, descargue y despacho de mercancías con el objetivo de controlar y monitorear estas dependencias.
Implementar avisos de privacidad como de videovigilancia y demás conforme a las obligaciones establecidas en la Ley 1581 de 2012 y sus decretos reglamentarios.
 - b. Monitorear y registrar periódicamente las actividades de los usuarios internos y visitantes en las instalaciones de la **DIAN** a través de un circuito cerrado de televisión.
 - c. Notificar y presentar sin excepción al personal de cada dependencia, los visitantes que requieran permanecer en las oficinas de la **DIAN** por periodos continuos, definiendo con cada dependencia el tiempo mínimo para considerar obligatoria estas notificaciones en días.
 - d. Implementar revisiones periódicas a los detectores de contacto, sonido o movimiento que permiten activar alarmas de intrusión en la entidad; estas revisiones deben considerar un cronograma de revisión que debe ser elaborado, aprobado y actualizado por la entidad.
 - e. Activar alarmas de forma permanente en dependencias desocupadas dentro de las instalaciones de la **DIAN**, especialmente si se trata de secciones que contengan equipos tecnológicos o de comunicaciones.
 - f. Mantener todos los diseños de cada uno de los sistemas de monitoreo, con clasificación “clasificada”, para evitar que existan posibilidades de divulgación no autorizada.
 - g. Implementar, para cada panel de control de los sistemas de alarmas, mecanismos a prueba de manipulaciones no autorizadas.
 - h. Implementar pruebas periódicas a los sistemas de alarmas y monitoreos que permitan confirmar que su funcionamiento se realiza de forma correcta acorde a lo definido por la entidad.
Efectuar un análisis de riesgos y planes de tratamiento específicos para cada una de las seccionales, que permita aplicar los lineamientos relacionados con la supervisión de la seguridad en estas instalaciones.
Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la DIAN debido al acceso físico de funcionarios y terceros con acceso a la información de la organización y otros activos asociados en las oficinas, salas e instalaciones de la DIAN, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@dian.gov.co y el aplicativo GRC

E. Controles relacionados:

1. 5.34 –Protección de datos personales (PII).
2. 6.8 – Informes de eventos de seguridad de la información.

7.5 Protección contra amenazas físicas y ambientales

A. Objetivo de control: diseñar e implementar la protección contra amenazas físicas y ambientales, considerando desastres naturales, ataques maliciosos, accidentes y otras amenazas físicas intencionales o no intencionales a la infraestructura de la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones, Oficina de Seguridad de la Información, Subdirección de Procesos, y la Subdirección Administrativa, dependencias encargadas de la gestión, control y pruebas de los Planes: Plan de Continuidad del Negocio y Plan de Recuperación de Desastres; así como la Subdirección de Desarrollo de Talento Humano por la facultad de capacitar a los funcionarios de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Alinear, revisar y actualizar los controles contra amenazas externas y ambientales, enmarcados en los planes de contingencia, de emergencia, de gestión de riesgo, planes de evacuación y de continuidad de la operación tecnológica.
 - b. Monitorear las variables de temperatura y humedad de los centros de cómputo, cableado, comunicaciones y cuartos técnicos; y cuando estos se vean afectados por daño o falta de mantenimiento, reportar a la Subdirección Administrativa dichas eventualidades para que estos equipos sean cambiados o se haga el mantenimiento necesario para su debido funcionamiento.
2. La Subdirección Administrativa debe:
 - a. Establecer los mecanismos o controles necesarios en sus procedimientos para permitir que existan, funcionen y se apliquen adecuada y efectivamente las acciones contra amenazas externas y ambientales, teniendo en cuenta los principios y lineamientos de este numeral y formen parte del Sistema de Gestión Ambiental de la entidad.
 - b. Implementar mecanismos adecuados contra las amenazas ambientales (temperatura, humedad, fuego, etc.), especificados por los fabricantes de los equipos dispuestos en los centros de cómputo, cableado, comunicaciones y cuartos técnicos de la **DIAN**.
 - c. Monitorear las variables de temperatura y humedad de los cuartos de archivo y, cuando estos se vean afectados por daño o falta de mantenimiento, se deben reportar dichas eventualidades para que estos equipos sean cambiados o se haga el mantenimiento necesario para su debido funcionamiento.
 - d. Identificar las amenazas externas y definir acciones para prevenir o reducir las consecuencias de estas.

- e. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN** debido a amenazas externas o ambientales.
- 3.
4. La Subdirección de Procesos debe:
 - a. Coordinar la elaboración del Plan de Continuidad y Recuperación de Desastres, que mitigue la afectación la operación de la entidad; así mismo, implementar pruebas periódicas que confirmen operación adecuada de los controles contra amenazas externas y ambientales.
5. La Subdirección de Desarrollo de Talento Humano debe:
 - a. Revisar, aprobar, actualizar y divulgar los documentos que relacionan los aspectos de prevención y atención de emergencias identificadas a nivel nacional, declaración del nivel de emergencia, alarmas y demás aspectos de seguridad física, que se encuentran contemplados en los procedimientos relacionados y que hacen parte del listado maestro.
6. Los funcionarios y terceros de la entidad deben:
 - a. Conocer y aplicar los controles para la prevención y atención de emergencias identificadas a nivel nacional, declaración del nivel de emergencia, alarmas y demás aspectos de seguridad física, que se encuentran contemplados en los procedimientos relacionados y que hacen parte del listado maestro.
 - b. Atender las recomendaciones sobre las medidas de seguridad del personal e instalaciones establecidas en el “Memorando 00092 del 30 de abril del 2021 “Recomendación sobre las medidas de seguridad del personal e instalaciones de la **DIAN**”.

E. Controles relacionados:

1. 5.29 – Seguridad de la información durante la interrupción
2. 5.30 – Preparación de las TIC para la continuidad del negocio

7.6 Trabajar en áreas seguras

- A. Objetivo de control:** diseñar y aplicar medidas de seguridad para trabajar en áreas seguras de la **DIAN**, protegiendo la información y otros activos asociados contra daños e interferencias no autorizadas por parte del personal que trabaja en estas dependencias.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección Administrativa y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de controlar la seguridad para trabajar en instalaciones de la **DIAN** y sus seccionales, así como la Oficina de Seguridad de la Información, encargada de gestionar y monitorear el acceso de ingreso a las áreas seguras, como también la Oficina de Tributación Internacional y Subdirección de Apoyo en la Lucha Contra el Delito Aduanero y Fiscal, responsables de administrar y garantizar la protección del procesamiento y resguardo de la información clasificada y reservada que se genera en el desarrollo de sus funciones.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

Espacios que requieren control estricto de acceso físico, ya que están destinados al procesamiento o resguardo de información clasificada y reservada. En estos lugares también se ubican los equipos y la infraestructura tecnológica que soportan los sistemas de información y comunicaciones de la entidad.

Se consideran como áreas seguras los siguientes espacios:

- E. Centro de datos San Agustín-Impuestos Bogotá
- F. Centros de cableado de las sedes Nivel local y Direcciones Seccionales
- G. Áreas de gestión documental, radicación y archivo (Archivo Central de las sedes Nivel local y Direcciones Seccionales)
- H. Cuartos y plantas eléctricas de las sedes Nivel local y Direcciones Seccionales
- I. Despacho del director general.
- J. Oficina de Tributación Internacional, Subdirección de Apoyo en la Lucha Contra el Delito Aduanero y Fiscal (Laboratorio Forense) y aquellas que manejen información clasificada y reservada.

Las áreas mencionadas deben contar con un perímetro de seguridad definido y estar resguardadas mediante barreras físicas y mecanismos de control de acceso que garanticen la protección contra ingresos no autorizados.

1. La Subdirección Administrativa debe:

- a. Contar con mecanismos de protección física, ambiental, dispositivos y controles de acceso adecuados para la protección de la información que permitan el acceso solamente al personal autorizado.
- b. Restringir y/o resguardar elementos inflamables dentro de las áreas seguras, así como aquellas en las que se encuentren los equipos y demás infraestructura de soporte a los sistemas de información y comunicaciones.
- c. Capacitar al personal de limpieza acerca de las precauciones a seguir durante el proceso de limpieza en cada una de las dependencias que la **DIAN** ha considerado como áreas seguras.
- d. Designar un funcionario específico para supervisar las actividades de limpieza en las áreas seguras. Con esta supervisión, a su vez, se impide el ingreso de maletas, bolsos u otros objetos que no sean propios de las tareas de aseo.
- e. Implementar en las áreas seguras avisos relacionados con la Protección de Datos Personales en Sistemas de Videovigilancia que realiza la entidad.
- f. Monitorear periódicamente las áreas seguras, confirmando que estas cumplen como mínimo con lo siguiente:
 - Que estén vacías y cerradas con llave.

- Restringir el uso de equipo fotográfico, de video, audio u otro equipo de grabación, tales como cámaras en dispositivos móviles, a menos que se cuente con autorización para ello por parte de la dependencia encargada.
 - Con apoyo de un CCTV, visualizar el trabajo realizado en estas áreas teniendo en cuenta que las cámaras no pueden apuntar directamente a la captura de información.
- g. Establecer los mecanismos o controles necesarios en sus procedimientos para permitir que existan, funcionen y se apliquen adecuada y efectivamente los controles de seguridad de las áreas seguras de la **DIAN**, teniendo en cuenta los principios y lineamientos de este numeral y que forman parte del Sistema de Gestión de Calidad. Reportar a la Oficina de Seguridad de la Información, los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN** en las dependencias seguras, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@bian.gov.co y el aplicativo GRC

2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:

- a. Contar con mecanismos de protección física y ambiental y dispositivos y controles de acceso adecuados para la protección de la información que permitan el acceso solamente al personal autorizado a las instalaciones seguras de los data center.
 - b. Restringir, almacenar, mantener y/o guardar elementos inflamables dentro de las dependencias seguras de los data center, y demás infraestructura de soporte a los sistemas de información y comunicaciones.
 - c. Implementar avisos que informen la restricción que existe en los data center, las cuales deben detallar que en ninguna circunstancia se puede fumar, comer o beber.
 - d. Designar a un funcionario específico para supervisar las actividades de limpieza en los data center. Con esta supervisión, a su vez, se impide el ingreso de maletas, bolsos u otros objetos que no sean propios de las tareas de aseo.
- Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN** en los data center, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@bian.gov.co y el aplicativo GRC.
- Monitorear periódicamente los data center (Sitio 1- Sitio 2), confirmando que cumplen como mínimo con lo siguiente:
- Que estén vacías y cerradas con llave.
 - Restringir el uso de equipo fotográfico, de video, audio u otro equipo de grabación, tales como cámaras en dispositivos móviles, a menos que se cuente con autorización para ello por parte de la dependencia encargada.
 - Con apoyo de un CCTV, visualizar el trabajo realizado en estas dependencias teniendo en cuenta que las cámaras no pueden apuntar directamente a la captura de información.

3. La Oficina de Tributación Internacional debe:

- a. Contar con mecanismos de protección física y ambiental y dispositivos y controles de acceso adecuados para la protección de la información que permitan el acceso solamente al personal autorizado a las instalaciones de esta dependencia.
- b. Restringir, almacenar, mantener y/o guardar elementos inflamables dentro de la dependencia

- c. Contar con un libro de registro para el ingreso de funcionarios, contratistas y visitantes al área segura DIAN, por parte de la dependencia, en este se debe registrar: nombre, número de identificación, fecha y hora de entrada, y nombre del funcionario que autoriza el ingreso, a su vez realizar el acompañamiento constante del personal.
 - d. Portar el carnet de identificación durante la permanencia en esta área tanto para los funcionarios, contratistas y visitantes.
 - e. Implementar avisos que informen la restricción que existe en la misma, las cuales deben detallar que en ninguna circunstancia se puede fumar, comer o beber.
 - f. Designar a un funcionario específico para supervisar las actividades de limpieza en los datacenter. Con esta supervisión, a su vez, se impide el ingreso de maletas, bolsos u otros objetos que no sean propios de las tareas de aseo.
 - g. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la DIAN en el área segura, utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@bian.gov.co y el aplicativo GRC
 - h. Monitorear periódicamente los data center (Sitio 1- Sitio 2), confirmando que cumplen como mínimo con lo siguiente:
 - i. Que estén vacías y cerradas con llave.
 - j. Restringir el uso de equipo fotográfico, de video, audio u otro equipo de grabación, tales como cámaras en dispositivos móviles, a menos que se cuente con autorización para ello por parte de la dependencia encargada.
 - k. Con apoyo de un CCTV, visualizar el trabajo realizado en estas dependencias teniendo en cuenta que las cámaras no pueden apuntar directamente a la captura de información.
4. La Subdirección de Apoyo en la Lucha Contra el Delito Aduanero y Fiscal debe:
- a. Contar con mecanismos de protección física y ambiental y dispositivos y controles de acceso adecuados para la protección de la información que permitan el acceso solamente al personal autorizado a las instalaciones de esta dependencia.
 - b. Restringir, almacenar, mantener y/o guardar elementos inflamables dentro de la dependencia
 - c. Contar con un libro de registro para el ingreso de funcionarios, contratistas y visitantes al área segura DIAN, por parte de la dependencia, en este se debe registrar: nombre, número de identificación, fecha y hora de entrada, y nombre del funcionario que autoriza el ingreso, a su vez realizar el acompañamiento constante del personal.
 - d. Portar el carnet de identificación durante la permanencia en esta area tanto para los funcionarios, contratistas y visitantes.
 - e. Implementar avisos que informen la restricción que existe en la misma, las cuales deben detallar que en ninguna circunstancia se puede fumar, comer o beber.
 - f. Designar a un funcionario específico para supervisar las actividades de limpieza en los datacenter. Con esta supervisión, a su vez, se impide el ingreso de maletas, bolsos u otros objetos que no sean propios de las tareas de aseo.
 - g. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la DIAN en el área segura.
 - h. Monitorear periódicamente los data center (Sitio 1- Sitio 2), confirmando que cumplen como mínimo con lo siguiente:
 - i. Que estén vacías y cerradas con llave.

- j. Restringir el uso de equipo fotográfico, de video, audio u otro equipo de grabación, tales como cámaras en dispositivos móviles, a menos que se cuente con autorización para ello por parte de la dependencia encargada.
- k. Con apoyo de un CCTV, visualizar el trabajo realizado en estas dependencias teniendo en cuenta que las cámaras no pueden apuntar directamente a la captura de información.

5. La Oficina de Seguridad de la Información debe:

- a. Gestionar los roles y responsabilidades que permiten el control y asignación de permisos para el acceso a áreas seguras ubicadas dentro de las instalaciones de la **DIAN**.
- b. Monitorear periódicamente la asignación de privilegios relacionados con la gestión de accesos que permiten ingreso a las áreas seguras de la **DIAN**.
- c. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información de la **DIAN** utilizando los canales de comunicación definidos por la Oficina de Seguridad de la Información, entre los cuales está el buzón de la oficina: seguridaddigital@dian.gov.co el aplicativo GRC

K. Controles relacionados:

- 1. 5.34 – Protección de datos personales (PII).
- 2. 6.8 – Informes de eventos de seguridad de la información

7.7 Escritorio y pantalla despejados

A. Objetivo de control: establecer la política de escritorio y pantalla despejada para prevenir el acceso no autorizado, pérdida y/o daño de la información que se encuentra en los puestos de trabajo, equipos de cómputo, medios removibles, dispositivos de impresión y digitalización de documentos.

B. Alcance: el alcance de esta política aplica para la Subdirección de Soluciones y Desarrollo y la Subdirección Administrativa, dependencias encargadas de mantener las estaciones y/o puestos de trabajo, escritorios físicos o virtuales limpios y libres de información sensible para la entidad en las instalaciones de la **DIAN** y sus seccionales. También aplica para la Oficina de Seguridad de la Información, encargada de divulgar y sensibilizar del buen uso y manejo de la información en los puestos de trabajo.

C. Características del control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

- 1. La Subdirección Administrativa debe:
 - a. Mantener las estaciones o puestos de trabajo o escritorios, físicos o virtuales, limpios y estar libres de documentos, carpetas, archivos o medios que contengan información

sensible para la entidad con el fin de proteger los documentos físicos o electrónicos y reducir los riesgos de acceso no autorizado, pérdida o daño de la información.

2. La Oficina de Seguridad de la Información debe:

- a. Capacitar a los funcionarios y terceros con el objetivo de crear una cultura de seguridad en el uso de documentos de trabajo o archivos fuera de su lugar de conservación o almacenamiento, permitiendo que la utilización solo sea en función de su uso y de lo sensible de la información que contengan y permitiendo que, al alejarse del puesto de trabajo o escritorio y al finalizar la jornada de trabajo, la información quede bajo llave y protegida de cualquier acceso, uso o difusión indebida.

3. Los funcionarios y terceros de la entidad deben:

- a. Evitar dejar sesiones abiertas en los computadores y/o portátiles desatendidos, así como tabletas o teléfonos celulares.
- b. Apagar los equipos ante ausencias prolongadas y al final de cada jornada.
- c. Prevenir y no dejar, en el escritorio del computador, archivos de información ni accesos directos a estos archivos. Se deben almacenar los archivos en las carpetas virtuales habilitadas OneDrive y SharePoint de la dependencia destinadas para este fin.
- d. Verificar que todos los documentos físicos y electrónicos se resguarden, tanto al final de la jornada como cuando se aleje del puesto de trabajo.
- e. Ubicar los computadores personales y/o portátiles de forma que las pantallas no puedan ser visualizadas por personas no autorizadas.
- f. Evitar anotar las contraseñas en papeles, evitar colocarlas en el computador o debajo del equipo.
- g. Retirar del escritorio y guardar en una gaveta con llave los documentos, los medios y los dispositivos de almacenamiento removibles como CD, DVD, discos duros externos o memorias USB, autorizados en la **DIAN**, cuando no los estén utilizando y al final de la jornada de trabajo.
- h. Guardar en el archivo de gestión los expedientes físicos a cargo, al final de la jornada.
- i. Evitar dejar sobre los escritorios las llaves utilizadas para acceder a documentos de archivo (físico o electrónico).

Eliminar documentos de apoyo con información reservada o clasificada que no se utilice nuevamente, hacer uso de la máquina de picar y depositar los desechos en los recipientes de la máquina o de basura destinados para su recolección. Referirse a la documentación establecida por la DIAN para la determinación de los documentos que son considerados de apoyo.

- j. Evitar retirar de las instalaciones de la **DIAN** información (física o electrónica) y cualquier activo de información de propiedad de la entidad; solo se deben retirar en casos excepcionales autorizados por el jefe de la dependencia.
- k. Prevenir riesgos y amenazas de sustracción, destrucción, ocultamiento y/o utilización indebida de los recursos y la información contenida en ellos. Se deben mantener los escritorios virtuales limpios y libres de documentos, carpetas, archivos o medios que contengan información sensible para la entidad con el fin de proteger los documentos físicos o electrónicos y reducir los riesgos de acceso no autorizado, pérdida o daño de la información.

4. La Subdirección de Soluciones y Desarrollo debe:

- a. Resguardar en debida custodia los dispositivos y medios removibles de almacenamiento (bajo llave).
- b. Bloquear los computadores y/o portátiles cuando no estén en uso. Los computadores deben tener configurado el protector de pantalla, de forma que se active luego del tiempo de inactividad establecido por la Dirección de Gestión de Innovación y Tecnología.

Fortalecer los mecanismos y controles sobre las pantallas limpias enumerados en este control.

E. Controles relacionados:

1. 5.34 – Protección de datos personales (PII).
2. 5.36 – Cumplimiento de políticas, normas y estándares de seguridad de la información.
3. 6.8 – Informes de eventos de seguridad de la información.
4. 7.8 – Ubicación y protección del equipo.

7.8 Ubicación y protección del equipo

A. Objetivo de control: ubicar y proteger los equipos para reducir los riesgos de amenazas, peligros del entorno y accesos no autorizados.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, y la Subdirección Administrativa, dependencias encargadas de gestionar los equipos y recursos de cómputo en las instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Ubicar los equipos y dispositivos que son utilizados para soportar las funciones misionales y críticas de la entidad en las dependencias cuyo acceso sea restringido y esté supervisado.
 - b. Mantener durante horario no hábil o en horarios en los cuales el usuario interno no se encuentre en su sitio de trabajo, bajo seguridad, los dispositivos removibles, así como toda información reservada y clasificada de la **DIAN**, independientemente del medio en que se encuentre.
 - c. Ubicar en locaciones protegidas los equipos de cómputo e impresoras para reducir el riesgo de amenazas ambientales y de acceso no autorizado.
 - d. Instalar sistemas de protección eléctrica en las instalaciones que brinden protección ante eventos del clima relacionados con rayos y tormentas eléctricas, que puedan sobrecargar o afectar la infraestructura tecnológica de las instalaciones.
 - e. Implementar medidas de protección física y eléctrica en la plataforma tecnológica (Hardware, software y comunicaciones) en las instalaciones, con el fin de evitar daños, fraudes, interceptación de la información o accesos no autorizados.
 - f. Monitorear de forma periódica el funcionamiento de los dispositivos de seguridad que permiten la detección temprana de incidencias en los centros de cómputo, cableado, comunicaciones y cuartos técnicos de la **DIAN**.

- g. Proteger, a través de canaletas, el cableado de la energía y telecomunicaciones que llevan datos o sostienen los servicios de información, para evitar el deterioro e indisponibilidad del servicio.
 - h. Restringir el uso de activos de información pública reservada, pública clasificada o datos personales no públicos (Carpetas, archivos de uso diario, accesos directos y similares) por parte de los usuarios internos, para evitar el fácil acceso a la información.
 - i. Establecer los mecanismos o controles necesarios en sus procedimientos que permitan que existan, funcionen y se apliquen adecuada y efectivamente, las acciones para la ubicación y protección de equipos de la **DIAN** y se encuentren en procedimientos formales del Sistema de Gestión de Calidad.
 - j. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por inconvenientes en la ubicación y protección de equipos.
 - k. Instalar sistemas de protección eléctrica en los centros de cómputo, cableado, comunicaciones y cuartos técnicos de manera que se pueda interrumpir el suministro de energía en caso de emergencia. Así mismo, e debe proteger la infraestructura de procesamiento de información mediante contratos de mantenimiento y soporte.
2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
- a. Proteger y monitorear el mantenimiento físico y lógico de los dispositivos y sistemas de la infraestructura de seguridad.
 - b. Implementar en los centros de cómputo, cableado, comunicaciones y cuartos técnicos de la **DIAN**, dispositivos de seguridad que permitan la detección temprana de incidencias consideradas como mínimas a controlar.
 - c. Restringir los equipos de cómputo cuando se detecte o sospeche que el equipo se encuentra contaminado por un software malicioso, un virus o por una falla física.
 - d. Implementar y monitorear frecuentemente en los centros de cómputo, cableado, comunicaciones y cuartos técnicos, un sistema de detección y prevención de incendios que minimice el impacto que puede generar la ocurrencia de un evento o situación de incendio en el lugar.
 - e. Implementar y monitorear un sistema de refrigeración que sea capaz de enviar alarmas vía correo electrónico en caso de mal funcionamiento o futuro mantenimiento de equipos pertenecientes a los centros de cómputo de la **DIAN**.
 - f. Notificar de forma oportuna las alarmas de eventos relacionados con la energía, provenientes del sistema de regulación y estabilización del fluido eléctrico en las instalaciones de la **DIAN**.
 - g. Implementar medidas de protección física y eléctrica en la plataforma tecnológica (Hardware, software y comunicaciones) en los data center, con el fin de evitar daños, fraudes, interceptación de la información o accesos no autorizados.
 - h. Reportar a la Oficina de Seguridad de la Información los eventos incidentes que se puedan provocar en los centros de datos a cargo de terceros, sean estos On-premise, en la nube o híbridos.
 - i. Mantener durante las actividades de mantenimiento preventivo o correctivo, la concordancia con los intervalos y especificaciones del proveedor; así mismo, generar los registros a que haya lugar en donde se permita realizar la trazabilidad de las fallas, personas involucradas y actividades desarrolladas.
 - j. Restringir los privilegios de configuración del equipo, tales como conexiones de red, usuarios locales de la máquina, papel tapiz y protector de pantalla institucional, entre otros.

- k. Implementar un bloqueo automático de las sesiones de usuario en todas las estaciones de trabajo después de cinco minutos de inactividad.
 - l. Implementar y monitorear, en toda la infraestructura tecnológica, estándares de seguridad (hardening) para su funcionamiento.
 - m. Establecer los controles apropiados a los servicios de suministro que atenten contra los activos de información, así como identificarlos, clasificarlos, valorarlos, analizar sus riesgos y establecer los controles para mitigar la afectación a estos.
 - n. Ejecutar el procedimiento de borrado seguro antes de su reutilización o finalización de su vida útil, para cada uno de los equipos que contengan información pública reservada, pública clasificada o datos personales no públicos en sus medios de almacenamiento.
 - o. Capacitar a los usuarios internos responsables de computadores portátiles para que tengan los cuidados requeridos para el uso apropiado del equipo.
3. Los funcionarios y terceros de la entidad deben:
- a. Utilizar los equipos de manera exclusiva bajo la completa responsabilidad, únicamente para el desempeño de las funciones del cargo o las obligaciones contractuales pactadas. Por tanto, no pueden ser utilizados con fines personales o por terceros no autorizados.
 - b. No dejar descuidados ni desatendidos los equipos de cómputo o elementos que estén bajo su custodia.
 - c. Bloquear la sesión al retirarse de su puesto de trabajo.
 - d. Apagar el equipo de cómputo y mantenerlo apagado en caso de que no se encuentre en la oficina por largos periodos o durante la noche, con excepción de la realización de actividades vía remota o la ejecución de procesos propios de las funciones asignadas.
 - e. Evitar realizar actividades o maniobras que pongan en riesgo los equipos de cómputo, impresoras y demás equipos electrónicos y la información que contienen, (consumir alimentos, bebidas o fumar, entre otros).
 - f. No realizar cambios directamente en los datos o por personas no autorizadas en los equipos de trabajo.

E. Controles relacionados:

1. 5.34 – Protección de datos personales (PII).
2. 6.8 – Informes de eventos de seguridad de la información

7.9 Seguridad de los activos fuera de las instalaciones

- A. Objetivo de control:** aplicar medidas de seguridad a los activos que se encuentran fuera de las instalaciones de la entidad con el fin de mitigar la afectación a la confidencialidad, integridad y disponibilidad de los activos de información que sean retirados de la entidad.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, y la Subdirección Administrativa, dependencias encargadas de gestionar la seguridad de los equipos fuera de las instalaciones de la **DIAN** o sus seccionales, así como la Oficina de Seguridad de la Información encargada de divulgar y sensibilizar del cuidado y resguardo de elementos de cómputo fuera de la entidad.

C. Características del control:

1. Tipo de control: preventivo.

2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Notificar al jefe inmediato sobre la salida de los elementos de cómputo de las instalaciones de la DIAN.
 - b. Registrar cualquier activo de la DIAN que sea retirado de las instalaciones en el formato de salida establecido para dicho retiro temporal de bienes. En este se debe indicar el nombre del responsable.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Implementar mecanismos de seguridad y protección requeridos (maletín, guaya, cargador, espumas, empaque, soportes, candado, entre otros.) en los equipos portátiles, tabletas, discos duros e implementos de comunicaciones (cámaras fotográficas, de video, etc.) previo a su retiro de las instalaciones.
 - b. Deshabilitar los puertos de los equipos que cuenten con puertos de transmisión y recepción.
 - c. Implementar controles de seguridad para fortalecer la confidencialidad de la información en los equipos portátiles de la DIAN
 - d. Alinear los mecanismos de protección con las instrucciones dadas por los fabricantes de los equipos, de forma que la seguridad de estos equipos y activos fuera de las instalaciones sea la óptima.
3. La Oficina de Seguridad de la Información debe:
 - a. Capacitar a los funcionarios y terceros (si aplica) sobre el cuidado de los activos de información que son retirados de las instalaciones de la **DIAN**, de forma que por ningún motivo estén desatendidos en sitios públicos, en su lugar de permanencia, y durante su traslado.
 - b. Verificar que los principios y lineamientos establecidos en este numeral, para la seguridad de equipos y activos, fuera de las instalaciones de la **DIAN**
4. Los funcionarios y terceros de la entidad deben:
 - a. Informar inmediatamente a la Subdirección de Soluciones y Desarrollo, en caso de pérdida o robo de un computador portátil, adicionalmente se debe interponer la denuncia respectiva ante las autoridades competentes y hacer llegar copia de esta.
 - b. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en la seguridad de equipos y activos fuera de las instalaciones de la **DIAN**.

E. Controles relacionados:

1. 5.14 – Transferencia de información
2. 6.7 – Trabajo a Distancia
3. 6.8 – Informes de eventos de seguridad de la información
4. 7.4 – Supervisión de seguridad física
5. 7.5 – Protección contra amenazas físicas y ambientales

6. 8.1 – Dispositivos de punto final de usuario

7.10 Medios de almacenamiento

A. Objetivo de control: establecer los procedimientos para la gestión de medios removibles para evitar posibles riesgos y fugas de la información y, con ello, proteger la información de usos no autorizados, robo, pérdida, uso indebido o corrupción de información en el proceso de transporte o transferencia de medios físicos.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo y la Subdirección Administrativa, dependencias encargadas de gestionar la seguridad de los equipos y dispositivos que funcionan como medios de almacenamiento de información en las instalaciones de la **DIAN** y sus seccionales. También aplica para la Oficina de Seguridad de la Información, encargada de divulgar y sensibilizar sobre el buen uso de los medios removibles y proveer el material necesario sobre el cifrado de la información.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Establecer procedimientos formales para la disposición segura de medios y minimizar el riesgo de fugas de información y datos personales sensibles.
 - b. Disponer de un mecanismo de eliminación o residuos de aparatos electrónicos y debe dar cumplimiento a lo establecido en la política nacional de Gestión Integral de Residuos de Aparatos Eléctricos y Electrónicos (RAEE). En el caso de la información almacenada en discos duros, debe hacerse eliminación de la información de forma segura con el fin de confirmar la pérdida de información. Cuando a un Disco Duro por su obsolescencia o con daños irreparables y sea imposible hacerle el borrado seguro, se debe certificar que la información no sea recuperable.
 - c. Restringir la venta de documentos que hayan sido destruidos para reciclaje.
 - d. Realizar los registros de entradas y salidas de medios de almacenamiento en los casos de requerir transportes seguros. Estos registros deben considerar el detalle de los responsables durante el transporte la entrega, origen y destino del equipo o medio de almacenamiento, adicional, la protección aplicada, y las condiciones físicas que conserven la integridad, confidencialidad y disponibilidad de la información. Es obligatorio contar con la autorización formal para el retiro de equipos de cómputo, información o software de las instalaciones de la entidad.
 - e. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por inconvenientes en el retiro de equipos.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Implementar para cada requerimiento de uso de medios de almacenamiento, la documentación emitida en la entidad: procedimiento "PR-IIT-0460 Gestión de

- requerimientos”, formatos: “FT-IIT- 5264 Aceptación y autorización de uso de medios removibles”, “FT-IIT-2529 Registro de medios removibles entregados a terceros”.
- b. Restringir el uso y conexión de medios removibles como dispositivos de almacenamiento (celulares, memorias USB, discos duros externos, cintas, memorias flash, y otros medios de almacenamiento) sobre cualquier medio tecnológico de la entidad, salvo en casos en que los funcionarios, por su trabajo, requieran usar medios removibles.
 - c. Implementar los controles requeridos para que los medios removibles sean utilizados solo por quienes están autorizados y para fines específicos.
 - d. Restringir la ejecución de programas, software, o elementos que provengan de medios removibles; las personas autorizadas para la ejecución de programas en los equipos de la entidad son los funcionarios de la Dirección de Gestión de Innovación y Tecnología con esa responsabilidad o quien haga sus veces (Tanto en el nivel central como en las Direcciones Seccionales).
 - e. Cifrar la información que deba ser entregada a través medios removibles.
 - f. Restringir el uso de medios removibles para el manejo de información pública clasificada o publica reservada y que pueda afectar la protección de datos personales e información confidencial de la entidad. En caso de ser requerido, debe solicitarse la aprobación por parte del Oficial de Protección de Datos Personales para el manejo de este tipo de información y a su vez, utilizar técnicas de cifrado.
 - g. Llevar un registro de la eliminación de información en formato lógico o físico que se encuentre almacenada en medios removibles. Se debe incluir el motivo de la eliminación y el resultado de esta. Cuando se deba hacer la eliminación total de información, se debe contar con la aprobación del jefe inmediato; se debe hacer una copia de la información antes de eliminarla.
 - h. Monitorear la herramienta de antivirus implementada en la entidad, para confirmar que realiza un análisis de medios removibles detectando y evitando accesos de virus o malware en la plataforma de la entidad.
 - i. Confirmar la eliminación de la información de todo dispositivo antes de que sea asignado a otro funcionario.
 - j. Realizar un proceso de desmagnetización y sobrescritura segura (o similares), antes de hacerla eliminación física, para los casos de Discos Duros.
 - k. Utilizar para la destrucción de medios de almacenamiento algunos de los siguientes métodos si son físicos: desintegración, pulverización, fundición, incineración o trituración (o similares). En el caso de un medio óptico de almacenamiento, se debe realizar la pulverización, trituración de corte transversal o incineración.
 - l. Llevar un registro de la eliminación física, el motivo y el resultado de esta.
3. La Oficina de Seguridad de la Información debe:
- a. Capacitar a los funcionarios y terceros de la **DIAN** en relación con el uso de medios removibles, conforme con las políticas, procedimientos y los demás documentos que se tengan contemplados por la entidad.

E. Controles relacionados:

1. 5.14 – Transferencia de información
2. 6.8 – Informes de eventos de seguridad de la información
3. 7.14 – Eliminación segura o reutilización de equipos
4. 8.10 – Eliminación de información

7.11 Utilidades de apoyo

A. Objetivo de control: proteger los equipos de cómputo y procesamiento contra fallas de energía u otras interrupciones causadas por fallas en los servicios de suministro.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección Administrativa, esta dependencia será la encargada de gestionar los recursos físicos y servicios públicos en las instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de seguridad: integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:

El uso de la red de energía regulada debe estar restringido a los equipos de procesamiento de información y cómputo que lo requieran para su operación, con el fin de protegerlos y garantizar su disponibilidad.

Se debe disponer de mecanismos de respaldo y regulación de energía, tales como Sistemas de Alimentación Ininterrumpida (SAI/UPS), para proteger los equipos críticos contra fluctuaciones o interrupciones del suministro eléctrico.

- a. Suministrar plantas eléctricas a las sedes de la **DIAN** y confirmar su mantenimiento preventivo y correctivo de forma periódica.
- b. Establecer los procedimientos, mecanismos o controles necesarios en sus procedimientos para la correcta prestación de los servicios de suministro en la **DIAN** y que se encuentren en el Sistema de Gestión de calidad.
- c. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por inconvenientes en la prestación de los servicios de suministro.
- d. Suministrar mecanismos de alarmas para detectar fallas en los servicios públicos.
- e. Proporcionar iluminación de emergencia y comunicaciones. Los interruptores y válvulas de emergencia para cortar la energía, el agua, el gas u otros servicios públicos deben ubicarse cerca de las salidas de emergencia o las salas de equipos.
- f. Almacenar de manera segura el detalle de los contactos de emergencia, los cuales deben registrarse y estar disponibles para el personal en caso de un apagón. Así mismo, verificar que esta información no contenga datos personales más allá del nombre y número de teléfono del contacto.
- g. Inspeccionar periódicamente el correcto funcionamiento de los servicios públicos.

Confirmar que el equipo de apoyo a los servicios públicos esté en una red separada de las instalaciones de procesamiento de información.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información

7.12 Seguridad del cableado

A. Objetivo de control: proteger el cableado de energía eléctrica y de telecomunicaciones contra interceptación, interferencia o daño.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección Administrativa y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de administrar y proteger el cableado de las instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Establecer y mantener los procedimientos, mecanismos y controles necesarios para asegurar la integridad física del cableado y de las instalaciones que lo albergan en toda la DIAN.
 - b. Asegurar que los principios y lineamientos de seguridad del cableado se apliquen efectivamente y se integren en los procedimientos formales del Sistema de Gestión de Calidad.
 - c. Gestionar y reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos por fallas en la seguridad física del cableado.
 - d. Garantizar el buen estado y mantenimiento de la infraestructura física de los centros de cableado y centros de datos, incluyendo elementos estructurales, de cerramiento y de climatización.
 - e. Asegurar la inspección periódica de las instalaciones físicas e informar las novedades de infraestructura tecnológica a la subdirección correspondiente para su gestión. La gestión y corrección de fallos físicos es responsabilidad directa de esta subdirección.
 - f. Garantizar y gestionar el control de acceso físico a los centros de cableado y centros de datos, asegurando que solo personal autorizado ingrese a estas áreas y definiendo los protocolos para personal interno, externo y de servicios generales.
 - g. Verificar que la instalación del cableado de datos y de suministro de energía cumpla con los estándares definidos para protegerlo contra interceptación, interferencia o daños.
2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Definir los estándares y requerimientos técnicos de seguridad para el diseño y la protección del cableado de datos y de los espacios que lo contienen, los cuales deben ser implementados por la Subdirección Administrativa

- b. Definir, ejecutar y supervisar el plan de mantenimiento técnico de los activos de tecnología (equipos de red, servidores, etc.) y del cableado de datos alojados en los centros de cableado y centros de datos.
- c. Gestionar el acceso lógico a los equipos de tecnología que se encuentren dentro de los centros de cableado, asegurando la confidencialidad e integridad de la configuración de estos.
- d. Establecer los estándares para la organización, identificación y etiquetado del cableado de datos y de los puertos en los racks, para asegurar una gestión operativa eficiente y segura.
- e. Proveer la supervisión y el soporte técnico especializado a la Subdirección Administrativa durante actividades físicas que puedan impactar la operación o integridad de la infraestructura tecnológica.

E. Controles relacionados:

- 1. 6.8 – Informes de eventos de seguridad de la información
- 2. 7.2 – Entrada física
- 3. 7.3 – Asegurar oficinas, salas e instalaciones
- 4. 7.4 – Supervisión de la seguridad física.
- 5. 7.5 – Protección contra amenazas físicas y ambientales
- 6. 7.6 – Trabajar en áreas seguras

7.13 Mantenimiento de equipos

A. Objetivo de control: gestionar el correcto mantenimiento y funcionamiento de los equipos de la entidad para proteger su disponibilidad e integridad.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, dependencia encargada de gestionar el mantenimiento de equipos y recursos de cómputo en las instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Establecer y mantener un marco de gestión para el mantenimiento de equipos tecnológicos, que incluya los mecanismos de soporte, la gestión de incidentes y el reporte a la Oficina de Seguridad de la Información.
 - b. Asegurar que todas las actividades de mantenimiento (preventivo y correctivo) sean planificadas, programadas para minimizar el impacto en la operación y ejecutadas de acuerdo con las especificaciones del proveedor.

- c. Realizar evaluaciones de riesgo previas a las actividades de mantenimiento por parte de terceros, definiendo y aplicando el principio de mínimo privilegio para el acceso físico, lógico y de red que se les conceda.
- d. Garantizar que las obligaciones contractuales en materia de seguridad, privacidad de la información y cumplimiento legal y regulatorio queden estipuladas y sean exigibles a los terceros.
- e. Garantizar la supervisión de todo personal de terceros durante la ejecución de actividades de mantenimiento dentro de las instalaciones de la DIAN.
- f. Habilitar y gestionar infraestructuras de red segregadas para el uso de personal de terceros, monitoreando el acceso para prevenir la exposición de redes internas críticas.
- g. Establecer y aplicar los controles de seguridad para autorizar, registrar y monitorear las sesiones de mantenimiento remoto.
- h. Controlar la salida y reingreso de equipos de las instalaciones para fines de mantenimiento, asegurando que se apliquen las medidas de protección de activos fuera del perímetro de la entidad.
- i. Mantener un registro centralizado y detallado de todas las actividades de mantenimiento realizadas a los activos de información.
- j. Garantizar que los equipos que lleguen al final de su ciclo de vida sean gestionados a través de un proceso formal de eliminación segura o reutilización, de acuerdo con las políticas establecidas.

Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información
2. 7.9 – Seguridad de los activos fuera de las instalaciones
3. 7.14 – Eliminación segura o reutilización de equipos

7.14 Eliminación segura o reutilización de equipos

A. Objetivo de control: verificar que cualquier dato sensible o software licenciado haya sido retirado o sobrescrito en forma segura, antes de su eliminación, disposición o reúso del equipo.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, dependencia encargada de gestionar la disposición final o el reúso de equipos y recursos de cómputo en las instalaciones de la **DIAN** y sus seccionales.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Realizar una copia de respaldo, y someter a procedimientos de borrado seguro de información y software instalado a los equipos de cómputo que vayan a ser reasignados

o datos de baja, con el fin de evitar la pérdida de información o recuperación no autorizada de esta.

- b. Utilizar las técnicas adecuadas para el borrado o sobre escritura segura de acuerdo con la tecnología del medio de almacenamiento.
- c. Verificar que los principios y lineamientos establecidos en este literal, para la disposición segura o reutilización de equipos, se encuentren en procedimientos formales del Sistema de Gestión de Calidad y se apliquen efectivamente.
- d. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en los procesos de disposición segura o reutilización de equipos.
- e. Aplicar los anteriores lineamientos de seguridad a los medios de almacenamiento que contienen información antes de su eliminación o reutilización.

2. La Subdirección Administrativa debe:

- a. Otorgar elementos para la destrucción de información física en las dependencias que procesen altos volúmenes de información de carácter público clasificado (incluyendo datos personales) e información pública reservada.
- b. Establecer a través de Gestión Documental un procedimiento para la eliminación adecuada de información física.

1. Los funcionarios y terceros de la entidad deben:

- a. Destruir los documentos físicos antes de arrojarlos a basura, en caso tal que se vayan a reutilizar, se deben tachar los datos allí presentes.
- b. Impedir la reutilización de información física cuando esta contenga información de carácter público clasificado (incluyendo datos personales) e información pública reservada.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información
2. 7.10 – Medios de almacenamiento
3. 8.10 – Eliminación de información
4. 8.24 – Uso de criptografía

8. CONTROLES TECNOLOGICOS

A continuación, se describen los lineamientos y políticas que hacen referencia a las responsabilidades que establece la **DIAN** para la seguridad en los recursos tecnológicos:

8.1 Dispositivos de punto final de usuario

- A. Objetivo de control:** definir los parámetros y medidas de seguridad que deben implementar los funcionarios y terceros de la entidad para proteger los dispositivos de punto final de usuario y la información procesada y almacenada en estos, de tal manera que estén resguardados de pérdida, daño, acceso o divulgación no autorizada.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, la Subdirección Administrativa y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de gestionar la seguridad y protección de seguridad para los equipos de punto final de usuario en las instalaciones de la **DIAN**, sus seccionales y equipos personales que manejen información de la entidad.

C. Características del control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección Administrativa debe:
 - a. Realizar la autorización, entrega y control del uso de dispositivos móviles, de acuerdo con el perfil del cargo, funciones, y necesidades específicas de cada dependencia, según la autorización definida por la Dirección de Gestión de Innovación y Tecnología.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Definir un control de cifrado para los dispositivos de punto final de usuario.
 - b. Establecer lineamientos de ingreso y salida de las instalaciones de los dispositivos de punto final.
 - c. Establecer lineamientos para la adecuada custodia, conservación, operación y mantenimiento de los dispositivos de punto final de usuario o que manejen información de la entidad en dispositivos personales.

Definir controles lógicos para el acceso a diferentes aplicaciones y/o sistemas de la entidad a través de dispositivos de punto final de usuario.

- d. Revisar los requisitos de seguridad de los medios removibles que se utilicen para acceder a la información desde redes externas.
- e. Definir medidas de seguridad en cuanto software y antivirus de los dispositivos móviles utilizados para manejo de información, labores contractuales y funciones de la entidad, así como doble factor de autenticación.
- f. Establecer los lineamientos para conexiones de visitantes y usuarios internos que ingresen a la entidad dispositivos propios.
- g. Bloquear el acceso de los dispositivos de punto final de usuario en propiedad de terceros, contratistas y/o usuarios externos a el dominio de la **DIAN**: "dian.gov.co"; para conectarse a los servicios de la red de datos se debe realizar una solicitud a la mesa de ayuda y cumplir con los lineamientos referentes definidos por esta.
- h. Monitorear los dispositivos móviles institucionales y personales, que gestionen cualquier activo de información a través de las herramientas de gestión tecnológica definidas por la entidad.
- i. Realizar verificación de los dispositivos de punto final de usuario cuando se requiera de forma remota, sin que para ello se necesite la autorización de la persona a la que se le haya asignado y generar el reporte respectivo.
- j. Entregar elementos de seguridad -tipo guaya- para los dispositivos de punto final de usuario cuando sea necesario.
- k. Brindar soporte a los usuarios internos responsables de los dispositivos de punto final únicamente en las instalaciones de la entidad, sobre los aplicativos y sistemas instalados en los equipos suministrados.

- l. Registrar todos los casos de soporte de los dispositivos de punto final de usuario en la herramienta de gestión de mesa de ayuda.
 - m. Brindar el soporte a los equipos en modalidad de Teletrabajo y de acuerdo con lo establecido en la Circular 000496 de 9 mayo de 2022 o la que la sustituya.
 - n. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de los dispositivos de punto final.
 - o. Configurar en todos los computadores de la **DIAN** un protector de pantalla con tiempo máximo de cinco minutos para que se active cuando el equipo no esté en uso.
3. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Aplicar los procedimientos establecidos para la conservación de la información (copias de respaldo), formateo y reinstalación de las aplicaciones o servicios requeridos por el nuevo responsable del equipo.
4. Los funcionarios y terceros de la entidad deben:
 - a. Solicitar la autorización a la Subdirección de Soluciones y Desarrollo para el uso de aplicaciones dentro de los dispositivos de punto final de usuario que sean de su propiedad (computador portátil, celular Smartphone, Tablet y similares).
 - b. Permitir que se habiliten las funcionalidades de auditoría y control de la información almacenada en los dispositivos de punto asignados.
 - c. Tomar medidas y precauciones necesarias para la adecuada custodia, conservación, operación y mantenimiento de los dispositivos de punto final de usuario o que manejen información de la entidad en dispositivos personales; además, cumplir las disposiciones administrativas y técnicas aplicables definidas por la Oficina de Seguridad de la Información y la Dirección de Gestión de Innovación y Tecnología.
 - d. Responder por el cuidado, manipulación y seguridad en todo momento de los dispositivos de punto final de usuario que, por necesidades del servicio, requieran ser transportados fuera de las instalaciones de la entidad.
 - e. Dar cumplimientos a los lineamientos de ingreso y salida de los dispositivos de punto final estipulados por la Dirección de Gestión de Innovación y Tecnología.
 - f. Hacerse responsables de las llaves asignadas (llaves de guayas, llaves de cajones y similares) para el almacenamiento y cuidado de los dispositivos de punto final que se les asigne.
 - g. Utilizar las herramientas de cifrado cuando se requiere para el cuidado apropiado de la información pública clasificada y publica reservada que tenga a cargo.
 - h. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de los dispositivos de punto final asignados.
 - i. Bloquear la pantalla del computador a su cargo cuando se ausenten de su puesto de trabajo, con el fin de impedir el acceso de terceros no autorizados a la información almacenada en el computador.
 - j. Evitar tener sobre el escritorio información propia de la entidad en medios de almacenamiento, en su lugar, se debe guardar en un lugar seguro para impedir su pérdida, daño, copia o acceso por parte terceros o personal que no tenga autorización para su uso o conocimiento.
 - k. Evitar que, durante el uso de impresoras en la **DIAN**, se descuiden documentos con información clasificada y/o reservada que haya sido impresa.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información
2. 8.9 - Gestión de la configuración
3. 8.16 - Actividades de seguimiento

8.2 Derechos de acceso privilegiado

A. Objetivo de control: restringir y controlar los accesos privilegiados, para la asignación y uso de derechos de acceso a los diferentes programas, servicios, aplicativos, bases de datos y cualquier acceso a actividades específicas de la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de gestionar el aprovisionamiento de usuarios privilegiados y de administración en los sistemas e infraestructura de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Definir, aprobar y socializar un procedimiento de solicitud y autorización de derechos de acceso privilegiado de acuerdo con la política de control de acceso específica que maneja la entidad.
 - b. Autorizar, otorgar y confirmar que los privilegios para la administración de los sistemas de información sean asignados solamente a los funcionarios que tengan las competencias requeridas para cumplir sus funciones.
 - c. Mantener un listado actualizado de los funcionarios con accesos privilegiados y de administración en cada uno de los sistemas de información.
 - d. Establecer los controles para que los usuarios de los recursos tecnológicos, los servicios de red y los sistemas de información no puedan instalar programas o aplicar configuraciones críticas en sus equipos de cómputo utilitarios, que permitan escalar privilegios o evadir controles de seguridad informáticos.
 - e. Aprobar, actualizar y socializar con los grupos internos de trabajo de tecnología, el listado de programas utilitarios de uso autorizado para la operación de la plataforma tecnológica, los servicios de red y sistemas de información. Adicionalmente, se deben retirar o deshabilitar los programas utilitarios privilegiados no autorizados.
 - f. Restringir las conexiones remotas a los recursos de la plataforma tecnológica, permitiendo únicamente el acceso a los funcionarios autorizados.
 - g. Monitorear y deshabilitar los servicios o funcionalidades no utilizadas de los sistemas operativos, firmware y bases de datos, cuando los funcionarios hayan sido retirados de sus funciones o se encuentren en una situación administrativa que los separe temporalmente de sus funciones; por ejemplo, en periodos de vacaciones.
 - h. Configurar, para el correcto uso, las carpetas de uso interno de la entidad preservando la integridad, confidencialidad y disponibilidad de la información.

- i. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en los procesos de aprovisionamiento de usuarios privilegiados.
2. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Mantener un listado actualizado de los funcionarios con accesos privilegiados y de administración en cada uno de los servidores, sistemas operativos, bases de datos y directorio activo de la entidad.
 - b. Aprovisionar los debidos accesos a los diferentes sistemas operativos y conexiones de bases de datos evitando el uso indebido de utilitarios que puedan afectar la seguridad los sistemas de información alojados sobre la plataforma tecnológica.
 - c. Restringir los puertos que permitan realizar mantenimiento y soporte remoto a los equipos de red, servidores y equipos de usuario final, permitiendo el acceso únicamente a los administradores de red.
 - d. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en los procesos de aprovisionamiento de usuarios privilegiados.
 3. Los funcionarios y terceros de la entidad deben:
 - a. Permitir tomar el control remoto de sus equipos a la mesa de ayuda, para esto debe evitar tener archivos con información sensible a la vista y debe permanecer atento al equipo mientras el tercero tiene control sobre este.
 - b. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en los procesos de aprovisionamiento de usuarios privilegiados.

E. Controles relacionados:

1. 5.15 – Control de acceso.
2. 5.17 – Información de autenticación.
3. 5.18 – Derechos de acceso.
4. 6.8 – Informes de eventos de seguridad de la información.

8.3 Restricción de acceso a la información

- A. Objetivo de control:** restringir el acceso a la información, sistemas de información y aplicaciones únicamente a personal autorizado, de acuerdo con la política de control de acceso establecida en este manual.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, dependencia encargada de gestionar los accesos a la información en los equipos de cómputo de la **DIAN** y sus seccionales.
- C. Características de control:**
 1. Tipo de control: preventivo.
 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Segmentar, a través de roles, los privilegios de los usuarios dentro del sistema de información.
 - b. Confirmar que se aplican los lineamientos de seguridad para el control de acceso a información electrónica teniendo en cuenta los niveles de clasificación y el manejo de intercambio de información.
 - c. Prohibir el acceso a información sensible por parte de usuarios con identidades desconocidas.
 - d. Proporcionar mecanismos para controlar el acceso a la información.
 - e. Controlar a qué datos puede acceder un usuario de los sistemas de información.
 - f. Controlar qué identidades o grupo de identidades tienen acceso a los sistemas de información.
 - g. Establecer controles de acceso lógicos a los sistemas de información.
2. La Subdirección Administrativa debe:
 - a. Restringir el acceso a información física teniendo en cuenta los niveles de clasificación y el manejo de intercambio de información.
3. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Identificar, según los niveles de clasificación de información, cuáles sistemas son considerados sensibles y gestionar ambientes tecnológicos aislados e independientes.
 - b. Aislar los sistemas de información clasificados como sensibles de otras fuentes de datos, con el objetivo de proteger la información desde los ambientes lógicos.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información

8.4 Acceso al código fuente

- A. Objetivo de control:** restringir el acceso al código fuente de los sistemas de información, aplicaciones y software de la entidad.
- B. Alcance:** el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones y la Subdirección de Soluciones y Desarrollo, dependencias encargadas de gestionar la seguridad del código fuente de los sistemas y aplicaciones de la DIAN.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Autorizar, registrar y monitorear periódicamente todos los accesos al código fuente de los programas y sistemas de información de la entidad aplicando los principios de conservación de la información; el acceso al código fuente debe estar protegido mediante contraseñas con un alto nivel de cifrado.
Restringir el acceso a los elementos asociados como diseños, especificaciones, planes de verificación y de validación, únicamente a personal autorizado y bajo supervisión de actividades.
 - b. Ubicar en un equipo fuera de la red de la entidad y de accesos a internet, el código que se encuentre libre para pruebas específicas antes de ser enviado a producción.
 - c. Inhabilitar puertos de USB, Bluetooth, RF (Radio Frecuencia) de los equipos utilizados para este tipo de pruebas, salvo que el jefe de la Oficina de Seguridad de la Información los autorice.
 - d. Restringir el acceso directo al repositorio del código fuente a los desarrolladores, solo permitir el acceso a través de herramientas a los desarrolladores para el debido control de actividades y autorizaciones.
 - e. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren acceso indebido al código fuente.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Utilizar el código que se encuentre libre de vulnerabilidades antes de ser enviado a producción.
 - b. Restringir la actualización del código fuente, componentes asociados y otorgar el acceso al código fuente, únicamente con los procedimientos de control de cambios.
 - c. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren acceso indebido al código fuente.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información.
2. 8.32 – Gestión del Cambio.

8.5 Autenticación segura

A. Objetivo de control: permitir el ingreso a sistemas de información y aplicaciones de la **DIAN** mediante un inicio seguro de sesión.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de gestionar las características de autenticación en programas, sistemas de información e infraestructura de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Restringir la visualización de información por el sistema hasta que el proceso de inicio se haya completado satisfactoriamente.
 - b. Inhabilitar mensajes de ayuda durante el proceso de autenticación.
 - c. Validar los datos de acceso una vez se han diligenciado todos los datos de entrada.
 - d. Limitar el número de intentos fallidos de conexión auditando los intentos no exitosos.
 - e. Bloquear la visualización de contraseñas digitadas.
 - f. Implementar mecanismos de protección contra intentos de inicio de sesión de fuerza bruta en nombres de usuario y contraseñas en programas y sistemas de información.
 - g. Generar un evento de seguridad si se detecta un intento potencial o una violación exitosa de los controles de inicio de sesión.
 - h. Finalizar las sesiones inactivas después de un período definido de inactividad.
 - i. Restringir los tiempos de duración de la conexión.
 - j. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en el proceso de autenticación.
2. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Restringir la visualización de información de las bases de datos, sistema operativo, configuraciones de autenticación y Directorio Activo, hasta que el proceso de inicio se haya completado satisfactoriamente.
 - b. Inhabilitar mensajes de ayuda durante el proceso de autenticación en los sistemas de información.
 - c. Limitar el número de intentos fallidos de conexión auditando los intentos no exitosos.
 - d. Bloquear la visualización de contraseñas digitadas.
 - e. Implementar mecanismos de protección contra intentos de inicio de sesión de fuerza bruta en nombres de usuario y contraseñas en bases de datos, sistema operativo y directorio activo.
 - f. Generar un evento de seguridad si se detecta un intento potencial o una violación exitosa de los controles de inicio de sesión.
 - g. Finalizar sesiones inactivas después de un período definido de inactividad en los sistemas de información.
 - h. Restringir los tiempos de duración de la conexión en los sistemas de información.
 - i. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en el proceso de autenticación.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información.

8.6 Gestión de capacidad

A. Objetivo de control: gestionar la capacidad, tanto de recursos humanos como de oficinas, instalaciones, y la tecnología, con el fin de evitar pérdidas de disponibilidad o rendimiento de los sistemas de información.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura tecnológica y de Operaciones, Subdirección Administrativa y Subdirección de Desarrollo del Talento Humano, dependencias encargadas de gestionar la disposición de recursos físicos, tecnológicos y humanos de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de Seguridad: integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Planear y gestionar la capacidad de procesamiento requerida en los recursos tecnológicos de la información de la **DIAN**, efectuando proyecciones de crecimiento y provisiones en la plataforma tecnológica por lo menos una vez al año.
 - b. Optimizar los servicios tecnológicos y sistemas de información, al igual que la verificación de capacidad de los servicios de red de la entidad, contemplando el aumento o disminución de recursos tecnológicos
 - c. Realizar actividades de monitoreo, revisión, proyección y soporte oportuno para el uso y desempeño aceptable de capacidad de la infraestructura tecnológica.
 - d. Realizar un plan de gestión de la capacidad para sistemas críticos de la entidad. Este plan debe ser formalizado en el Sistema de Gestión de Calidad.
2. La Subdirección Administrativa debe:
 - a. Planear y gestionar la capacidad de los recursos físicos de la **DIAN**, efectuando proyecciones de crecimiento por lo menos una vez al año y confirmar si existe la necesidad de espacios o instalaciones para el desarrollo de las actividades de la entidad.
 - b. Realizar actividades de monitoreo, revisión y soporte de la capacidad sobre la infraestructura física de la entidad.
3. La Subdirección de Desarrollo del Talento Humano debe:
 - a. Planear y gestionar la capacidad de los recursos humano de la **DIAN**, como parte de las actividades de administración del programa de desempeño de la entidad.
 - b. Definir la necesidad de nuevo personal para apoyar las actividades de la entidad.

E. Controles relacionados: No aplica.

8.7 Protección contra malware

A. Objetivo de control: proteger los equipos de cómputo para reducir los riesgos de amenazas, peligros del entorno y accesos no autorizados.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura tecnológica y de Operaciones y la Subdirección de Soluciones y Desarrollo, Oficina de seguridad de la información y Los funcionarios y terceros de la entidad, quienes están involucrados en la gestión de la seguridad lógica de los recursos tecnológicos de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo, detectivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Disponer de herramientas como antivirus, antimalware, antispam y antispyware que reduzcan el riesgo ocasionado por software malicioso y que respalden la seguridad digital contenida y administrada en la plataforma tecnológica de la **DIAN** y los servicios que se ejecutan en la misma.
 - b. Confirmar que el software de antivirus, antimalware, antispyware y antispam cuente con las licencias de uso requeridas, certificando su autenticidad, posea las últimas actualizaciones y parches de seguridad y la posibilidad de actualización periódica de las últimas bases de datos de firmas del proveedor de servicios, para mitigar las vulnerabilidades de la plataforma tecnológica.
 - c. Confirmar que toda la información almacenada en la plataforma tecnológica sea escaneada por el software de antivirus, incluyendo la información que se encuentra contenida y transmitida por el servicio de correo electrónico.
 - d. Restringir la posibilidad a usuarios internos y externos de realizar cambios en la configuración del software de antivirus, antispyware, antispam y antimalware.
 - e. Configurar e implementar escaneos periódicos al software y el contenido de los sistemas de información que apoyan los procesos críticos de la entidad.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Verificar que, en los casos en que los usuarios internos deban utilizar equipos que no pertenezcan a la entidad, cumplan con la legalidad del software instalado, antivirus licenciado y actualizado. Que solo puedan conectarse a la red una vez hayan obtenido en aval de la Dirección de Gestión de Innovación y Tecnología.
 - b. en coordinación con la Oficina de Seguridad de la Información, quien validará los aspectos relacionados con la seguridad y privacidad de la información, antes de la inclusión o modificación de cualquier software en dicho listado.
3. La Oficina de Seguridad de la Información debe:
 - a. Incorporar en el programa de capacitación dirigido a servidores públicos, colaboradores y terceros vinculados a la DIAN, estrategias para identificar los riesgos asociados al software malicioso.

- b. Registrar de manera oportuna y precisa los incidentes relacionados con software malicioso que afecten la confidencialidad, integridad o disponibilidad de la información institucional, con el fin de facilitar su análisis, documentar las lecciones aprendidas y fortalecer los controles definidos.
4. Los funcionarios y terceros de la entidad deben:
- a. Emplear los equipos y recursos de cómputo de manera exclusiva y bajo la completa responsabilidad del usuario interno al cual fueron asignados, únicamente para el desempeño de las funciones del cargo o las obligaciones contractuales pactadas. Por tanto, no podrán ser utilizados con fines personales o por terceros no autorizados.
 - b. Evitar la manipulación directa o por personas no autorizadas de los equipos a su cargo, y en caso necesario se deberá acudir a la Subdirección de Soluciones y Desarrollo a través de la mesa de ayuda para solicitar instalación de software en los equipos de la **DIAN**.
 - c. Evitar cambiar o eliminar la configuración del software de antivirus, antispyware, antimalware y antispam definida por la Subdirección de Soluciones y Desarrollo.
 - d. Realizar tareas de escaneo de virus en diferentes medios previamente a su uso.
 - e. Abstener el uso del equipo de cómputo cuando se detecte o sospeche que el equipo se encuentra contaminado por software malicioso, virus o por una falla física.
 - f. Evitar descargar archivos de internet de fuentes desconocidas, abrir o ejecutar archivos y/o documentos de fuentes desconocidas, especialmente los que se encuentran en medios de almacenamiento externo o que provienen de correos electrónicos desconocidos.
 - g. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas en el equipo por motivos de rendimiento, errores y mensajes de alertas o por sospecha de algún daño o ataque por software malicioso.

E. Controles relacionados:

1. 6.3 – Concientización, educación y capacitación en seguridad de la información.
2. 6.8 – Informes de eventos de seguridad de la información.
3. 8.8 – Gestión de vulnerabilidades técnicas.
4. 8.13 – Copia de seguridad de la información
5. 8.19 – Instalación de software en sistemas operativos.
6. 8.32 – Gestión del cambio.

8.8 Gestión de vulnerabilidades técnicas

- A. Objetivo de control:** obtener de manera oportuna la información actualizada sobre vulnerabilidades técnicas que puedan afectar los activos tecnológicos de la DIAN, con el fin de evaluar su nivel de exposición y adoptar las medidas necesarias para gestionar los riesgos asociados.
- B. Alcance:** el alcance de esta política aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones y la Subdirección de Soluciones y Desarrollo, dependencias encargadas de gestionar las configuraciones de hardware, software, servicios y redes de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Verificar que se realice la identificación de vulnerabilidades por parte de la SITO una vez al año.
 - b. Definir indicadores que permitan el monitoreo continuo y la toma de decisiones informadas respecto a las vulnerabilidades técnicas identificadas en los activos tecnológicos de la DIAN.
 - c. Realizar seguimiento hasta el cierre de las vulnerabilidades clasificadas como críticas, altas y medias, y validar la efectividad de las acciones de mitigación.
 - d. En los casos que se considere necesario, instar a los proveedores de sistemas de información, a la Subdirección de Infraestructura Tecnológica y de Operaciones, y a la Subdirección de Soluciones y Desarrollo, a entregar las evidencias de los análisis de vulnerabilidades realizados sobre sus sistemas e infraestructura tecnológica.
2. La Subdirección de Infraestructura tecnológica y de operaciones debe:
 - a. Cumplir con las políticas y la normatividad de seguridad de la información vigentes en la entidad, aplicables a todos los sistemas, infraestructuras y activos tecnológicos utilizados en la DIAN.
 - b. Contar y mantener las herramientas y/o contratos de soporte que permitan aplicar oportunamente las actualizaciones en las distintas plataformas utilizadas.
 - c. Aplicar actualizaciones de software, firmware o parches de seguridad de manera planificada, previa validación mediante pruebas en entornos controlados, con el fin de prevenir impactos negativos en el funcionamiento de las aplicaciones en los entornos de producción.
 - d. Realizar análisis periódicos de vulnerabilidades de seguridad en la infraestructura tecnológica, generar los respectivos informes técnicos y reportar a la Oficina de Seguridad de la Información cualquier vulnerabilidad identificada.
 - e. Coordinar con la Oficina de Seguridad de la Información la elaboración y ejecución de planes de remediación para las vulnerabilidades detectadas, o la implementación de controles alternos.
 - f. Coordinar con la Oficina de Seguridad de la Información la generación y ejecución de planes de remediación de las vulnerabilidades detectadas o implementación de controles alternos.
 - g. Implementar los controles mitigatorios, que ha sido diseñados o aprobados por la Oficina de Seguridad de la Información, en los casos en que no sea posible realizar las remediaciones necesarias.
 - h. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que impliquen la pérdida, daño, robo o compromiso de información, como consecuencia de fallas asociadas a vulnerabilidades en los activos tecnológicos.
3. La Subdirección de Soluciones y Desarrollo debe:

- a. Asegurar que todos los desarrollos de software, propios o subcontratados se sometan a pruebas de análisis de vulnerabilidades de seguridad antes de su paso a producción.
- b. Realizar el monitoreo en producción de los desarrollos de software y, en caso de detectar vulnerabilidades que comprometan la seguridad, elaborar los informes técnicos correspondientes y reportarlos a la Oficina de Seguridad de la Información, conforme a los recursos y capacidades disponibles.
- c. Coordinar con la Oficina de Seguridad de la Información la generación y ejecución de planes de remediación de las vulnerabilidades detectadas o implementación de controles alternos.
- d. Implementar los controles mitigatorios, que ha sido diseñados o aprobados por la Oficina de Seguridad de la Información, en los casos en que no sea posible realizar las remediaciones necesarias.
- e. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que impliquen la pérdida, daño, robo o compromiso de información, como consecuencia de fallas asociadas a vulnerabilidades en los activos tecnológicos.

E. Controles relacionados:

1. 5.9 – Inventario de información y otros activos asociados.
2. 5.14 – Transferencia de información.
3. 5.20 – Abordar la seguridad de la información en los acuerdos con los proveedores.
4. 5.22 – Seguimiento, revisión y gestión de cambios de servicios de proveedores.
5. 5.26 – Respuesta a incidentes de seguridad de la información.
6. 6.8 – Informes de eventos de seguridad de la información.
7. 8.8 – Gestión de vulnerabilidades técnicas.
8. 8.9 – Gestión de la configuración.
9. 8.28– Codificación segura.
10. 8.30– Desarrollo subcontratado.
11. 8.32– Gestión del Cambio.

8.9 Gestión de la configuración

A. Objetivo de control: establecer, documentar, implementar, socializar, monitorear y revisar las configuraciones, incluidas las de seguridad, de hardware, software, servicios y redes para permitir que el *hardware*, el *software*, los servicios y las redes funcionen correctamente con la configuración de seguridad requerida y que la configuración no se altere por cambios no autorizados o incorrectos.

B. Alcance: el alcance de esta política aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones y la Subdirección de Soluciones y Desarrollo, dependencias encargadas de gestionar las configuraciones de hardware, software, servicios y redes de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:

- a. Definir y establecer plantillas de configuraciones de seguridad para los equipos de cómputo de punto final de la entidad y mantener actualizada la plantillas, así como para software propio, de terceros y sistemas operativos durante su vida útil.
- b. Definir e implementar roles, responsabilidades y procedimientos para permitir un control satisfactorio de todos los cambios de configuración de los equipos de cómputo de punto final y sistemas que se desarrollen para la entidad. Para ello, se debe considerar:
 - Minimizar el número de identidades con derechos de acceso privilegiados o de nivel de administrador.
 - Deshabilitar identidades innecesarias, no utilizadas o inseguras.
 - Deshabilitar o restringir funciones y servicios innecesarios.
- c. Integrar la gestión de la configuración con los procesos de gestión de activos y las herramientas asociadas.
- d. Proteger las plantillas de configuraciones de seguridad de equipos de punto final como información confidencial, por lo cual debe resguardarse contra el acceso no autorizado.
- e. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas asociadas a configuraciones de seguridad.

2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:

- a. Definir y establecer plantillas de configuraciones de seguridad para hardware, software, servicios (por ejemplo, servicios en la nube) y redes, para sistemas recién instalados, así como para sistemas operativos durante su vida útil.
- b. Garantizar que se implementen roles, responsabilidades y procedimientos para permitir un control satisfactorio de todos los cambios de configuración en los sistemas e infraestructura. Para ello, se debe considerar:
 - Minimizar el número de identidades con derechos de acceso privilegiados o de nivel de administrador.
 - Deshabilitar identidades innecesarias, no utilizadas o inseguras.
 - Deshabilitar o restringir funciones y servicios innecesarios.
- c. Establecer las configuraciones y requisitos de seguridad de la información pertinentes para los dispositivos de propiedad del proveedor, en los que se almacene, procese o transite información de la **DIAN**.
- d. Revisar y actualizar las plantillas de configuraciones de seguridad, de forma preventiva o cuando los proveedores de los equipos indiquen actualizaciones de seguridad recomendadas.
- e. Implementar procesos y herramientas para hacer cumplir las configuraciones definidas (incluidas las configuraciones de seguridad) para hardware, software, servicios (por ejemplo, servicios en la nube) y redes.
- f. Revisar periódicamente las configuraciones de hardware, software, servicios y redes para confirmar que su funcionamiento este alineado con lo definido por la entidad en sus respectivas plantillas.
- g. Permitir la realización de configuraciones en la infraestructura asignada únicamente a personal autorizado de la Subdirección de Infraestructura Tecnológica y de Operaciones y aplicar la gestión de cambios para efectuar modificaciones en las configuraciones.
- h. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por fallas asociadas a configuraciones de seguridad.

E. Controles relacionados:

1. 5.32 – Derechos de propiedad intelectual.
2. 6.8 – Informes de eventos de seguridad de la información.
3. 8.32 – Gestión del Cambio.

8.10 Eliminación de información

A. Objetivo de control: eliminar de forma segura la información almacenada en sistemas de información, dispositivos o en cualquier otro medio de almacenamiento cuando ya no sea necesaria, con el fin de evitar la exposición innecesaria de información confidencial y cumplir con los requisitos legales, estatutarios, reglamentarios y contractuales para la eliminación de información.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, dependencia encargada de gestionar las necesidades tecnológicas de los sistemas de información en las instalaciones de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Eliminar información sobre sistemas, aplicaciones y servicios que no sea de valor para los procesos de la entidad.
 - b. Eliminar versiones obsoletas, copias y archivos temporales dondequiera que se encuentren.
 - c. Usar un software de eliminación seguro y aprobado por la entidad para eliminar información de forma permanente, confirmando que no se pueda recuperar mediante el uso de herramientas forenses o de recuperación especializadas.
 - d. Usar proveedores aprobados y certificados de servicios de eliminación segura.
 - e. Utilizar mecanismos de eliminación apropiados para el tipo de medio de almacenamiento que se va a eliminar (desmagnetización de unidades de disco duro y otros medios de almacenamiento magnético).
 - f. Eliminar la información confidencial cuando el equipo se devuelve a los proveedores, eliminando los almacenamientos auxiliares (por ejemplo, unidades de disco duro) y la memoria antes de que el equipo abandone las instalaciones de la **DIAN**.
 - g. Elegir el método adecuado cuando se requiera eliminar de forma segura la información confidencial en algunos dispositivos (por ejemplo: teléfonos inteligentes) mediante la destrucción o el uso de las funciones integradas en estos dispositivos (por ejemplo: "restaurar la configuración de fábrica").
 - h. Destruir físicamente el dispositivo de almacenamiento y eliminar simultáneamente la información que contiene.

- i. Oficializar las actividades de borrado de información, que permitan analizar la causa de un evento de fuga de información.
- j. Reportar a la Oficina de Seguridad de la Información los eventos e incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por incidentes asociados a fuga de información o por fallas en los procesos de disposición segura o reutilización de equipos.
- k. Conservar la información confidencial por el tiempo necesario para su resguardo, para reducir el riesgo de divulgación no deseada.
- l. Verificar si el método de eliminación proporcionado por el proveedor de servicios en la nube es adecuado. En caso afirmativo, determinar si la entidad debe usar el método o solicitar al proveedor de servicios en la nube elimine la información.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información
2. 7.14 – Eliminación segura o reutilización de equipos

8.11 Enmascaramiento de datos

A. Objetivo de control: limitar la exposición de datos confidenciales, incluida la privacidad y protección de la información de identificación personal para cumplir con los requisitos legales, estatutarios, reglamentarios y contractuales por medio del enmascaramiento de datos.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, encargada de coordinar y adelantar procesos de especificaciones técnicas, desarrollo interno o con terceros, procesos de calidad, actualización, mantenimiento, corrección y mejora de los sistemas de información y servicios digitales de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Promover técnicas como seudonimización o anonimización para ocultar la verdadera identidad de los titulares y desconectar el vínculo entre titular y datos.
 - b. Verificar que los datos hayan sido adecuadamente seudonimizados o anonimizados. La anonimización de datos debe considerar todos los elementos de la información sensible para ser efectivos.
 - c. Seleccionar alguna de las técnicas adicionales para efectuar el enmascaramiento de datos: cifrado, anular o eliminar algunos caracteres, sustitución de valores, reemplazos con su hash u ofuscación de datos.
 - d. Diseñar consultas y máscaras para mostrar solo los datos mínimos requeridos al usuario consultante.
 - e. Implementar acuerdos o restricciones en el uso de los datos procesados.
 - f. Prohibir que sean cotejados los datos procesados con otra información para identificar al principal titular de la información personal.

- g. Realizar un seguimiento del suministro y recepción de los datos tratados.
- h. Ocultar la verdadera identidad de los titulares de datos personales en casos donde se sospeche de situaciones de riesgo para la protección de la información personal.
- i. Implementar las consultas o máscaras de datos definidas en las bases de datos y todo repositorio de datos personales o sensibles.
- j. Implementar para los datos reemplazados con su hash, una función que permite evitar ataques de enumeración.
- k. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por incidentes asociados a identificación de titularidad en información personal.

2. Los funcionarios y terceros de la entidad deben:

- a. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por incidentes asociados a identificación de titularidad en información personal.
- b. Utilizar las herramientas y los medios autorizados por la Entidad para el enmascaramiento de información de tipo reservado o datos personales.

E. Controles relacionados:

1. 5.34 – Protección de datos personales (PII).
2. 6.8 – Informes de eventos de seguridad de la información

8.12 Prevención de fuga de datos

A. Objetivo de control: detectar y prevenir la divulgación y extracción no autorizadas de información por parte de individuos, sistemas, redes y cualquier otro dispositivo que procese, almacene o transmita información confidencial, clasificada y reservada.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información, dependencia encargada de emitir las políticas y lineamientos relacionadas con la seguridad y privacidad de la información de la **DIAN**, y para la Dirección de Gestión e Innovación Tecnológica DGIT, quien es la dependencia encargada de implementar dichas políticas.

C. Características de control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de seguridad: confidencialidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Monitorear los canales para detectar posibles amenazas de fuga de datos que tiene la **DIAN**: correo electrónico, transferencias de archivos, dispositivos móviles personales (que utilicen herramientas de la **DIAN**) y dispositivos portátiles de almacenamiento.
 - b. Analizar las situaciones en las que se requiere restringir la capacidad de determinados usuarios para copiar y pegar o cargar datos en servicios, dispositivos y medios de almacenamiento fuera de la organización.

- c. Requerir las autorizaciones por parte de los propietarios de los datos, para casos donde se requiera su exportación.
- d. Definir y divulgar los términos y condiciones de uso para la toma de capturas de pantalla o fotografías de la pantalla.
- e. Monitorear el uso y el movimiento de datos y tomar medidas para evitar la fuga de datos: alertar a los usuarios sobre su comportamiento de riesgo y bloquear la transferencia de datos a dispositivos portátiles de almacenamiento externo de la **DIAN**.

2. La DGIT y Subdirección de Soluciones y Desarrollo debe:

- a. Seleccionar e implementar la herramienta DLP que permite identificar y monitorear información sensible en riesgo de divulgación no autorizada y detectar la divulgación de información confidencial por servicios, dispositivos y medios de almacenamiento fuera de la organización.
- b. Implementar el cifrado, el control de acceso y la protección física a los medios de almacenamiento que contienen copias de seguridad que involucren datos sensibles o personales.
- c. Poner en cuarentena los correos electrónicos que contengan información confidencial para evitar la posible fuga.
- d. Bloquear las acciones de los usuarios o las transmisiones de la red que expongan información confidencial.
- e. Con un énfasis proactivo se debe implementar la tecnología de decepción, para detectar, atrasar y analizar intentos no autorizados a la información confidencial con el uso de activos que sean ficticios (señuelos (Decoys), trampas, honeypots), sin valor real, pero diseñados para atrapar atacantes maliciosos o espionaje gubernamental. por ejemplo, archivos, bases de datos, cuentas de correo y otros recursos que parezcan tener datos valiosos, integrados con el etiquetamiento y la herramienta de DLP. Finalmente debe generar alertas automáticas en el sistema de monitoreo de seguridad (SIEM) del SOC de la DIAN.

3. Los funcionarios y terceros de la entidad deben:

- a. Leer y aplicar los términos y condiciones de uso para la toma de evidencias bajo capturas de pantalla o fotografías a las pantallas.
- b. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por incidentes asociados a fuga de información personal de acuerdo con el procedimiento de gestión de incidentes de seguridad de la información definido en la Entidad.-.
- c. Identificar y clasificar la información para protegerla contra fugas y extracción no autorizada.

E. Controles relacionados:

1. 5.12 – Clasificación de la información.
2. 5.15 – Control de acceso.
3. 5.34 – Protección de datos personales (PII).
4. 6.8 – Informes de eventos de seguridad de la información.

8.13 Copia de seguridad de la información

A. Objetivo de control: realizar, gestionar, almacenar y recuperar Las copias de seguridad de la información, software e imágenes de los sistemas de la **DIAN**, garantizando la disponibilidad e integridad de los activos de información críticos de la entidad siguiendo los procedimientos establecidos

B. Alcance: el alcance de esta política aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencia encargada de gestionar las copias de respaldo a los sistemas de información, bases de datos, aplicaciones e infraestructura tecnológica de la **DIAN**.

C. Características de control:

1. Tipo de control: correctivo.
2. Propiedades de seguridad: integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Formular, aprobar y socializar un procedimiento formalizado de copias de seguridad para la infraestructura tecnológica, las bases de datos, los sistemas de información, archivos electrónicos que contengan información relevante para la entidad y demás activos de información que permita realizar su recuperación dentro de los RPO definidos en el BIA o acordados con las áreas de negocio, cuando se requiera teniendo en cuenta entre otros los siguientes aspectos:
 - Frecuencia de las copias de respaldo: estas se deben realizar de forma periódica, según la criticidad de la información y los requisitos de la entidad. (Diaria, semanal, mensual, etc.)
 - Tipos de copias de respaldo: se deben implementar copias completas, incrementales y diferenciales de acuerdo con la estrategia definida para cumplir con las necesidades de la entidad, las copias pueden incluir datos, configuraciones de los sistemas, imágenes, sistemas de información, entre otros, que permitan la recuperación completa.
 - Almacenamiento: Las copias de respaldo deben almacenarse en ubicaciones seguras, preferiblemente en sitios geográficamente separados, ya sea en infraestructura local (on-premise) o en servicios de nube, con el fin de mitigar riesgos asociados a desastres físicos o fallos técnicos. Además, la entidad debe contar con un sitio alternativo de almacenamiento que permita gestionar las copias de respaldo según diferentes niveles de priorización, garantizando la disponibilidad de la información crítica conforme a los objetivos de continuidad del negocio y recuperación ante incidentes.
 - Requisitos para el almacenamiento: se deben definir los requisitos tanto para las instalaciones en sitio (on-site) y como para las fuera de ellas (off-site), considerando el volumen de información, la capacidad de almacenamiento disponible y el período de retención de las copias, en línea con los requisitos del Análisis de Impacto al Negocio (BIA) definidos por los procesos de negocio y los procesos de soporte. Esta definición debe asegurar que las copias de respaldo estén disponibles de manera oportuna y eficaz ante cualquier evento disruptivo.
 - Retención y ciclo de vida: las copias de respaldo se deben conservar durante un período definido de acuerdo con las, tablas de retención o los criterios de las áreas de negocio y dueños de los activos de información, de tal manera que se permita la

continuidad de las operaciones y la consulta histórica de la información. Así mismo se debe establecer el proceso de eliminación segura de copias obsoletas.

- Pruebas de restauración: Se deben realizar pruebas periódicas para validar la efectividad de las copias de seguridad. Estas pruebas se deben documentar y formar parte del plan de continuidad de TI.
 - Protección: Las copias de respaldo se deben proteger mediante cifrado a la información respaldada.
 - Responsabilidades: Se debe tener claro el responsable de la ejecución, monitoreo y mantenimiento de las copias de seguridad, la custodia de las copias, así como asegurar que existan los recursos y controles adecuados para cumplir con este lineamiento.
- b. Se debe contar con una herramienta, robot, aplicativo, u otro mecanismo para realizar las copias de respaldo a:
- Los servidores de archivos (carpetas con información de las dependencias)
 - Servidores que manejan aplicaciones web y aplicaciones locales
 - Información almacenada en servidores
 - Aplicaciones de los servidores
 - Información de aplicaciones contenida en servidores
 - Bases de datos de los diferentes aplicativos y servicios de la entidad
 - Controladores de dominio y de DHCP (Configuraciones de elementos de red)
 - *Switches & Rosters, firewall*
 - Equipos y/o estaciones de trabajo, siempre que el responsable de cada dependencia considere necesario previa coordinación entre las dependencias y la Dirección de Gestión de Innovación y Tecnología.
 - La información de los funcionarios alojada en el.
- c. Disponer de una plataforma que permita generar los informes de copia de seguridad para verificar que las copias de respaldo se hayan realizado de manera correcta garantizando que se pueda recuperar la versión más reciente de los datos.
- d. Realizar pruebas de tensión (de estrés) del hardware de backups (unidades de almacenamiento, unidades ópticas y controles) y del software (programas de backups y unidades de dispositivo). Estas pruebas deben estar documentadas en el procedimiento de backups, así como sus responsables y las debidas evidencias. Estas pruebas deben hacerse como mínimo una vez al año o cuando se adquiera nueva infraestructura tecnológica para el almacenamiento de información de la entidad.
- e. Contar con las librerías e infraestructura necesarias para generar y restaurar las copias de respaldo; se debe establecer un esquema de rotulado de las copias de respaldo, que contengan toda la información necesaria para identificar cada una de ellas y administrarlas debidamente respecto a la información que contenga.
- f. Extender los mismos controles de seguridad aplicados a los activos de TI en el sitio principal y en el sitio alterno y/o otros sitios de procesamiento para cumplir con las medidas de protección y seguridad física apropiados.
- g. Definir y mantener un plan de capacitación permanente a los involucrados y responsables del procedimiento de copias de respaldo
- h. Reportar a la Oficina de Seguridad de la Información los incidentes que involucren la pérdida, daño, robo o compromiso de activos de información asociados a copias de respaldo o restauración de información.
- i. Mantener actualizada la documentación relacionada con el esquema de backups.

E. Controles relacionados:

1. 5.1.30 – Preparación de las TIC para la continuidad del negocio.
2. 6.8 – Informes de eventos de seguridad de la información.
3. 8.1 – Dispositivos de punto final de usuario.
4. 8.10 – Eliminación de información.

8.14 Redundancia de las instalaciones de procesamiento de información

A. Objetivo de control: implementar la redundancia requerida en las instalaciones de procesamiento de información para cumplir con los requisitos de disponibilidad continua de los servicios tecnológicos de la entidad, en línea con los requisitos definidos por el negocio y los objetivos de continuidad.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y a la Subdirección de Infraestructura Tecnológica y de Operaciones, como dependencias encargadas de gestionar la redundancia de las instalaciones de procesamiento de información de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Verificar de manera aleatoria el cumplimiento de los requisitos de disponibilidad de los servicios de TI.
2. La subdirección de infraestructura tecnológica y de operaciones debe:
 - a. Cumplir con los lineamientos definidos por la guía “TIA-942 estándar - Diseño y Cableado de un Centro de Datos en los centros de datos”.
 - b. Reportar a la Oficina de Seguridad de la Información cualquier evento que comprometa la disponibilidad de servicios de TI.
 - c. Contar con proveedores diferentes para los servicios críticos como redes de datos e internet, así como instalaciones críticas de procesamiento de información, garantizando la redundancia operativa ante la caída de uno de ellos. Utilizar dos centros de datos separados geográficamente (mínimo 20 km lineales) o servicios en la nube con sistemas duplicados, según la gestión de riesgos de seguridad de la información en la propiedad de disponibilidad.
 - d. Tener componentes duplicados en los sistemas; por ejemplo: CPU, fuentes de alimentación discos duros, memorias o en redes (como cortafuegos, enrutadores, conmutadores).
 - e. Implementar múltiples instancias paralelas de componentes de software con balanceo de cargas automático entre ellas.
 - f. Plantificar y ejecutar pruebas para la activación de los componentes redundantes y las instalaciones de procesamientos.
 - g. Contar con alertas sobre fallas en las instalaciones de procesamiento de información.

- h. Verificar el uso de tecnologías en nube para contar con redundancias de los recursos tecnológicos.
- i. Incluir y desarrollar lineamientos relacionados con el SOC (*Security Operation Center*).

E. Controles relacionados:

- 1. 5.30 – Preparación de las TIC para la continuidad del negocio.
- 2. 6.8 – Informes de eventos de seguridad de la información.

8.15 Registro

A. Objetivo de control: elaborar, conservar y revisar regularmente los registros de las actividades de los usuarios, fallas, excepciones y eventos de seguridad de la información (logs), con el fin de apoyar la detección, análisis y repuesta ante incidentes de seguridad.

B. Alcance: el alcance de esta política aplica para la Subdirección de Soluciones y Desarrollo, y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de gestionar los registros de eventos de los sistemas e infraestructura de la **DIAN**. **Características de control:**

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

C. Lineamientos:

- 1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Generar y mantener registros (logs) de las actividades relevantes en los sistemas operativos y aplicaciones, asegurando que incluyan como mínimo: fecha, hora, usuario, acción realizada, dirección IP origen y destino, y demás atributos que sean requeridos.
 - b. Confirmar que todas las aplicaciones y bases de datos tengan habilitados los mecanismos de registro de las actividades realizadas tanto por usuarios como por administradores.
 - c. Direccionar los logs en línea de todos los sistemas de la **DIAN** al SIEM (Security Information and Event Management) de la entidad. Esta plataforma tendrá una retención de estos logs, según su capacidad.
 - d. Alertar a la Oficina de Seguridad de la Información sobre eventos que puedan afectar la recopilación de los eventos.
 - e. Asegurar que los sistemas de información adquiridos para la entidad cuenten como mínimo con los siguientes archivos de registro de actividades (logs):
 - log de auditoría.
 - log de seguridad.
 - logs servidor de aplicaciones.
 - Logs de transaccionalidad de aplicaciones.
 - Registros de eventos de transacciones, producidos directamente por la aplicación, y diferenciarlos del registro de eventos del servidor de aplicaciones.

Estos logs deben tener una retención de mínimo un año. Estas actividades deben ser coordinadas con la Subdirección de Infraestructura Tecnológica y de Operaciones.

2. La Subdirección de Soluciones y Desarrollo debe:

- a. Garantizar que los sistemas desarrollados en la entidad cuenten como mínimo con los siguientes archivos de registro de actividades (logs):
 - log de auditoría.
 - log de seguridad.
 - logs servidor de aplicaciones.
 - Los de transaccionalidad en aplicaciones.
 - Registros de eventos de transacciones, producidos directamente por la aplicación, y diferenciarlos del registro de eventos del servidor de aplicaciones.

D. Controles relacionados:

1. 5.25 – Evaluación y decisión sobre eventos de seguridad de la información.
2. 5.28 – Recolección de evidencia.
3. 5.34 – Protección de datos personales (PII).
4. 6.8 – Informes de eventos de seguridad de la información.
5. 8.16 – Actividades de seguimiento.
6. 8.17 – Sincronización de reloj.

8.16 Actividades de seguimiento

A. Objetivo de control: monitorear las redes de datos, los sistemas y las aplicaciones para detectar comportamientos anómalos y tomar medidas apropiadas de forma oportuna para evaluar posibles incidentes de seguridad de la información.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencias encargadas de gestionar los monitoreos a las redes de datos, los sistemas, las aplicaciones y la infraestructura tecnológica de la **DIAN**.

C. Características de control:

1. Tipo de control: detectivo y correctivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Monitorear permanentemente los eventos de los sistemas de información de la **DIAN** que puedan generar un incidente de seguridad y privacidad de la información y que atente contra la confidencialidad, integridad o disponibilidad de los activos de información.
 - b. Reportar a la Oficina de Seguridad de la Información los eventos que puedan afectar la seguridad de la información de la entidad.

- c. Definir y establecer una línea base para identificar el comportamiento normal (tanto en horas normales como en horas pico) de redes, sistemas, aplicaciones e infraestructura tecnológica, para facilitar la identificación de anomalías tales como:
 - Terminación no planificada de procesos o aplicaciones.
 - Actividad típicamente asociada con malware o tráfico que se origina en direcciones IP o dominios de red maliciosos conocidos (por ejemplo, aquellos asociados con servidores de comando).
 - Características de ataque conocidas (por ejemplo, denegación de servicio y desbordamiento de memoria intermedia).
 - Comportamiento inusual del sistema (por ejemplo, registro de pulsaciones de teclas, inyección de procesos y desviaciones en el uso de protocolos estándar).
 - Cuellos de botella y sobrecargas en las redes de datos (por ejemplo, colas de la red, niveles de latencia y fluctuaciones de la red).
 - Acceso no autorizado (real o intentado) a sistemas o información.
 - Escaneo no autorizado de aplicaciones comerciales, sistemas y redes.
 - Intentos exitosos y fallidos de acceder a recursos protegidos (por ejemplo, servidores DNS, portales web y sistemas de archivos).
 - Comportamiento inusual del usuario y del sistema en relación con el comportamiento esperado.
 - d. Monitorear tráfico de red, sistema y aplicación entrante y saliente.
 - e. Ejecutar acciones de revisión periódicas sobre archivos de configuración de red y sistema de nivel crítico o administrativo.
 - f. Registrar las revisiones a herramientas de seguridad, por ejemplo: antivirus, IDS, sistema de prevención de intrusiones (IPS), filtros web, cortafuegos, prevención de fuga de datos.
 - g. El software de monitoreo debe configurarse para generar alertas (por ejemplo, a través de consolas de administración, mensajes de correo electrónico o sistemas de mensajería instantánea) en función de umbrales predefinidos. También debe ajustarse y hacer capacitación en la línea de base de la organización para minimizar los falsos positivos.
 - h. Se deben establecer procedimientos para identificar y abordar los falsos positivos, incluido el ajuste del software de monitoreo para reducir la cantidad de falsos positivos en el futuro.
 - i. Implementar y ejecutar las acciones de respuesta frente a amenazas sobre las redes de datos, los sistemas y las aplicaciones que se identifiquen y/o que sean reportadas por el Centro de Operación de Seguridad de la Información (COSI = SOC), para mejorar la postura de ciberseguridad de la Entidad.
2. La Oficina de Seguridad de la Información debe:
- a. Generar alertas necesarias ante la identificación de actividades anómalas sobre los sistemas de información de la **DIAN**. A su vez, realizar el plan de seguimiento para la implementación de las actividades requeridas para corregir estos eventos.
 - b. Tener una plataforma para el monitoreo de las bases de datos que permita el registro detallado de las actividades que sobre estas se realicen
 - c. Integrar en el diseño de SOC la capacidad de correlación de eventos, para realizar el monitoreo, detección y respuesta centralizado para Eventos de seguridad, gestión de amenazas y vulnerabilidades.
 - d. Escalar a las diferentes dependencias de la entidad a través de los dueños de los activos de información, las actividades que puedan implicar un riesgo de seguridad de la información o un uso inadecuado de los sistemas de la **DIAN** y que puedan atentar contra

de la confidencialidad, integridad o disponibilidad de la información, para que definan si las actividades corresponden a eventos anómalos.

- e. Informar a la Dirección de Gestión de Innovación y Tecnología, la información relacionada con los riesgos, acciones y/o mitigaciones sugeridas, y con ello, acordar medidas para aplicar los controles y/o las acciones correspondientes para la mitigación de los eventos identificados y reportados.
- f. Revisar actividades asociadas con malware o tráfico que se origina en direcciones IP o dominios de red maliciosos conocidos; por ejemplo, aquellos asociados con servidores de comando y control de botnet.
- g. Revisar las características de ataque conocidas. Ejemplo: la denegación de servicio y el desbordamiento de memoria intermedia; el comportamiento inusual del sistema (registro de pulsaciones de teclas, inyección de procesos y desviaciones en el uso de protocolos estándar).
- h. Diseñar, implementar, supervisar y optimizar el Centro de Operación de Seguridad de la Información (COSI = SOC) para el monitorear, identificar, correlacionar, alertar y responder en coordinación con la Subdirección de Infraestructura y Operaciones ante amenazas y eventos de seguridad de la información en la **DIAN**.
- i. Capacitar al personal acerca de cómo responder a las alertas e interpretar con precisión los posibles incidentes.

3. Los funcionarios y terceros de la entidad deben:

- a. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren la pérdida, daño, robo o compromiso de activos de información por incidentes asociados a alertas en los registros de eventos.

E. Controles relacionados:

1. 5.7 – Inteligencia de amenazas.
2. 5.25 – Evaluación y decisión sobre eventos de seguridad de la información.
3. 5.26 – Respuesta a incidentes de seguridad de la información.
4. 5.28 – Recolección de evidencia.
5. 6.8 – Informes de eventos de seguridad de la información.

8.17 Sincronización de reloj

A. Objetivo de control: asegurar la sincronización los relojes de los servidores, sistemas de procesamiento de información, equipos y servicios tecnológicos con una única fuente de referencia de tiempo, para obtener la exactitud de los registros de auditoría.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencia encargada de gestionar la configuración que permite la sincronización del tiempo legal en los sistemas y aplicaciones de la **DIAN**.

C. Características de control:

1. Tipo de control: detectivo.
2. Propiedades de seguridad: integridad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Documentar los requisitos necesarios para el cumplimiento de la sincronización de relojes de los servidores, sistemas de procesamiento de información, equipos y servicios tecnológicos.
 - b. Actualizar la hora de los servidores con la escala de tiempo internacional UTC, mediante sincronización a través del protocolo NTP v4, conforme al Instituto Nacional de Metrología (INM).
 - c. Realizar pruebas periódicas que permitan confirmar la correcta sincronización de la hora oficial de país provista por el Instituto Nacional de Metrología.
 - d. Monitorear las diferencias entre relojes de distintos servicios y registrarlas, cuando se utilizan servicios en la nube o entornos híbridos.
 - e. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren compromiso de activos de información por incidentes asociados a la hora que poseen los servidores, sistemas de procesamiento de información, equipos y servicios tecnológicos.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información.

8.18 Uso de programas de utilidad privilegiados

A. Objetivo de control: restringir y controlar estrictamente el uso de programas utilitarios que podrían tener capacidad de anular el sistema y los controles de las aplicaciones de la **DIAN**.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones, y la Subdirección de Soluciones y Desarrollo, dependencias encargadas de gestionar el uso de programas de utilidad privilegiados de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Establecer una política, a nivel del controlador de dominio, que no permita la instalación de software y cambios de configuración del sistema.
 - b. Definir un lineamiento para que ningún usuario final tenga privilegios de administrador y que exista un número limitado de usuarios autorizados para el uso de programas utilitarios.
 - c. Definir un procedimiento de identificación, autenticación y autorización para el uso de programas utilitarios por funcionarios y/o terceros, que incluya la identificación única de

la persona que utiliza el programa utilitario, así como la documentación de los niveles de autorización y si hay autorización de Uso Adhoc.

- d. Registrar y mantener actualizados todos los usos aprobados de los programas de utilidad.
- e. Llevar el inventario de programas utilitarios que sean autorizadas por la entidad.

2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:

- a. Restringir el uso de las herramientas de administración licenciadas (herramientas propias de la **DIAN** usadas para administrar los equipos: instalación, desinstalación de software y similares) para el sistema, solo para usuarios administradores.
- b. Implementar la política, a nivel del controlador de dominio, que impida la Instalación de software y cambios de configuración en los sistemas.
- c. Confirmar que en los sistemas e infraestructura ningún usuario final tenga privilegios de administrador, conforme a lo establecido por la Subdirección de Soluciones y Desarrollo.
- d. Bloquear la sesión después de cinco (5) minutos de inactividad del sistema, confirmando que se realice el bloqueo sin cerrar las sesiones de aplicación o de red.
- e. Suspender y bloquear las estaciones de trabajo cuando la ausencia temporal de actividad supere las dos horas.
- f. Se debe garantizar que cada programa utilitario se ejecute bajo una cuenta de servicio o usuario independiente, con permisos mínimos necesarios, no se puede compartir las sesiones evitando el uso de la misma cuenta en varias sesiones activas al mismo tiempo, sobre todo si es en diferentes equipos o usuarios, y si se necesita múltiples sesiones cada una debería tener identificación y registro de las sesiones de RDP o administrativas y deben ser desconectadas automáticamente tras 60 minutos así como no quedar abiertas por largo periodo sin supervisión. Debe tenerse en cuenta las políticas de contraseñas seguras, fuertes y MFA en rotaciones periódicas sobre todos para usuarios privilegiados
- g. Limitar el número de usuarios autorizados para el uso de programas utilitarios.
- h. Separar de forma lógica los programas de utilidad del software de aplicación.
- i. Implementar el borrado, remoción o inhabilitación el software utilitario que no cuente con la autorización requerida.

E. Controles relacionados:

1. 6.8 – Informes de eventos de seguridad de la información.
2. 8.2 – Derechos de acceso privilegiado.

8.19 Instalación de software en sistemas operativos

- A. Objetivo de control:** establecer e implementar procedimientos y medidas para gestionar de forma segura la instalación de software en los sistemas operativos por parte de los usuarios, mitigando afectación la confidencialidad, integridad y disponibilidad de la información de la **DIAN**. Esta política aplica a todos los dispositivos y sistemas operativos (Windows, Linux, macOS, entre otros) utilizados en la DIAN ya sean físicos o virtuales, incluyendo servidores, estaciones de trabajo, laptops y dispositivos móviles, que manejen información sensible o crítica.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones y Subdirección de Soluciones y Desarrollo, dependencias encargadas de gestionar el uso de software en los sistemas de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Prohibir el desarrollo y/o implementación de soluciones informáticas o herramientas de gestión no corporativas en lugares o ambientes diferentes a los dispuestos por la Dirección de Gestión de Innovación y Tecnología y que no sigan los procedimientos de desarrollo de software establecidos por la entidad.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Establecer restricciones y limitaciones para la instalación del software en los equipos de cómputo de la **DIAN ya sean físicos o virtuales**, según el licenciamiento que se tenga disponible.
 - b. Contar con un inventario total de software de la entidad y avalar o realizar la adquisición de software para la **DIAN**.
 - c. Cumplir con los procesos y procedimientos establecidos por la entidad para la construcción o adquisición de software.
 - d. Validar si la entidad cuenta con soluciones que tengan las funcionalidades requeridas por alguna dependencia. De no existir estas soluciones, se debe escalar una solicitud de adquisición a la Dirección de Gestión de Innovación y Tecnología y cumplir con los procedimientos y requisitos para su adquisición e instalación.
 - e. Remitir a la Oficina de Seguridad de la información las solicitudes que se registren por la mesa de ayuda, relacionadas con requerimientos de instalación de software de uso libre.
 - f. Llevar el inventario de aplicaciones de uso libre que sean autorizadas por la entidad.
 - g. Instalar y mantener actualizados el software de seguridad de protección de punto final como antivirus, IDS/IPS, firewall, proxys y demás aplicaciones de seguridad informática que se instalen en los equipos de usuarios internos, de forma que cuenten con las últimas versiones de detección y control de nuevos vectores de ataques. Estos aplicativos no podrán ser manipulados o desactivados por los usuarios internos.
 - h. Restringir las posibilidades de copiar, vender y/o distribuir el software de la entidad.
 - i. Restringir el uso exclusivo de software especializado para realizar pruebas de vulnerabilidades, monitoreo de la red, explotación de vulnerabilidades, análisis de protocolos e intercepción o análisis de tráfico en la red, a funcionarios que hacen parte de la Oficina de Seguridad de la Información o de la Subdirección de Infraestructura Tecnológica y de Operaciones, bajo autorización y supervisión de la oficina antes mencionada.
 - j. Confirmar que las licencias instaladas en la **DIAN** corresponden en cantidad y versión licenciada con la que se adquirió.
 - k. Manejar un sistema de control de configuración para mantener el monitoreo e inventario de todo el software instalado en los equipos de cómputo de los usuarios.

- l. Designar responsables y establecer instructivos y guías para controlar la instalación de software, tanto en las máquinas de los usuarios internos como en los servidores.
 - m. Confirmar que todo software instalado en la plataforma tecnológica de la **DIAN** cuente con soporte de los proveedores y fabricantes.
 - n. Conceder accesos temporales y supervisar a los fabricantes y terceros autorizados, para realizar actualizaciones sobre el software.
 - o. Generar un plan de actualizaciones para el software, aplicaciones y librerías de programas que se deben llevar a cabo por los administradores, bajo la autorización del Comité de Cambios.
 - p. Confirmar que las instalaciones de software se realizan siempre que se aprueben de forma satisfactoria.
 - q. Registrar de forma segura los eventos relacionados con actualizaciones de software operativo.
 - r. Archivar en repositorios seguros las versiones anteriores del(los) software(s) que han sido actualizados o cambiados.
 - s. Validar los riesgos que genera la migración hacia nuevas versiones del software. Se debe confirmar el correcto funcionamiento de los sistemas de información y herramientas de software que se ejecutan sobre la plataforma tecnológica cuando el software es actualizado.
 - t. Restringir el uso de software o servicios de red que permitan el intercambio de información con terceras partes sin el debido aval o autorización por parte de la Oficina de Seguridad de la información.
3. La Oficina de Seguridad de la información debe:
 - a. Realizar el análisis del requerimiento de instalación de software de uso libre en términos de seguridad de la información y entregar el resultado a la Subdirección de Soluciones y Desarrollo para la toma de la decisión definitiva.
 - b. Enviar un mensaje al usuario interno e informar a su jefe inmediato, para que dé traslado a la autoridad disciplinaria, administrativa o judicial competente, informando sobre los hechos que puedan ser constitutivos de violación a los reglamentos vigentes del uso de software.
 - c. Autorizar los accesos temporales y controlados a los fabricantes y terceros autorizados para realizar actualizaciones sobre el software.
4. Los funcionarios y terceros de la entidad deben:
 - a. Utilizar el software legalmente adquirido, desarrollado y/o autorizado por la entidad a través de la Subdirección de Soluciones y Desarrollo.
 - b. Enviar una solicitud a través de la mesa de ayuda a la Subdirección de Soluciones y Desarrollo en caso de requerirse la instalación de software de uso libre a través de la herramienta establecida para tal fin, relacionando el nombre de la aplicación, la versión, el tipo de licencia de uso, la casa de software productora, las referencias en internet, la justificación del requerimiento y el periodo de tiempo estimado de uso.
 - c. Abstener el uso de software o hardware que vulnere o evada los controles de seguridad informática o seguridad y privacidad de la información establecidos por la **DIAN**.
 - d. Informar a la Oficina de Seguridad de la información de eventos de violación a los reglamentos vigentes relacionados con software.

E. Controles relacionados:

1. 5.22 – Seguimiento, revisión y gestión de cambios de servicios de proveedores
2. 6.8 – Informes de eventos de seguridad de la información
3. 8.5 – Autenticación segura
4. 8.8 – Gestión de vulnerabilidades técnicas
5. 8.29 – Pruebas de seguridad en desarrollo y aceptación
6. 8.31 – Separación de los entornos de desarrollo, prueba y producción

8.20 Seguridad en redes

A. Objetivo de control: proteger las redes y los dispositivos de red para mitigar la afectación a la información en los sistemas y aplicaciones de la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura tecnológica y de Operaciones y la Oficina de Seguridad de la información, dependencias encargadas de gestionar la seguridad de las redes de la **DIAN** y sus seccionales.

C. Características de control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Restringir las redes de datos alámbricas o inalámbricas de la **DIAN** a únicamente los funcionarios y terceros autorizados con contrato o convenio vigente para conectarse y acceder a los sistemas de información de la entidad.
 - b. Restringir el acceso a la red local extendida únicamente a funcionarios de la entidad, y garantizar que las condiciones de seguridad sean las mismas que en la red interna.,.
 - c. Supervisar las acciones de terceros autorizados por contrato vigente para dar soporte, verificando que los equipos cumplan con las políticas de seguridad de la información de la entidad. Establecer métodos para la contención (aislamiento) de dispositivos con comportamiento inusual.
 - d. Autorizar y monitorear las acciones realizadas sobre los canales de comunicación entre entidades públicas, privadas o los servicios de computación en la nube
 - e. Establecer y configurar métodos de cifrado para toda comunicación que pase por redes de terceros.
 - f. Establecer configurar y registrar los protocolos de cambio de configuración por defecto (hardening) para los equipos activos de la red.
 - g. Deshabilitar por defecto los puertos físicos y lógicos de la plataforma tecnológica de comunicaciones.
 - h. Establecer mecanismos para detectar intrusos para descubrir cualquier intento de acceso o ataque sobre plataformas informáticas.
 - i. Restringir el uso del servicio de internet solo para fines laborales e institucionales y realizar las funciones asignadas.
 - j. Definir la herramienta de mensajería instantánea institucional y restringir el uso de todas las demás configurando las excepciones de acuerdo con las necesidades funcionales.

Contar con un procedimiento que permita controlar la publicación en los sistemas colaborativos de la información marcada o etiquetada como clasificada o reservada.

- k. Restringir el acceso a los servicios de computación en la nube a través de dispositivos móviles. Dicho acceso solo está autorizado para usuarios internos que, por su rol, requieren movilidad entre diferentes sedes de la **DIAN** o ubicaciones externas.
- l. Administrar las capacidades y accesos de los diferentes servicios disponibles en las herramientas de computación en la nube que contrate la entidad.
- m. Integrar al SIEM de la entidad el registro de las actividades sobre los equipos activos de la red.
- n. Restringir el acceso a los servicios de computación en la nube desde equipos o redes de uso público.
- o. Restringir la sincronización de información de la nube con cuentas personales.
- p. Implementar sistemas que controlen la autenticación en la red.
- q. Mantener la documentación actualizada, incluidos los diagramas de red y los archivos de configuración de los dispositivos.
- r. Establecer las políticas de acceso de acuerdo con las necesidades técnicas de los servicios, teniendo en cuenta el principio de mínimo privilegio.
- s. Independizar la interfaz de administración de los equipos activos de la red de las interfaces de servicio.
- t. Realizar la gestión de la capacidad sobre los canales de comunicación y conservar la información histórica con el fin de establecer las líneas base de comportamiento y realizar periódicamente la revisión del desempeño y la optimización.
- u. Definir e implementar protocolos de comunicación e internet de última generación.

2. La Oficina de Seguridad de la información debe:

- a. Validar y analizar las solicitudes de autorización de conexión de un tercero para realizar tareas de soporte en equipos de la entidad.
- b. Evaluar los riesgos, la disponibilidad de la información, su sensibilidad y su clasificación frente a los compromisos legales o contractuales que tenga la entidad por el uso de los servicios de computación en la nube.
- c. Monitorear y revisar la información desarrollada, gestionada o almacenada, sin necesidad de contar con la autorización de su(s) autor(es) o generador(es).

3. Los jefes de las dependencias deben:

- a. Determinar el tipo de información a almacenar en la nube de acuerdo con su clasificación y sensibilidad. De igual manera, establecer cuáles usuarios pueden tener acceso o permisos de modificación sobre la misma.
- b. Coordinar con la Subdirección de Soluciones y Desarrollo el mecanismo un método para realizar la descarga de altos volúmenes de información, en la nube, a un sistema de carpetas públicas. Así mismo, se debe establecer el medio y la forma en que esta información sea recuperada en caso de ser necesario.

4. Los funcionarios y terceros de la entidad deben:

- a. Solicitar a la Oficina de Seguridad de la información autorización cuando se requiera comunicación con un tercero para recibir soporte y que este requiera la conexión a equipos de la entidad.
- b. Evitar, bajo el riesgo de sanción por parte de la entidad, el envío, recepción, descarga y visualización de páginas, archivos o adjuntos en cualquier formato digital, con contenido

insultante, ofensivo, injurioso, obsceno, violatorio de los derechos de autor y/o que atente contra la integridad de las personas o instituciones.

- c. Evitar, bajo el riesgo de sanción por parte de la entidad, colocar información de la **DIAN** (independientemente de su formato o su nivel de clasificación de confidencialidad) en sitios de internet públicos, privados o los denominados discos, carpetas virtuales o cualquier sistema de publicación de documentos, dentro o fuera de las instalaciones de **DIAN** que no sean aprobados por la entidad.
- d. Especificar en sus redes sociales personales que sus opiniones, discusiones, expresiones y demás publicaciones son a nombre de quien las expresa y no se emiten a nombre de la entidad.
- e. Evitar bajo sanción por la entidad publicar imágenes, opiniones, información o debates sobre la **DIAN** en sus redes sociales. Sin embargo, si algún usuario interno las publica, debe ser autorizado por la Oficina de Comunicaciones Institucionales y la Oficina de Seguridad de la información, para lo cual debe adicionar la siguiente frase en español e inglés:
 - “Las opiniones y publicaciones realizadas en este sitio corresponden a una opinión y no constituyen en ningún momento una posición oficial de la **DIAN**”.
 - “The opinions and publications made on this site correspond to a personal opinion and do not constitute at any time an official position by Colombian Tax and Customs Office, **DIAN**.”
- f. Sincronizar la información almacenada en su repositorio individual en la nube, con su equipo institucional, si está registrado en el dominio interno de la **DIAN**.
- g. Mantener, depurar y/o actualizar la información almacenada en su repositorio individual creado en la nube.
- h. Habilitar el control de cambios y las marcas de revisión activas cuando se utilicen herramientas de trabajo colaborativo o elaboración de archivos compartidos.
- i. Evitar, bajo el riesgo de sanción por parte de la entidad, desactivar las funciones de seguimiento, revisión o auditoría que tengan configuradas las herramientas de computación en la nube.
- j. Evitar, bajo riesgo de sanción por parte de la entidad, utilizar los servicios de colaboración en la nube para:
 - Procesar o almacenar información de tipo personal.
 - Distribuir software no seguro o de procedencia no permitida o ilegal.
 - Intentar obtener un acceso no autorizado o causar disrupción en cualquier dispositivo, dato, cuenta o red.
 - Obstaculizar el uso de las herramientas disponibles en la nube por parte de otras personas.
 - Copiar, adulterar o tratar de manipular el software disponible en la nube para provecho propio, usos no permitidos o ilegales.
 - Realizar acciones que pongan en riesgo la seguridad o aumenten la vulnerabilidad de los servicios o de la información disponible en la nube.
- k. Reportar cualquier evento que pueda constituirse como un incidente de seguridad y privacidad de la información almacenada en los sistemas de colaboración.
- l. No usar las credenciales, accesos, nombres de usuario o dirección de correo electrónico asignado con fines personales.

- m. No extraer, exfiltrar, o transmitir total o parcialmente información asignada en el ejercicio de sus labores en herramientas o cuentas no oficiales de la entidad.

E. Controles relacionados:

1. 5.3 – Segregación de deberes.
2. 5.10 Uso aceptable de la información y otros activos asociados.
3. 5.14 – Transferencia de información.
4. 5.22 – Seguimiento, revisión y gestión de cambios de servicios de proveedores.
5. 6.6 – Acuerdos de confidencialidad o no divulgación.
6. 6.8 – Informes de eventos de seguridad de la información.
7. 8.15 – Inicio de sesión.
8. 8.16 – Actividades de seguimiento.
9. 8.24 – Uso de criptografía.

8.21 Seguridad de los servicios de red

A. Objetivo de control: identificar los mecanismos de seguridad, los niveles de servicio y los requisitos de gestión de todos los servicios de red.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura tecnológica y de operaciones, dependencia encargada de gestionar la seguridad de las redes de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Confirmar que todos los equipos, servicios propios o servicios que se contraten externamente, cuenten con los registros de auditoría de las labores realizadas en estos y que permita evaluar los riesgos de seguridad.
 - b. Monitorear permanentemente la disponibilidad de los canales de comunicación.
 - c. Monitorear permanente los canales de comunicación para identificar y establecer su desempeño y generar los mecanismos de control.
 - d. Brindar los niveles de servicio adecuados en las labores asociadas a los contratistas y a las necesidades propias de la entidad.
 - e. Contar con las características de seguridad que permitan controlar, monitorear, bloquear, segmentar y asignar los puertos para las diferentes redes que se utilicen.
 - f. Confirmar las medidas de seguridad que los proveedores implementan para mantener la seguridad de sus redes.
 - g. Establecer e implementar controles y procedimientos para restringir el acceso a los servicios de la red con base en el principio de mínimo privilegio.
 - h. Establecer con apoyo de la Oficina de Seguridad de la información, los Parámetros técnicos requeridos para la conexión segura.
 - i. Establecer los únicos medios autorizados por la **DIAN** para el acceso a la red local extendida y restringir el acceso de acuerdo con el principio de mínimo privilegio.

- j. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren compromiso de activos de información por incidentes asociados a la seguridad de los servicios de red.
- k. Realizar e informar el análisis de causa raíz para identificar el control a mejorar y el riesgo materializado cuando se presente alguna indisponibilidad de servicio.

E. Controles relacionados:

- 1. 6.8 – Informes de eventos de seguridad de la información.
- 2. 8.20 – Seguridad en redes.

8.22 Segregación de redes

A. Objetivo de control: separar las redes, los grupos de servicios de información, sistemas de información y usuarios para controlar el tráfico entre ellos, en función de las necesidades misionales de la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Infraestructura Tecnológica y de Operaciones, dependencia encargada de gestionar la seguridad de las redes de la **DIAN**.

C. Características de control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Diseñar y mantener la segregación en las redes de datos que permitan el aislamiento funcional entre las diferentes aplicaciones, sedes, áreas, grupos y dependencias de la entidad.
 - b. Aislar el tráfico entre las zonas: pública, desmilitarizada, de usuarios, de servicios internos y demás identificadas en la entidad.
 - c. Configurar la red de datos para que se encuentre en segmentos físicos y lógicos independientes, separando como mínimo los usuarios internos, visitantes, las conexiones con terceros, la conexión a internet y las plataformas informáticas de servicio.
 - d. Establecer un perímetro externo llamado “DMZ internet (Delimitarized Zone)” en la red a través del cual se puedan limitar las conexiones desde internet hacia las plataformas informáticas internas, permitiendo la seguridad de las últimas. De igual forma, las conexiones desde la red interna hacia la DMZ internet deben ser limitadas solamente a las necesidades operacionales de funcionamiento de las plataformas, bajo el principio de “acceso mínimo requerido”.
 - e. Separar las redes alámbricas de las inalámbricas y se debe contar con redes inalámbricas públicas que están disponibles en casos especiales.
 - f. Configurar los dominios de red separados de la red pública (Internet) a través de firewall.

- g. Diseñar e implementar el esquema de defensa en profundidad para realizar la segregación de las redes de la entidad.
 - h. Implementar un portal cautivo de acceso inalámbrico para los invitados a las instalaciones de la entidad, el cual debe contar con las mismas restricciones establecidas para los funcionarios; este servicio no debe afectar la red interna, teniendo en cuenta que no es una prioridad en el cumplimiento de la misionalidad de la entidad
 - i. Implementar de forma segura la red de "Zona Wifi gratis para la Gente" según el Decreto 728 de 2017.
 - j. Implementar un servicio de red para los equipos de análisis forense, el cual debe estar aislado y solo puede ser utilizado por los responsables asignados en Fiscalización (TACI).
 - k. Reportar a la Oficina de Seguridad de la Información los eventos y/o incidentes que involucren compromiso de activos de información por incidentes asociados a la seguridad de los servicios de red.
 - l. Evaluar y optimizar el tamaño de los diferentes segmentos de red asignados.
 - m. Mantener actualizada la documentación de la asignación de los segmentos tanto de servicio como de transporte, y establecer un protocolo para la asignación de estos.
 - n. Establecer mecanismos técnicos para que cualquier equipo que sea conectado a la red de la entidad esté por defecto en aislamiento
 - o. Entregar a la Oficina de Seguridad de la Información accesos de solo lectura sobre los principales sistemas de seguridad informática de la entidad.
2. La Oficina de Seguridad de la Información debe:
- a. Realizar la revisión de los incidentes con base en la información suministrada por la Subdirección de Infraestructura Tecnológica y de Operaciones con el fin de gestionarlos.
 - b. Realizar periódicamente una revisión en busca de comportamientos inusuales en los equipos de seguridad informática a los que tenga acceso.

E. Controles relacionados:

1. 5.15 – Control de acceso.
2. 6.8 – Informes de eventos de seguridad de la información.
3. 8.20 – Seguridad en redes.

8.23 Filtros Web

- A. Objetivo de control:** asegurar que el acceso a internet desde los equipos de usuario final de la entidad se realice de manera controlada, con el fin de reducir la exposición a amenazas que puedan afectar la seguridad de la información y promover el uso adecuado de los recursos de conectividad disponibles en la Entidad.
- B. Alcance:** el alcance de este lineamiento aplica para la Oficina de seguridad de la información y Subdirección de Infraestructura Tecnológica y de Operaciones de la entidad, encargadas de proteger los sistemas contra el malware y evitar el acceso a recursos web no autorizados.
- C. Características de control:**
1. Tipo de control: preventivo.
 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la información debe:
 - a. Establecer y mantener actualizadas las reglas para el uso seguro y apropiado de los recursos en línea, incluyendo cualquier restricción a sitios web y aplicaciones basadas en la web indeseables o inapropiados.
 - b. Incluir, en las reglas de uso seguro y apropiado de los recursos en línea, las diferencias entre los equipos en la red de la entidad y los equipos que se encuentran en teletrabajo.
 - c. Identificar y documentar los tipos de sitios web a los que los funcionarios y terceros deben o no tener acceso.
 - d. Indicar si es válido o no el acceso a páginas o servicios de internet no permitidos que un funcionario o tercero solicite para el cumplimiento de sus actividades.
 - e. Definir lineamientos y controles para restringir el acceso a sitios web que contengan información ilegal o que se sepa que contiene virus o material que pueda afectar los equipos de la entidad, se debe considerar bloquear el acceso a los siguientes tipos de sitios web:
 - Maliciosos conocidos o sospechosos (por ejemplo, a aquellos que distribuyen *malware* o contenido de *phishing*).
 - Servidores de mando y control.
 - Maliciosos identificados en la inteligencia de amenazas.
 - Que comparten contenido ilegal.
 - f. Definir los lineamientos de acceso a sitios web que tengan funciones de carga de información con el fin de estar alineados con el control de prevención de fuga de datos (8.12) de esta manual.
 - g. Verificar, al menos una vez al año, que los filtros web se están aplicando de acuerdo con los lineamientos establecidos.
 - h. Brindar capacitación a los funcionarios y terceros de la entidad sobre el uso seguro y apropiado de los recursos en línea, incluido el acceso a la web y los siguientes aspectos:
 - Las reglas definidas en este tema.
 - El punto de contacto para plantear problemas de seguridad.
 - El proceso de excepción cuando se necesita acceder a recursos web restringidos por razones comerciales.
3. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Implementar los controles definidos por la Oficina de Seguridad de la Información, bloqueando la dirección IP o el dominio de los sitios web identificados que requieren restricción de acceso.
 - b. Direccionar a la Oficina de Seguridad de la Información las solicitudes de funcionarios o terceros que soliciten el acceso a páginas o servicios de internet no permitidos.
 - c. Restringir el acceso a servicios de streaming de audio y video desde la red de datos de la Entidad, salvo que por funciones asignadas sea necesario y debe ser autorizado por la Oficina de Seguridad de la información.

- d. Restringir el acceso a redes sociales desde la red de datos de la Entidad, salvo que por funciones asignadas sea necesario y debe ser autorizado por la Oficina de Seguridad de la Información.
 - e. Prohibir el acceso a páginas web, portales, sitios web y aplicaciones web que no hayan sido autorizadas por la Oficina de Seguridad de la Información a través de la política de navegación.
4. Los funcionarios y terceros de la entidad deben:
- a. Solicitar a la Oficina de Seguridad de la Información a través de jefe inmediato, acceso a páginas o servicios de internet no permitidos cuando estos sean requeridos para el cumplimiento de sus actividades.

E. Controles relacionados:

1. 5.7. – Inteligencia de amenazas.

8.24 Uso de criptografía

A. Objetivo de control: establecer un esquema para el uso adecuado y eficaz de las técnicas criptográficas para gestionar la confidencialidad, integridad, y disponibilidad de la información pública reservada y pública clasificada y datos personales administrada por la **DIAN** que sea transportan, transmiten y/o almacenan en los diferentes medios digitales y/o electrónicos disponibles en la entidad.

B. Alcance: el alcance de estos lineamientos aplica para todas las dependencias de la **DIAN** que tratan información pública reservada, pública clasificada y datos personales, para el personal encargado de implementar los controles de cifrado en los servicios de red, en las plataformas informáticas y en los sistemas de información de la entidad, en el momento de almacenarse o transmitirse por cualquier medio digital o electrónico utilizado.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir lineamientos sobre el uso de criptografía para la protección de la información en la entidad.
 - b. Establecer condiciones de cifrado para los correos electrónicos de la entidad cuando estos cuenten con información pública reservada o pública clasificada.
 - c. Validar la efectividad de los controles de criptografía con el fin de salvaguardar la seguridad y la privacidad de la información, tanto en su almacenamiento como durante su transmisión.
2. La Dirección de Gestión de Innovación y Tecnología debe:

- a. Controlar que la información y/o las aplicaciones que contengan contraseñas de usuario o claves para el control de acceso a los sistemas de información no sea almacenada en texto plano y debe hacer uso de mecanismos criptográficos.
- b. Incluir en todos los sistemas de información que gestionen almacenamiento o transmisión de datos, el uso de técnicas de cifrado que garanticen la confidencialidad e integridad de dichos activos.
- c. Cifrar los discos duros de los equipos de cómputo que contengan información pública reservada o pública clasificada.
- d. Definir protocolos o certificados de cifrado en los canales de comunicación a nivel de red interna y externa.
- e. Adelantar las acciones pertinentes para la implementación del mecanismo de firma electrónica en los siguientes servicios: cifrado de documentos y comunicaciones, sede electrónica, portal del funcionario, buzón del ciudadano, business process management, automatización de procesos y procedimientos, gestión de expedientes electrónicos, archivo electrónico, gestión documental electrónica, movilidad, seguridad e identidad digital, entre otros.
- f. Cifrar la información en los procesos de recepción, almacenamiento, transmisión y/o consulta de los activos de información catalogados como información pública reservada y pública clasificada de la **DIAN**, con el propósito de proteger su confidencialidad, integridad.
- g. Utilizar herramientas, mecanismos y técnicas criptográficas que garanticen el principio de no repudio frente a las modificaciones realizadas sobre la información generada y administrada por la Entidad.
- h. Aplicar controles criptográficos en todo el ciclo de vida de los documentos o archivos digitales, cuando contengan información pública reservada y pública clasificada, datos personales sensibles o privados, semiprivados y de menores de edad.
- i. Aplicar controles criptográficos para la información de intercambio con fines tributarios, aduaneros y cambiarios. También se deben aplicar controles en la recepción, almacenamiento, consulta y/o transmisión de información y emplear esquemas de seguridad exclusivos e independientes.
- j. Utilizar técnicas criptográficas para autenticar a los usuarios o entidades externas que requieran hacer uso de los sistemas de información de la **DIAN**. Su implementación se realizará según los lineamientos establecidos en este manual.
- k. Manejar esquemas de cifrado “desde el arranque” (PBA) para los discos de almacenamiento interno de los equipos portátiles, de manera que el inicio del sistema operativo se realice con el disco ya cifrado.
- l. Implementar métodos de cifrado a nivel de dispositivo de almacenamiento, base de datos, table-space para la información pública reservada y pública clasificada.
- m. Revisar que en los sistemas de información y/o aplicaciones construidas por terceros o internos, se apliquen controles criptográficos a la información pública reservada y pública clasificada, datos personales sensibles o privados, semiprivados y de menores de edad.
- n. Administrar y controlar las llaves criptográficas.
- o. Definir roles y responsabilidades para la implementación de reglas para el uso de criptografía y la gestión de las claves.
- p. Definir lineamientos para la distribución de claves y recuperación de claves perdidas o dañadas, y también para la destrucción de llaves que se requieran en la entidad.
- q. Requerir como mínimo el uso de mecanismos de identificación basados en llave pública o su equivalente para los procedimientos de cargue automático de archivos provenientes de terceros.

- r. Regular los controles criptográficos mediante un esquema de cifrado de datos que utilice algoritmos, protocolos, mecanismos y técnicas con estándares nacionales y/o internacionales.
- s. Utilizar algoritmos, protocolos, mecanismos y técnicas de cifrado con estándares nacionales y/o internacionales.
- t. Utilizar herramientas, mecanismos y técnicas criptográficas para la protección de la información en operaciones como el cifrado, firma digital, firma electrónica y con el fin evitar el no repudio de las transacciones electrónicas.

3. Los funcionarios y terceros deben:

- a. Notificar a la Dirección de Gestión de Innovación y Tecnología la información que requiere sea cifrada según la información pública reservada y clasificada, datos personales sensibles o privados, semiprivados y de menores.
- b. Solicitar a la Dirección de Gestión de Innovación y Tecnología la disposición de controles criptográficos, de manera total o parcial, sobre las bases de datos donde se encuentre almacenada información pública reservada y pública clasificada, datos personales sensibles o privados, semiprivados y de menores de edad.
- c. Cumplir con los lineamientos de cifrados definidos en esta política y emplear las herramientas adoptadas por la Dirección de Gestión de Innovación y Tecnología para este fin.
- d. Cifrar previamente y generar una huella digital o código hash cuando se requiere enviar información pública reservada o pública clasificada, datos personales sensibles o privados, semiprivados y de menores de edad, a través de la herramienta de correo electrónico institucional.
- e. Almacenar las claves de forma segura y comprometerse a restringir el acceso solo a los usuarios autorizados. De igual forma, una copia de las claves, si esta existe, deberá ser almacenada en sitio seguro para su recuperación en caso de que esta se extravíe.
- f. Cumplir las condiciones de cifrado definidas por la Oficina de Seguridad de la Información para el envío de correos electrónicos de la entidad, cuando estos cuenten con información pública reservada o pública clasificada.
- g. Dar cumplimiento de la presente política con el fin de que la información pública reservada y pública clasificada, datos personales sensibles o privados, semiprivados y de menores de edad, se cifre en el momento de almacenarse o transmitirse por cualquier medio.

E. Controles relacionados:

- 1. 5.22. – Seguimiento, revisión y gestión de cambios de servicios de proveedores
- 2. 5.31. – Requisitos legales, estatutarios, reglamentarios y contractuales
- 3. 8.24. – Uso de criptografía

8.25 Ciclo de vida de desarrollo seguro

- A. Objetivo de control:** definir los lineamientos y directrices de desarrollo seguro de software y gestionar la seguridad y privacidad de la información, como parte integral del ciclo de vida de desarrollo seguro del software de los sistemas de información de la **DIAN**, el cual incluye planificación, análisis, diseño, implementación, despliegue y mantenimiento

B. Alcance: el alcance de este lineamiento aplica a los proveedores de software, contratistas, terceros, así como a la Dirección de Gestión de Innovación y Tecnología y a la Subdirección de Soluciones y Desarrollo, en la medida en que estas instancias son responsables de adquirir, diseñar, recibir, instalar y/o desarrollar software para la DIAN. El alcance de este lineamiento aplica para los proveedores de software, contratistas, terceros, la Dirección de Gestión de Innovación y Tecnología y la Subdirección de Soluciones y Desarrollo, por cuanto son las que adquieren, reciben, instalan y/o desarrollan software para la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo y proceso de gestión.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Definir y documentar detalladamente los procedimientos y controles para la transferencia de software desde desarrollo hacia producción y para los desarrollos contratados.
2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Establecer en lo posible las últimas metodologías para el desarrollo de software, que incluyan la definición de requerimientos de seguridad y las buenas prácticas de desarrollo seguro.
 - b. Gestionar el correcto funcionamiento y separación de ambientes de desarrollo, pruebas, integración y producción.
 - c. Implementar los lineamientos y los controles establecidos por la Dirección de Gestión de Innovación y Tecnología en relación con lo definido en este control.
 - d. Confirmar que la plataforma tecnológica, las herramientas de desarrollo y los componentes de cada sistema de información se encuentren actualizados con los últimos parches generados para las versiones en uso y que estén ejecutando la última versión aprobada del sistema.
 - e. Certificar que todo sistema de información adquirido o desarrollado utilice herramientas de desarrollo licenciadas y reconocidas en el mercado.
 - f. Gestionar el cumplimiento del manual de políticas y lineamientos de seguridad de la información, normatividad y lineamientos vigentes en la **DIAN** durante todo el ciclo de desarrollo.
 - g. Proteger el código fuente del software construido, para que personal no autorizado no pueda descargarlo ni modificarlo.
 - h. Certificar que la información a ser entregada para sus pruebas esté enmascarada o anonimizada, no se revele información confidencial de los ambientes de producción y que no contiene datos personales reales de acuerdo con lo establecido en la Ley 1581 de 2012.
3. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Implementar el correcto funcionamiento y separación de ambientes de desarrollo, pruebas, integración y producción.
 - b. Disponibilidad y continuidad:

- Garantizar la operación continua de los servicios críticos de la organización.
- Diseñar e implementar planes de contingencia y recuperación ante desastres (DRP/BCP).
- Monitorear la capacidad de los recursos para evitar caídas por sobrecarga.

c. Integridad y rendimiento

- Mantener la correcta configuración de los sistemas para que los datos no se vean alterados de manera indebida.
- Optimizar el rendimiento de la infraestructura para soportar las aplicaciones y servicios con eficiencia.

E. Controles relacionados:

1. 5.8. – Seguridad de la información en la gestión de proyectos.
2. 5.32. – Derechos de propiedad intelectual.
3. 8.4. – Acceso al código fuente.
4. 8.9 – Gestión de la configuración.
5. 8.27. – Principios de arquitectura e ingeniería de sistemas seguros.
6. 8.28. – Codificación segura.
7. 8.29. – Pruebas de seguridad en desarrollo y aceptación.
8. 8.30. – Desarrollo subcontratado.
9. 8.31. – Separación de los entornos de desarrollo, prueba y producción.
10. 8.32. – Gestión del cambio.

8.26 Requisitos de seguridad de la aplicación

A. Objetivo de control: identificar, especificar y aprobar los requisitos de seguridad de la información al desarrollar o adquirir aplicaciones.

B. Alcance: el alcance de este lineamiento aplica la Dirección de Gestión de Innovación y Tecnología y la Subdirección de Soluciones y Desarrollo, encargados de verificar la protección de la información y que todos los requisitos de seguridad de la información de identifiquen y aborden al desarrollar o adquirir aplicaciones.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:
 - a. Identificar y especificar los requisitos de seguridad de las aplicaciones, estos requisitos se pueden determinar a través de una evaluación de riesgos.
 - b. Incluir en los requisitos de seguridad de las aplicaciones, como mínimo, los siguientes aspectos:

- Nivel de confianza en la identidad.
- Identificar el tipo de información y nivel de clasificación a ser procesado por la aplicación.
- Necesidad de segregación de acceso y nivel de acceso a datos y funciones en la aplicación.
- Resiliencia contra ataques maliciosos o interrupciones no intencionales (por ejemplo, protección contra desbordamiento de búfer o inyecciones de lenguaje de consulta estructurado (SQL)).
- Requisitos legales, estatutarios y reglamentarios en la jurisdicción donde se genera, procesa, completa o almacena la transacción.
- Necesidad de privacidad asociada con todas las partes involucradas.
- Los requisitos de protección de cualquier información confidencial.
- Protección de datos en proceso, en tránsito y en reposo.
- Necesidad de cifrar de forma segura las comunicaciones entre todas las partes involucradas.
- Controles de entrada, incluidas verificaciones de integridad y validación de entrada.
- Controles automatizados (por ejemplo, límites de aprobación o aprobaciones duales).
- Controles de salida, considerando también quién puede acceder a las salidas y su autorización.
- Restricciones entorno al contenido de los campos de “texto libre”, ya que pueden coincidir al almacenamiento no controlado de datos confidenciales (por ejemplo, datos personales).
- Requisitos derivados del proceso de negocio, tales como registro y seguimiento de transacciones, requisitos de no repudio.
- Requisitos exigidos por otros controles de seguridad (por ejemplo, interfaces para registro y monitoreo o sistemas de detección de fuga de datos).
- Manejo de mensajes de error.
- c. Identificar requisitos de seguridad en los servicios transacciones que puedan realizar en desarrollos de la entidad o desarrollos subcontratados.
- d. Incluir en las cláusulas contractuales para los desarrollos subcontratados los lineamientos mencionados en el presente control.
- e. Pruebas de Penetración: Simular ataques reales para evaluar y corregir vulnerabilidades.
- f. Actualización y Parches Continuos: Mantener el software y los componentes dependientes actualizados para evitar explotaciones.
- g. Ejecutar como mínimo las prácticas referenciadas en OWASP o en *secure software development lifecycle*, así mismo, validar la inclusión de buenas prácticas como: *SANS CIS Controls version 8*, *Web Application Security Consortium*, *Common Weakness Enumeration (CWE)*, *Department of Homeland Security: Build Security In Porta*, *CERT Secure Coding* y *MSDN Security Developer Center*.
- h. Incluir en los desarrollos de la entidad una lista de validación de entradas, verificando: fuentes de datos, datos de entradas, fallas de entrada, tipos de datos no esperados, rangos de datos, largos de datos, caracteres considerados peligrosos.
- i. Se debe sanear todas las salidas de datos no confiables hacia consultas SQL, XML y LDAP en los sistemas de información que desarrolle la entidad; así mismo las salidas de datos no confiables hacia un comando del sistema operativo.
- j. Administrar la autenticación y las contraseñas de los sistemas de información de la entidad, teniendo en cuenta al menos lo siguiente: autenticación en todos los sistemas, servicios de autenticación estándar, centralizar los controles de autenticación, falla

segura de autenticación, cifrar las contraseñas, no enviar contraseñas por correo cuando se solicite “olvido contraseñas”.

- k. Administrar las sesiones de los sistemas de información que se desarrollen en la entidad, incluyendo mínimos los siguientes criterios: deshabilitar logueos persistentes, generar un nuevo identificador de sesión luego de cada re-autenticación, no permitir logueos concurrentes con el mismo usuario.
- l. Implementar un control de acceso desde los desarrollos de la entidad, teniendo en cuenta como mínimo lo siguiente: restringir el acceso a URL (Uniform Resource Locator) protegidas, limitar el acceso a funciones protegidas, evitar las referencias directas a objetos, restringir el acceso a servicios y limitar el número de transacciones que un usuario común o un dispositivo puede desarrollar en determinado período.
- m. Incluir prácticas de criptografía en los sistemas que desarrolle la entidad, teniendo en cuenta el FIPS 140-2 o un estándar equivalente, se sugiere (Ver <http://csrc.nist.gov/groups/STM/cmvp/validation.html>).
- n. Configurar los errores y los logs de los sistemas de información desarrollados en la entidad que permitan identificar como mínimo lo siguiente: a) registrar log de fallas de validación, b) registrar intentos de autenticación, c) registrar log de fallas en los controles de acceso y d) registrar los eventos de intento de evasión de controles.
- o. Proteger los datos implementando el mínimo privilegio, restringiendo el acceso de los usuarios solamente a la funcionalidad, datos y sistemas de información que son necesarios para realizar sus tareas.
- p. Remover cualquier aplicación que no sea necesaria y la documentación de los sistemas que pueda revelar información útil para los atacantes.

E. Controles relacionados:

- 1. 5.17. – Información de autenticación.
- 2. 5.31. – Requisitos legales, estatutarios, reglamentarios y contractuales.
- 3. 5.32. – Derechos de propiedad intelectual.
- 4. 5.33. – Protección de registros.
- 5. 5.34. – Protección de datos personales (PII).
- 6. 5.35. – Revisión independiente de la seguridad de la información.
- 7. 5.36. – Cumplimiento de políticas, normas y estándares de seguridad de la información.
- 8. 8.2. – Derechos de acceso privilegiado.
- 9. 8.5. – Autenticación segura.
- 10. 8.24. – Uso de criptografía.

8.27 Principios de arquitectura e ingeniería de sistemas seguros

A. Objetivo de control: establecer, documentar y mantener principios de arquitectura para la construcción de sistemas seguros y la aplicación a cualquier actividad de implementación de sistemas de información y/o software.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología y la Subdirección de Soluciones y Desarrollo encargadas de verificar que los sistemas de información se diseñen, implementen y operen de forma segura dentro del ciclo de vida del desarrollo.

C. Características de control:

- 1. Tipo de control: preventivo.

2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:

- a. Definir y documentar procedimientos y controles para la construcción, mantenimiento y/o ajustes de los sistemas de información y/o software aplicando los principios de construcción de seguridad.
- b. Incluir el tema de seguridad en el diseño e implementación en todas las capas de arquitectura (negocio, datos, aplicaciones y tecnología) equilibrando la necesidad de seguridad de la información y el manejo de datos personales de acuerdo con lo establecido en la Ley 1581 de 2012.
- c. Realizar el análisis de patrones de ataques conocidos y tenerlos en cuenta en la construcción y/o ajustes de los sistemas de información y/o software.
- d. Revisar y actualizar con regularidad los protocolos, principios y procedimientos establecidos para la construcción de software y/o sistemas de información, teniendo en cuenta la mejora continua para contribuir a los estándares de seguridad y poder combatir nuevas amenazas potenciales. Las actualizaciones que se realicen deben cumplir el versionamiento documental establecido en el Sistema de Gestión Documental.
- e. Verificar que se cumplan los protocolos, principios y/o procedimientos establecidos para el ciclo de desarrollo de seguro software (incluidos los de arquitectura), cuando se contrate con un tercero la construcción y/o mantenimiento de sistemas de información y/o software para la entidad.
- f. Crear capacidades de los controles de seguridad para prevenir, detectar y responder a eventos de seguridad en los sistemas de información.
- g. Incluir en la definición, documentación e implementación, como mínimo, los siguientes principios de arquitectura en construcción de sistemas o software seguro: "confianza cero", "seguridad por diseño", "defensa en profundidad", "seguridad por defecto", "denegación predeterminada", "fallo seguro", "desconfiar de la entrada de aplicaciones externas", "seguridad en implementación", "asumir incumplimiento", "privilegio mínimo", "facilidad de uso y administración", "funcionalidad mínima", "tolerancia a fallos y resiliencia", "cifrado y protección de datos", "respuesta a incidentes planificada", "separación de funciones", "superficie mínima de ataque", "gestión segura de configuraciones", "auditoría y registro", "diseño modular y reutilizable", "seguridad adaptativa", "privacidad por diseño", "economía de mecanismos (simplicidad)" y "validación de entrada y salida".

2. La Dirección de Gestión de Innovación y Tecnología debe:

- a. Verificar que los operadores de tecnologías de la información incluyan las siguientes consideraciones de seguridad de la información, para las transacciones por redes de telecomunicaciones:
 - El uso de mecanismos criptográficos por parte de cada una de las partes involucradas en la transacción.
 - Todos los aspectos de las transacciones deben validar que:
 - i. La información de autenticación privada y confidencial del usuario, de todas las partes, sea validada y verificada.
 - ii. La transacción permanezca confidencial y se mantenga la privacidad asociada con todas las partes involucradas.

- iii. La trayectoria de las comunicaciones entre todas las partes involucradas esté cifrada.
 - iv. Los protocolos usados para comunicarse entre todas las partes involucradas sean seguros.
 - v. El almacenamiento de los detalles de la transacción se realice en un entorno que no sea accesible públicamente y no sea retenido ni expuesto en un medio de almacenamiento accesible directamente desde la Web.
- b. Donde se utilice una autoridad confiable (por ejemplo, para los propósitos de emitir y mantener firmas o certificados digitales), la seguridad debe estar integrada e incluida en todo el proceso de gestión de certificados/firmas de un extremo a otro.

E. Controles relacionados:

- 1. 5.12. – Clasificación de la información.
- 2. 5.15. – Control de acceso.
- 3. 5.16. – Gestión de identidad.
- 4. 5.17. – Información de autenticación.
- 5. 5.18. – Derechos de acceso.
- 6. 8.2. – Derechos de acceso privilegiado.
- 7. 8.5. – Autenticación segura.

8.28 Codificación segura

A. Objetivo de control: aplicar los principios de codificación segura al desarrollo de software en la entidad.

B. Alcance: el alcance de este lineamiento aplica para la Oficina de Seguridad de la Información y la Subdirección de Soluciones y Desarrollo, encargadas de verificar que el software se escriba de forma segura y definir controles para reducir las posibles vulnerabilidades de seguridad de la información en el software.

C. Características de control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Oficina de Seguridad de la Información debe:
 - a. Monitorear las posibles amenazas con el fin de mantener actualizada la base de conocimiento sobre las vulnerabilidades del software y poder asesorar y guiar acerca de los principios de codificación segura en la entidad a través de la mejora y aprendizaje continuos.
- 2. La Subdirección de Soluciones y Desarrollo debe:
 - a. Definir y documentar la codificación segura en el desarrollo de software (en la planificación, en la ejecución y en la revisión y mantenimiento de software en la entidad).
 - b. Implementar la codificación segura en el desarrollo de software en la entidad.

- c. Establecer y aplicar las líneas base seguras aplicables para el desarrollo de software, estas definiciones deben extenderse a los componentes de software de terceros y el software de código abierto.
- d. Planificar los requisitos previos antes de la codificación segura, los cuales deben incluir los siguientes aspectos:
 - Configuración de herramientas de desarrollo, como entornos de desarrollo integrados para ayudar a hacer cumplir la creación de código seguro.
 - Seguir la orientación emitida por los proveedores de herramientas de desarrollo y entornos de ejecución.
 - Mantenimiento y uso de herramientas de desarrollo actualizadas (por ejemplo, compiladores).
 - Calificación de los desarrolladores en la escritura de código seguro.
 - Diseño y arquitectura seguros.
 - Normas de codificación seguras.
 - Uso de ambientes controlados para el desarrollo.
- e. Realizar actividades de capacitación en codificación segura en el equipo de desarrollo.
- f. Evitar el uso de técnicas inseguras en las diferentes fases del desarrollo de software.
- g. Realizar análisis de vulnerabilidades de código para los sistemas que se consideren críticos. Incluyendo todos los desarrollos de software.
- h. Realizar análisis de errores de codificación comunes, documentarlos y promover su mitigación en el personal de desarrollo de software.
- i. Incluir en las buenas prácticas de desarrollo de software el control de versiones para administrar el código por versiones, historial de cambios para facilitar la revisión y la recuperación del código.

E. Controles relacionados:

- 1. 8.8. – Gestión de vulnerabilidades técnicas.
- 2. 8.25 Ciclo de vida de desarrollo seguro.
- 3. 8.29. – Pruebas de seguridad en desarrollo y aceptación.

8.29 Pruebas de seguridad en desarrollo y aceptación

A. Objetivo de control: llevar a cabo pruebas de funcionalidad de la seguridad durante el ciclo de desarrollo de sistemas de información y/o software, para las actualizaciones, ajustes, nuevos sistemas de información, nuevos desarrollos propios de la **DIAN** y/o software, así como establecer criterios de aceptación relacionados.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo encargadas de validar el cumplimiento de los requisitos de seguridad de la información cuando las aplicaciones o el código se implementen en el entorno de producción.

C. Características de control:

- 1. Tipo de control: preventivo.
- 2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

- 1. La Subdirección de Soluciones y Desarrollo debe:

- a. Definir el alcance de las pruebas, las cuales deben ser proporcionales a la importancia y naturaleza del sistema, aplicación y/o software.
- b. Realizar pruebas durante los ciclos de desarrollo de los sistemas, elaborando un programa detallado de las actividades, entradas de las pruebas y las salidas esperadas bajo diferentes condiciones.
- c. Incluir en las pruebas los siguientes requisitos de seguridad de la información:
 - Cumplir con el diligenciamiento de los formatos vigentes para pruebas funcionales por parte de los funcionarios dueños de los sistemas de información y/o software antes de cualquier puesta en producción, documento(s) que certifica(n) la realización de estas pruebas.
 - Certificar la ejecución de pruebas no funcionales y de seguridad por parte de la Dirección de Gestión de Innovación y Tecnología por medio del diligenciamiento del formato vigente para este fin y anexar las evidencias consolidadas.
 - Evidenciar la certificación y aceptación por parte de las dependencias funcionales sobre las pruebas realizadas.
- d. Llevar a cabo las pruebas de aceptación en un ambiente staging, para verificar la conformidad del sistema y evitar introducir vulnerabilidades al ambiente de producción de la **DIAN**.
- e. Verificar que el entorno de prueba, en la medida de lo posible, coincida con el entorno de producción, teniendo en cuenta la separación de los entornos de desarrollo, prueba y producción.
- f. Establecer la ejecución de pruebas automáticas en los sistemas de información en la entidad.
- g. Realizar pruebas para detectar errores en los sistemas de información en ambientes de pruebas y producción.
- h. Establecer pruebas de rendimiento automáticas para identificar rápidamente los problemas de rendimiento de los sistemas de información.
- i. Incluir pruebas de capacidad de los sistemas de información, definiendo límites de uso y capacidad máxima esperada, incluyendo pruebas cuando se superen los límites definidos.
- j. Establecer pruebas de seguridad automáticas dinámicas (DAST) y estáticas (SAST) incluyendo pruebas de penetración automatizadas del proceso de compilación e implementación de los sistemas de información.

E. Controles relacionados:

1. 5.32. – Derechos de propiedad intelectual.
2. 8.25. – Ciclo de vida de desarrollo seguro.
3. 8.26. – Requisitos de seguridad de la aplicación.
4. 8.27. – Principios de arquitectura e ingeniería de sistemas seguros.
5. 8.28. – Codificación segura.
6. 8.29. – Pruebas de seguridad en desarrollo y aceptación.
7. 8.31. – Separación de los entornos de desarrollo, prueba y producción.

8.30 Desarrollo subcontratado

- A. Objetivo de control:** supervisar y efectuar seguimiento de la actividad de desarrollo de sistemas de información y/o software contratado externamente.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo, la cual debe asegurar que sean implementadas las medidas de seguridad de la información requeridas por la entidad en el desarrollo de sistemas subcontratados.

C. Características de control:

1. Tipo de control: preventivo y detectivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y tecnología debe:
 - a. Suministrar al desarrollador externo el modelo de amenazas debidamente aprobado.
 - b. Incluir en las cláusulas contractuales de los desarrollos subcontratados obligaciones relacionadas con el cumplimiento de buenas prácticas de desarrollo, entrega de pruebas y resultados de análisis y remediación de vulnerabilidades realizadas al desarrollo subcontratado.
 - c. Incluir en las cláusulas contractuales de desarrollos subcontratados, que en caso de que la entidad realice un análisis de vulnerabilidades e identifique en el software subcontratado alguna vulnerabilidad, el tercero debe realizar la remediación sin incurrir en costos adicionales.
 - d. Verificar y certificar las evidencias suministradas por el desarrollador externo, considerando como mínimo que:
 - Se haya realizado las pruebas suficientes para determinar que no exista contenido malicioso intencional y no intencional en el momento de la entrega.
 - Se haya realizado pruebas suficientes para proteger contra la presencia de vulnerabilidades conocidas.
 - Se haya realizado las pruebas de seguridad estáticas y dinámicas de software.
 - Se haya entregado la documentación, componentes y artefactos creados.
 - Todo desarrollo ejecutado por un tercero debe usar como mínimo las prácticas referenciadas en OWASP o en *Secure software development lifecycle*.

E. Controles relacionados:

1. 5.32. – Derechos de propiedad intelectual.
2. 8.25. – Ciclo de vida de desarrollo seguro.
3. 8.26. – Requisitos de seguridad de la aplicación.
4. 8.27. – Principios de arquitectura e ingeniería de sistemas seguros.
5. 8.28. – Codificación segura.
6. 8.29. – Pruebas de seguridad en desarrollo y aceptación.
7. 8.31. – Separación de los entornos de desarrollo, prueba y producción.

8.31 Separación de los entornos de desarrollo, prueba y producción

A. Objetivo de control: reducir los riesgos de acceso o cambios no autorizados en los ambientes utilizados para el desarrollo de aplicaciones en la entidad, con la separación de ambientes de desarrollo, pruebas y producción.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología y la Subdirección de Infraestructura Tecnológica y de Operaciones, ambas encargadas de establecer y proteger adecuadamente los ambientes para las actividades de desarrollo e integración de sistemas que comprendan todo el ciclo de vida de desarrollo de sistemas de información y/o software.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad e integridad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Definir los procedimientos, mecanismos o controles necesarios para reducir los riesgos de accesos o cambios no autorizados en ambientes utilizados en el ciclo de vida del desarrollo.
 - b. Proveer los recursos necesarios para la implementación de controles que permitan la separación de ambientes de pruebas y producción, teniendo en cuenta consideraciones como: controles para el intercambio de información entre los ambientes de pruebas y producción, la inexistencia de compiladores, editores o fuentes en los ambientes de producción y un acceso diferente para cada uno de los ambientes.
2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:
 - a. Validar que todos los desarrollos de software que sean realizados por funcionarios, usuarios o contratistas dentro de la entidad, sean llevados a cabo en las plataformas de desarrollo de la entidad dispuestas para estas funciones.
 - b. Realizar la instalación de nuevas aplicaciones misionales o nuevas plataformas de forma tal que se integren al correcto funcionamiento de la red o de las aplicaciones en producción.
 - c. Definir y documentar las reglas para la transferencia de software del ambiente de pruebas a producción.
 - d. Verificar que todo cambio que se realice en los sistemas de información en producción sea probado en un ambiente de pruebas antes de aplicarlo en los sistemas en producción, salvo que sean cambios de emergencia y que no afecten la continuidad del negocio.
 - e. Verificar que los compiladores, editores y otras herramientas de desarrollo y utilitarios del sistema, no sean accedidos desde sistemas de producción.
 - f. Verificar que en los ambientes de pruebas y producción los usuarios usen perfiles diferenciados; igualmente debe verificar que los menús desplieguen mensajes de identificación apropiados para reducir el riesgo de error.
 - g. Restringir el uso de datos personales en ambientes de desarrollo, conforme con lo establecido en la Ley 1581 de 2012.
 - h. Implementar y controlar el acceso a los ambientes de desarrollo seguro.
 - i. Realizar monitoreo, documentación y seguimiento a los cambios de estos ambientes y en los repositorios donde se almacena el código fuente.
 - j. Realizar las copias de respaldo en lugares seguros y fuera del entorno de desarrollo.
 - k. Monitorear y controlar los datos que se generen desde y hacia los ambientes de desarrollo seguro.

3. La Subdirección de Soluciones y Desarrollo debe:

- a. Verificar que todo cambio que se realice en los sistemas información en producción sea probado en un ambiente de pruebas antes de aplicarlo en los sistemas en producción, salvo que sean cambios de emergencia y que no afecten la continuidad del negocio.
- b. Validar que todos los desarrollos de software que sean realizados por funcionarios, usuarios o contratistas dentro de la entidad, sea llevados a cabo en las plataformas de desarrollo de la entidad dispuestas para estas funciones.

E. Controles relacionados:

1. 8.29. – Pruebas de seguridad en desarrollo y aceptación.
2. 8.33. – Información de prueba.

8.32 Gestión del cambio

A. Objetivo de control: controlar los cambios que se presenten sobre los sistemas de información, aplicativos y/o servicios de la entidad a través de la definición de procedimientos formales de control de cambios a la infraestructura tecnológica de la entidad y dentro del ciclo de vida de desarrollo.

B. Alcance: el alcance de este lineamiento aplica para la Dirección de Gestión de Innovación y Tecnología, la Subdirección de Soluciones y Desarrollo y la Subdirección de Infraestructura Tecnológica y de Operaciones encargadas de controlar y reducir, al mínimo, el impacto sobre los cambios normales o de emergencia que se presenten sobre los sistemas de información, aplicativos, servicios y/o infraestructura de la entidad.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, integridad y disponibilidad.

D. Lineamientos:

1. La Dirección de Gestión de Innovación y Tecnología debe:
 - a. Evitar las modificaciones a los paquetes de software suministrados por los proveedores, los cuales se deben limitar a los cambios necesarios; y todos los cambios se deben controlar estrictamente.
 - b. Definir y mantener actualizado el procedimiento de gestión de cambios de TI.
 - c. Implementar un software para la administración de la gestión de los cambios de TI.
 - d. Definir indicadores de gestión para el monitoreo de la gestión de cambios y toma de decisiones.
 - e. Verificar que los paquetes suministrados por el vendedor-proveedor no hayan sufrido modificaciones antes de ser instalados.
 - f. Incluir criterios de seguridad en los procedimientos de cambios de TI que implementen en la entidad.
 - g. Cumplir las prácticas de gestión de cambios de TI, como es: registrar, planear, evaluar, autorizar, probar, implementar y cerrar todos los cambios de TI.
2. La Subdirección de Soluciones y Desarrollo debe:

- a. Registrar las solicitudes de cambio en el Formato de Requerimiento de Cambio (FRC), ya sea físicamente o en una herramienta diseñada para tal fin.
- b. Realizar un documento con las solicitudes programadas y la fecha/hora propuesta, de igual manera anexar un documento de interrupción planeada del servicio, donde se detallen los activos que están indisponibles y el tiempo previsto de inactividad.
- c. Evaluar los cambios desde la perspectiva de la misionalidad y de TI conforme a su nivel de riesgo. Los criterios para tener en cuenta, entre otros, son: seguridad, complejidad, experiencia, capacidad, disponibilidad, continuidad y criticidad.
- d. Verificar el cambio en ambientes de pruebas preparados para dicha actividad y obtener la aprobación técnica y funcional.
- e. Implementar los cambios autorizados a través del grupo técnico correspondiente, conforme a la fecha aprobada. En lo posible realizarlo a través de órdenes de servicio para poder ser rastreadas. Se debe revisar el plan de reversión que debe estar explícitamente en la aprobación del cambio.
- f. Revisar y cerrar los cambios para su evaluación en post implementación, donde se verifique si el cambio logró sus objetivos, si el solicitante y las partes interesadas están satisfechos, si no hay efectos secundarios inesperados y si se documentaron las lecciones aprendidas (cuando aplique).
- g. Certificar en conjunto con los funcionarios dueños de los sistemas de información que los cambios implementados en los sistemas de información y/o software, y/o infraestructura, se hayan realizado en los tiempos definidos y no afectaron los procesos de negocio involucrados.
- h. Mantener un registro actualizado de todos los sistemas de información y/o software, versión de estos, fecha de última compilación y responsable(s) de su mantenimiento y soporte.
- i. Restringir el acceso a la documentación de sistemas de información, bibliotecas de códigos fuentes y programas ejecutables, solo a funcionarios autorizados. La excepción a este lineamiento son los manuales de usuario, manuales de capacitación, u otros documentos destinados a los usuarios del o los sistemas de información.
- j. Revisar los procedimientos de integridad y control de aplicaciones para que no estén comprometidos debido a los cambios en las plataformas de operaciones.
- k. Verificar que los cambios en la plataforma operativa se hagan a tiempo para permitir las pruebas y revisiones apropiadas antes de cualquier implementación.
- l. Considerar los siguientes aspectos, en caso de que un paquete de software necesite modificaciones:
 - Los niveles de riesgo en materia de integridad y afectación de controles de seguridad. En caso de verse comprometidos se deben tomar las medidas requeridas.
 - Si el paquete de software es suministrado por un proveedor externo, la Dirección de Gestión de Innovación y Tecnología debe solicitar el permiso de modificación y obtener el certificado para no perder su integridad.
 - Cualquier ajuste realizado debe ser documentado y debidamente aprobado por la Dirección de Gestión de Innovación y Tecnología a través del comité de cambios.
 - La Dirección de Gestión de Innovación y Tecnología, debe realizar una evaluación del impacto en caso de ser responsable del mantenimiento futuro del software como resultado de los cambios.
 - Revisar la compatibilidad con otros sistemas de información y/o software.
- m. Probar y documentar los cambios completamente, de manera que se puedan aplicar de nuevo, si es necesario, a futuras actualizaciones de software.

3. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:

- a. Verificar que todo cambio en los servicios de infraestructura y/o sistemas de información de la **DIAN**, cuenten con una solicitud de cambio y se deberán realizar siguiendo el procedimiento de gestión de cambios.
- b. Seguir procesos formales de documentación, especificación, pruebas, control de calidad y gestión de la implementación, para todos los nuevos desarrollos, funcionalidades y cambios importantes a los sistemas y software existentes.
- c. Cumplir con los lineamientos de gestión de cambios de este manual.
- d. Evitar usar actualizaciones automáticas de software en los activos de información críticos, ya que algunas actualizaciones pueden hacer que fallen aplicaciones importantes.
- e. Revisar las aplicaciones críticas del negocio y tras cambios que se presenten realizar pruebas, para que no haya impacto adverso en las operaciones o seguridad de los activos de información críticos de la **DIAN**.
- f. Establecer y documentar las condiciones para que los cambios sean exitosos de acuerdo con la naturaleza de los mismos, realizar la medición de la efectividad del cambio contrastada frente a la funcionalidad, establecer estrategias para reducir el impacto de los cambios sobre el servicio.
- g. Realizar la gestión de los riesgos asociados al cambio tecnológico dentro del proceso de gestión de cambios.

E. Controles relacionados:

1. 5.30 – Preparación de las TIC para la continuidad del negocio.
2. 5.37 – Procedimientos operativos documentados.
3. 8.29 – Pruebas de seguridad en desarrollo y aceptación.
4. 8.31 – Separación de los entornos de desarrollo, prueba y producción.

8.33 Información de prueba

A. Objetivo de control: realizar la selección, protección y control de los datos utilizados en las pruebas de los sistemas de información y efectuarlas de manera cuidadosa.

B. Alcance: el alcance de este lineamiento aplica para la Subdirección de Soluciones y Desarrollo y la Subdirección de Infraestructura Tecnológica y de Operaciones quienes hacen uso de los ambientes de pruebas y el uso de los datos de pruebas en los sistemas de información de la **DIAN**.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad e integridad.

D. Lineamientos:

1. La Subdirección de Soluciones y Desarrollo debe:

- a. Solicitar autorización por parte de usuario funcional cada vez que se copie información operacional de producción a un ambiente de desarrollo y/o pruebas.
- b. Borrar del ambiente de desarrollo y/o pruebas inmediatamente después de finalizar las pruebas, la información operacional que haya sido copiada.
- c. Registrar el copiado y uso de la información operacional para ejecutar auditorías, en los casos que sea requerido.
- d. Certificar que no se revele información confidencial de los ambientes de producción.
- e. No usar, durante la ejecución de pruebas en ambientes de desarrollo, datos que contengan información personal o información sensible que esté contenida en el ambiente de producción de los sistemas de información. Cuando se vayan a utilizar se deben anonimizar.

2. La Subdirección de Infraestructura Tecnológica y de Operaciones debe:

- a. Aplicar los procedimientos de control de acceso, tanto a los ambientes de producción, como a los ambientes desarrollo y/o pruebas.
- b. Enmascarar la información entregada para las pruebas.
- c. Certificar que no se revela información confidencial de los ambientes de producción.

E. Controles relacionados:

1. 8.11 - Enmascaramiento de datos.
2. 8.31 - Separación de los entornos de desarrollo, prueba y producción.

8.34 Protección de los sistemas de información durante las pruebas de auditoría

- A. Objetivo de control:** minimizar el impacto de la auditoría y otras actividades de aseguramiento y control, en los sistemas de información para minimizar las afectaciones a la disponibilidad, integridad y confidencialidad de la información de genera y administra la Entidad.
- B. Alcance:** el alcance de este lineamiento aplica a la Dirección de Gestión de Innovación y Tecnología, como responsable de la gestión de los sistemas de información, los cuales deben estar disponibles para atender las actividades de auditoría que realicen los entes de control, tanto internos como externos.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad e integridad.

D. Lineamientos:

1. La Oficina de Seguridad de la Información debe:
 - a. Definir los requisitos mínimos que se deben tener en cuenta al momento de realizar actividades de auditoría, aseguramiento y control para minimizar la afectación de la seguridad de la información a los sistemas de información y los datos de la Entidad.
2. La Dirección de Gestión de Innovación y Tecnología debe:

- a. Implementar los requisitos mínimos que se deben tener en cuenta al momento de realizar actividades de auditoría, aseguramiento y control a los sistemas de información de la Entidad.
- b. Entregar acceso a los sistemas de información y los datos solo en modo de lectura para los procesos de auditoría, aseguramiento y control.
- c. Establecer los roles y responsabilidades en términos de seguridad de la información de todos los actores que hagan parte de los procesos de auditoría, aseguramiento y control.
- d. Definir el alcance de las pruebas técnicas y los requisitos para solicitudes especiales y hacer el seguimiento de estas.
- e. Evitar que las pruebas de auditoría en producción afecten la disponibilidad de los sistemas de información o degradación de los servicios.
- f. Asegurar los datos entregados a los entes de control internos o externos en términos de integridad, confidencialidad, trazabilidad y no repudio utilizando mecanismos para esto como actas de entrega, mecanismos de hash, cifrado de datos, etc.

E. Controles relacionados:

1. 5.2 - Roles y responsabilidades de seguridad de la información.

9. CONTROLES ADICIONALES

A continuación, se describen los lineamientos y políticas que buscan **reforzar la resiliencia del SGSI** frente a riesgos modernos, mejorar la **confidencialidad, integridad y disponibilidad** de la información, y alinear la norma con **tendencias regulatorias y tecnológicas**.

9.1 Analítica De Datos

A. Objetivo de control:

Garantizar que todos los procesos y actividades orientados al análisis de datos en la Entidad se ejecuten bajo principios de seguridad, privacidad, ética y uso responsable de la información. Para ello, se deberán implementar controles que regulen el acceso, procesamiento y almacenamiento de datos personales y sensibles, utilizando exclusivamente las herramientas de almacenamiento, procesamiento y visualización definidas por la organización, las cuales se encuentran alineadas y avaladas conforme al esquema analítico de la DIAN.

B. Alcance: el alcance de este lineamiento aplica a la Subdirección de Información y Analítica, responsable del gobierno de datos de la Entidad y de los lineamientos del esquema analítico de la DIAN. También aplica a la Subdirección de Infraestructura Tecnológica y de Operaciones, encargada de gestionar los accesos a las fuentes de información en la DIAN; y a la Subdirección de Procesamiento de Datos, responsable de administrar la arquitectura, calidad y disponibilidad de los datos institucionales para habilitar su uso seguro, eficiente y estratégico en toda la Entidad, así como de definir e implementar las políticas y procesos para la operación del repositorio único de datos de la DIAN. Todas las áreas, trabajen o no con información misional, deberán observar las recomendaciones indicadas en este capítulo, garantizando que ningún conjunto de datos quede expuesto, incluida la información de las áreas de apoyo, donde también se gestionan activos de información fundamentales para el funcionamiento de la Entidad.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad e integridad.

D. Lineamientos:

1. La **Subdirección de Información y Analítica** debe:

- a. Definir y documentar los roles, responsabilidades y niveles de acceso requeridos para garantizar la seguridad de la información utilizada en los procesos y procedimientos de analítica de datos, tanto en el nivel central como en las seccionales. Esta definición deberá incluir a todos los funcionarios que desempeñen funciones de análisis de datos, sin limitarse únicamente a quienes cuenten con la ficha AT-AD.
- b. Definir lista de datos requeridos para la analítica de datos, esta lista debe evitar el uso de datos que no sean requeridos para los propósitos de la dependencia.
- c. Definir métodos para el abastecimiento y recolección de los datos utilizados para la analítica de datos a través de métodos seguros que eviten la fuga de esta información.
- d. Prohibir el uso de datos personales identificables en los procesos de analítica, permitiendo únicamente datos anonimizados o agregados con fines estadísticos.
- e. Definir lineamientos técnicos y organizativos para la transferencia de datos entre sistemas de analítica, incluyendo cifrado, autenticación, registro de actividad y acuerdos de intercambio.
- f. Diseñar modelos de analítica de datos que incorporen criterios explícitos de seguridad y privacidad, incluyendo evaluación de impacto, minimización de datos y control de acceso, con el propósito que todos los involucrados tengan en cuenta estos criterios.
- g. Incorporar criterios de seguridad y privacidad en todo el ciclo analítico, incluyendo la evaluación, calibración, despliegue y monitoreo de los modelos, garantizando que los datos sean confiables, pertinentes y protegidos, así como la trazabilidad, alertas y revisión de accesos.
- h. Gestionar los riesgos asociados a la analítica de datos, mediante su identificación, evaluación, tratamiento y seguimiento, asegurando la protección de la información y el cumplimiento de los principios de seguridad.
- i. Revisar y aplicar la clasificación de la información utilizada en analítica, implementando controles para proteger su confidencialidad, integridad y disponibilidad.
- j. Definir procesos y/o procedimientos de analítica de datos con medidas técnicas, humanas y administrativas necesarias para otorgar seguridad a los registros evitando su adulteración, pérdida, consulta, uso o acceso no autorizado o fraudulento.

2. La **Subdirección de Infraestructura Tecnológica y de Operaciones** debe:

- a. Disponer de espacios para la consulta de información en los procesos de analítica de datos, con los controles de acceso definidos en este manual.
- b. Entregar únicamente la información solicitada por la dependencia de analítica de datos. Se debe evitar entregar información que no sea requerida para este propósito.

3. La **Subdirección de Procesamiento de Datos** debe:

- a. **Se deberá diseñar e implementar controles de acceso basados en roles (RBAC)** para los sistemas de almacenamiento, procesamiento y explotación de datos, **aplicando el principio de mínimo privilegio, la segregación de funciones y la gestión de accesos privilegiados**; revisando periódicamente la creación e inactivación de usuarios y roles.
- b. **Se deberá implementar trazabilidad completa** de accesos, modificaciones y uso de los datos, mediante **registros de auditoría inmutables y correlacionados, retención conforme a normativa, y alertas** ante comportamientos anómalos o intentos de exfiltración.
- c. **Clasificar los datos institucionales** según su nivel de sensibilidad (**público, confidencial, reservado**), conforme a una política institucional de clasificación.
- d. Aplicar controles diferenciados de protección y tratamiento según la clasificación, incluyendo cifrado, control de accesos, monitoreo y trazabilidad. Asegurando que solo personal autorizado acceda a datos sensibles o críticos.
- e. Diseñar e implementar procesos seguros para la recolección, almacenamiento, procesamiento, depuración y eliminación de datos, incluyendo criterios de retención, destrucción segura y trazabilidad.
- f. Establecer controles automatizados y manuales para garantizar la integridad, exactitud y consistencia de los datos, incluyendo validaciones en procesos ETL, reconciliaciones y alertas por anomalías.
- g. Implementar procesos automatizados y manuales de depuración y validación continua de datos, para asegurar su calidad y confiabilidad en el repositorio único.
- h. Prohibir el uso de datos reales en entornos de desarrollo y pruebas. Solo se permitirán excepciones documentadas y aprobadas por la autoridad competente, aplicando anonimización o seudonimización, trazabilidad, controles de acceso reforzados y por el tiempo mínimo indispensable.
- i. Aplicar el principio de **minimización y técnicas de anonimización o seudonimización** en el tratamiento de datos personales, con especial énfasis en entornos de pruebas, analítica y modelado, garantizando que solo se utilicen los datos estrictamente necesarios para el propósito definido.
- j. Implementar **medidas técnicas y organizativas para proteger los datos personales**, en cumplimiento de la legislación vigente (Ley 1581 de 2012, GDPR y demás normas aplicables), incluyendo la obtención, gestión y trazabilidad del consentimiento informado cuando corresponda.
- k. Documentar, mantener y auditar los flujos de datos entre sistemas y procesos, incluyendo origen, destino, transformación y responsables.
- l. Validar periódicamente la seguridad de las herramientas de analítica y modelado utilizadas, incluyendo revisión de configuraciones, actualizaciones, vulnerabilidades y cumplimiento de requisitos de seguridad.
- m. Asegurar que los mecanismos de intercambio de datos con terceros o entre sistemas internos cuenten con cifrado, autenticación y registro de actividad, conforme a los lineamientos de transferencia de la información.
- n. Monitorear continuamente los eventos de seguridad relacionados con el repositorio único de datos, incluyendo accesos no autorizados, anomalías y amenazas.

E. Controles relacionados:

1. 5.34 - Protección de datos personales. (PII)
2. 5.1.71 Prevención de fuga de datos.
3. 5.1.12 Clasificación de la Información.
4. 5.1.13 Etiquetado de la Información.
5. 5.1.15 Control de acceso.
6. 8.5 - Autenticación segura
7. 5.1.34 Protección de la información de datos personales (identificación personal PII)
8. Seguridad en el ciclo de vida de los datos (Cláusulas 5.10 y 5.11).
9. Seguridad en el uso de herramientas analíticas (Cláusula 8.28)
10. Gestión de la calidad de los datos (Cláusula 5.23)
11. Interoperabilidad segura (Cláusula 5.19).
12. Registro y monitoreo (Cláusula 5.17).

9.2 Inteligencia Artificial

A. Objetivo de control: establecer los lineamientos y controles de seguridad de la información que deben observarse en la **adopción, uso, desarrollo y contratación de soluciones de inteligencia artificial (incluida la IA generativa)**, con el fin de mitigar los riesgos y prevenir afectaciones a la confidencialidad, integridad y disponibilidad de la información y de los activos asociados, cuando se gestionen datos o información de los procesos misionales de la DIAN mediante dichas tecnologías.

B. Alcance: el presente lineamiento aplica a la Oficina de Seguridad de la Información —en su función de orientar, promover y verificar el uso seguro de tecnologías—; **Equipo de Gobernanza de la IA**, en lo relacionado con la definición de criterios y principios aplicables al uso de inteligencia artificial; y a los **jefes de dependencia, funcionarios, contratistas y demás terceros** que, en el marco de sus funciones, adopten, utilicen, desarrollen, integren o contraten herramientas, aplicaciones o soluciones con componentes de inteligencia artificial (incluida IA generativa), para actividades asociadas a los procesos misionales y de apoyo de la Entidad.

C. Características de control:

1. Tipo de control: preventivo.
2. Propiedades de seguridad: confidencialidad, disponibilidad e integridad.

D. Lineamientos:

1. La **Oficina de Seguridad de la Información** debe:
 - a. Asesorar los proyectos, tecnologías y/o procesos que utilicen capacidades de Inteligencia Artificial sobre la protección de la confidencialidad e integridad de la información que sea utilizada.
 - b. Elaborar y publicar los lineamientos de seguridad específicos para la adopción y uso de soluciones de inteligencia artificial - incluidos proyectos de desarrollo, software adquirido, iniciativas de mejora de procesos y servicios de terceros -. Estos lineamientos

incorporarán el marco normativo vigente de protección de datos personales y estándares de evaluación (**Ley 1581 de 2012, ISO/IEC 42001:2023 e ISO/IEC 42005:2025**) y se diseñarán en armonía con la **Política de Gobernanza de IA** vigente. Para garantizar su aplicación homogénea, la OSI pondrá a disposición de las áreas un **formato o guía estandarizada** que permita documentar las recomendaciones y controles de seguridad de la información aplicables en cada caso. De este modo, la entidad refuerza que la seguridad, la privacidad y la ética se mantengan durante todo el ciclo de vida de las soluciones de IA (evaluación, diseño, desarrollo, implantación, operación y retiro).

- c. Requerir que **todo proyecto o servicio de IA** - propio o adquirido - realice **evaluaciones de seguridad** y establezca un **plan de monitoreo continuo de sus riesgos** a lo largo de su ciclo de vida, ampliando la vigilancia a proveedores y dependencias internas que empleen estas tecnologías. Las evaluaciones se ajustarán a las normas y políticas vigentes de seguridad y de gobernanza de IA deliberadamente alineadas con la gestión de riesgos (ISO/IEC 42001:2023) y las directrices de impacto social y ético (ISO/IEC 42005:2025).

2. Los **funcionarios de la Entidad** deben:

- a. Capacitarse sobre los riesgos de seguridad y privacidad de la información asociados al uso de herramientas IA.
- b. Seguir el Protocolos de uso seguro: no ingresar datos sensibles en herramientas de IA, uso de plataformas autorizadas por la Entidad.
- c. Seguir Guías de uso ético y responsable: evitar sesgos, discriminación y uso indebido de los resultados generados por IA, para asegurar confidencialidad e integridad.
- d. Utilizar las herramientas de IA dispuestas por la **DIAN**, en caso de tener una necesidad específica que requiera la evaluación de una herramienta diferente el jefe de área debe elevar la solicitud al equipo que defina la **Política de Gobernanza de la IA** vigente, y comunicando a la **Dirección de Tecnología** y a la **Oficina de Seguridad de la Información**.

3. La **Dirección de Gestión Corporativa** debe:

- a. Definir un Equipo de Gobernanza de la I.A., designando las áreas necesarias para su funcionamiento, para la organización del equipo establece una matriz RACI con las áreas involucradas.
- b. Establecer los principios para el funcionamiento del equipo de Gobernanza de la I.A., acordando con los integrantes los objetivos con respecto al cumplimiento normativo y ético, así como la gestión de los riesgos asociados al uso de la I.A.
- c. Promover la cultura organizacional sobre el uso de la IA de forma responsable.

4. El **Equipo de Gobernanza de la I.A.** o quien corresponda en la entidad debe.

- a. **Adoptar políticas y lineamientos de seguridad y privacidad** que garanticen el uso seguro, ético y conforme a la normativa de las soluciones de IA, incorporando principios de privacidad desde el diseño y seguridad por defecto.

- b. **Diseñar procedimientos homogéneos de evaluación y monitoreo**, asegurando que todas las áreas y proveedores sigan un plan uniforme durante el ciclo de vida de la IA.
 - c. **Planificar y ejecutar monitoreo continuo** para el seguimiento y verificación de la conformidad con los lineamientos, incluyendo auditorías periódicas y alertas ante incidentes de seguridad.
 - d. **Definir procesos para la clasificación, tratamiento y protección de datos** en todas las fases del ciclo de vida de la IA, así como para la actualización segura de modelos.
 - e. Identificar y registrar todas las iniciativas que incorporen IA (propias o de terceros) en un banco de proyectos, para mantener un **inventario centralizado de soluciones de IA**; el cual debe incluir propósito, datos utilizados, algoritmos, proveedores, estado de evaluación y responsables, incluso si no fueron aprobadas o están inactivas.
 - f. **Implementar controles para asegurar la trazabilidad y auditabilidad** de los modelos y datos, mediante registros seguros y mecanismos de auditoría que permitan verificar el cumplimiento normativo y ético.
 - g. **Desarrollar programas de formación** continua en prácticas seguras de IA, protección de datos y gestión de riesgos, fomentando la responsabilidad en todas las áreas involucradas.
 - h. **Establecer protocolos para la respuesta rápida ante incidentes** de seguridad relacionados con IA, asegurando la continuidad operativa y la protección de la información.
5. **Los jefes de las dependencias** que inicien proyectos que utilizan tecnología asociadas con inteligencia artificial deben:
- a. Presentar la descripción, alcance y evaluación de seguridad de la solución – incluyendo proyectos de desarrollo, software adquirido, iniciativas de mejora de procesos y servicios de terceros - en la cual se requiera implementar el uso de IA, para evaluarlo con el equipo de Gobernanza de IA o el área que determine la Política de Gobernanza de IA.
 - b. Realizar previamente la revisión de la clasificación de la información que será utilizada en proyectos de inteligencia artificial o que involucre su uso, implementando los controles necesarios para mitigar la afectación a su confidencialidad, integridad y disponibilidad de la información que sea utilizada.
 - c. Verificar que la entidad esté alineada con las recomendaciones y sugerencias para abordar la formulación y gestión de los proyectos que incluyan el uso de Inteligencia Artificial (AI) detalladas en la guía “Marco Ético para la Inteligencia Artificial en Colombia”.
 - d. Aplicar los controles necesarios para el manejo de datos personales que sean recolectados, utilizados y analizados en los proyectos, tecnología y/o procesos de Inteligencia Artificial, teniendo en cuenta lo especificado en el “Manual para la protección de datos personales - MN-IIT-0062”.
 - e. Aplicar un enfoque de gestión de riesgos de seguridad de la información en cada fase del ciclo de vida del proyecto.
 - f. Utilizar estándares internacionales, reglamentación nacional y de la industria para los requisitos de seguridad en el uso de Inteligencia Artificial.

- g. Verificar que al iniciar un proyecto de Inteligencia Artificial se incluyan componentes para educar y capacitar al personal involucrado, promoviendo el desarrollo seguro y sostenible de estas tecnologías.

E. Controles relacionados:

1. 5.30 - Preparación de las TIC para la continuidad del negocio.
2. 5.31 - Requisitos legales, estatutarios, reglamentarios y contractuales.
3. 6.3 - Concientización, educación y capacitación en seguridad de la información.
4. 8.8 - Gestión de vulnerabilidades técnicas.

10. MARCO LEGAL Y NORMATIVO

Para el marco legal y normativo, se puede consultar el Normograma de la Oficina de Seguridad de la Información, el cual contiene las leyes, decretos, resoluciones y demás documentos aplicables como políticas, manuales, circulares, documentos CONPES y, en general, toda la normatividad relacionada con los temas tratados en este Manual de Políticas y Lineamientos de Seguridad de la Información. Consulte el normograma aquí.

<https://diancolombia.sharepoint.com/sites/diannetpruebas/Areas/OSI/Paginas/Normograma.aspx>

Los procedimientos, instructivos y formatos relacionados en este Manual de Políticas y Lineamientos de Seguridad de la Información se encuentran en este listado maestro de documentos de la entidad:

<https://diancolombia.sharepoint.com/sites/diannetpruebas/procesos/Paginas/Listado-Maestro-VI.aspx>

11. ACCIONES DE IMPLEMENTACIÓN

Las dependencias de la **DIAN** que tengan asignadas responsabilidades relacionadas en este manual deben definir un plan de acción y hacer seguimiento, para dar cumplimiento a éste.

Este Plan deberá ser elaborado y entregado a la Oficina de Seguridad de la Información, dentro de los seis (6) meses siguientes a la publicación del presente Manual. La Oficina de Seguridad de la Información puede realizar verificación de este cumplimiento.

12. CONTROL DE CAMBIOS

Versión	Vigencia		Descripción de los cambios	Tipo de información
	Desde	Hasta		
1	13/01/2022	31/07/2022	Versión inicial	Información Pública
2	1/08/2022	28/09/2022	Versión 2 que reemplaza lo establecido en la versión 1. Actualiza los lineamientos establecidos en los numerales:	Información Pública

Versión	Vigencia		Descripción de los cambios	Tipo de información
	Desde	Hasta		
			"20. Inteligencia Artificial "y, "20.1 Analítica de Datos".	
3	29/09/2022	17/11/2022	Versión 3 que anexa la identificación de los controles de seguridad digital en los numerales: 14.1.1 Análisis y especificación de los requisitos de seguridad de la información. 14.2.5 Principios de construcción de sistemas seguros.	Información Pública
4	18/11/2022	22/10/2023	Se derogan las siguientes circulares: Circular de Uso del servicio de impresión No.000033 del 08 de sept 2015 Circular de Teletrabajo No.000496 mayo 2022 Circular de Uso de computadores portátiles No.000026 del 08 de agosto de 2016 Circular de Cifrado de datos - No.00013 del 4 abril 2017 Circular de Uso de medios removibles - No. No.00017 del 30 de agosto de 2019.	Información Pública
5	23/10/2023	30/12/2025	Actualización de la Norma ISO 27001 y 27002 en la versión 2022. Se modifica la plantilla del documento	Información Pública
6	31/12/2025		Actualización enmarcada en la mejora continua del SGSPI	Información Pública

Elaboró:	Oficina de Seguridad de la Información Elaboración Técnica		Oficina de seguridad de la información
	Tito Alejandro Menjura Murcia Elaboración metodológica	Gestor II	Coordinación de Procesos y Riesgos Operacionales
	Cesar Augusto Garzón Baquero Elaboración metodológica	Gestor II	Coordinación de Procesos y Riesgos Operacionales
Revisó:	Carlos Javier Ibañez S	Gestor II	Oficina de seguridad de la información
	Nancy Paola Sánchez Moreno	Gestor II	Oficina de seguridad de la información
Aprobó:	Francisco Andrés Daza C	Jefe	Oficina de seguridad de la información